Setnayan — Privacy Compliance Dossier

For submission to the National Privacy Commission (NPC), Republic of the Philippines

> **Status: DPO-prepared submission draft — pending final external legal review before filing.** This dossier is prepared by the Data Protection Officer to support NPC registration and to serve as Setnayan's Records of Processing Activities (ROPA) and Privacy Impact Assessment (PIA). It is reasoned from RA 10173 (Data Privacy Act of 2012), its IRR, and NPC issuances. It is **not legal advice**; the Personal Information Controller should have it reviewed by external counsel before submission.

> **Prepared:** 2026-07-12. **Version:** 2.0 (last updated **2026-07-13**). **Governing law:** RA 10173 + IRR + NPC Circulars.

> **Revised 2026-10-22.** This dossier is a 2026-07 snapshot and its body is kept for lineage. Its sub-processor table (§ "Subprocessors") and analytics row were corrected today; **for every other fact, the current statement is the revised pack** — Privacy Manual v1.1, ROPA DPS-01 → DPS-28, NPCRS v1.1 and `NPC_Compliance/00_WHAT_CHANGED_2026-10-22.md` — which supersede this text where they differ (notably: vendor government ID / liveness / AMLC retired 2026-07-03; PostHog removed 2026-10-22; account deletion is request → 24-hour review → anonymise-and-retain; the compressed gallery is kept for life; face selfies erased 12 hours after the event). DPO contact: dpo@setnayan.com.

> **(!) DO NOT LODGE — three defects open (2026-07-20). A compliance pass this session found three statements in this draft that do not match the shipped system, all verified against `origin/main` @ `5b72d625d`. Corrections, drafted replacement text, and the resolutions the owner/DPO must pick are in `Papic_Compliance_Delta_2026-07-20.md`. In summary: (1) §8a `:170` tells the NPC full-res is kept 6 months while the shipped constant is 90 days, and calls the compressed copy retention *"indefinitely"* against the 5-year media period in the filed Data Retention Schedule (Delta §1 — this also blocks all retention marketing copy); (2) the ROPA has no row for Papic-captured photographs and clips — media collected on real events today (drafted row 21 at Delta §2.2, `[PENDING DPO]`); (3) §11 item 7 + ROPA row 20 tell the regulator the Papic Lite pool *"is built but flag-OFF"* — it does not exist (zero code matches) and the product was cancelled 2026-07-20 (Delta §3). None of these establishes unlawful processing; all three are accuracy defects in an unlodged draft, and all three are document edits. A fourth item — whether the RSVP consent copy actually names guest-phone capture and face-sorted delivery — is recorded for DPO ruling at Delta §4.**

> **What changed in v2.0 (2026-07-13):** the ROPA (§3) and the sensitive-personal-information declaration (§5) were expanded from a customer-centric, biometric-only scope to cover **every category the platform actually processes** — self-profile religion / civil status / gender, the dependents & godparents family graph (minors' data), event honoree / specialty data (incl. christening child data and gender-reveal due-date), e-gift receiving handles, and the vendor-verification identity surface. The subprocessor list (§7) was completed (Persona, TikTok, Suno added). Retention (§3, §8a) was aligned to the **Data Retention Schedule (2026-07-11)** with its statutory floors. Driven by the reconciliation in `Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md`. Items still requiring owner/counsel action are consolidated in §11.

1. Personal Information Controller (PIC) and Data Protection Officer (DPO)

Field	Detail
Registered business name	SETNAYAN SOFTWARE DEVELOPMENT SERVICE
Legal form	Sole proprietorship (DTI-registered 2026-06-25, national scope)
PIC under RA 10173	The proprietor. A sole proprietorship has no legal personality separate from its proprietor, so the proprietor is the Personal Information Controller.
Data Protection Officer	The proprietor (Indalecio S. Casasola II), serving the DPO function directly
DPO contact	dpo@setnayan.com *(owner-locked 2026-07-24 as the single published DPO contact — this is the address on the live `/privacy` page and the one registered with the NPC DPO system on 2026-07-07. The earlier `dpo@setnayan.com` variant is retired; all documents align to `dpo@setnayan.com`.)*
Data subject response SLA	15 business days *(the period published in the live privacy notice. The older binding Privacy & Security Policy §9 states 7 business days and is to be reconciled up to 15 — see §11.)*
BIR registration	Under the proprietor's existing TIN
NPC registration	To be filed under the registered business name
Public privacy notice	Published at `setnayan.com/privacy` (effective 2026-05-13; **last updated 2026-07-13** via app PR #3215, adding the faith / family / honoree / e-gift disclosures + Anthropic/Suno subprocessors). The opt-in **biometric** and **device-identifier** sections were already present on `origin/main`.

2. Description of the Data Processing System

Setnayan is a Philippines-first life-events platform (V1 surface: weddings, with additional event types — birthday, debut, christening, gender reveal, anniversary, reunion, corporate and others — progressively enabled). It provides three role-routed doorways:

- **Couples / customers** plan an event end-to-end (guest lists, vendors, budget, schedule, invitations, media galleries) and optionally record personalization and family-milestone details.
- **Vendors** run a business profile, submit verification documents, and receive inquiries.
- **Administrators** (the Setnayan team) run operations, payment reconciliation, and integrity / fraud review.

Personal data is processed to deliver the planning service, to enable couple↔vendor communication, to process in-app payments, to verify vendor legitimacy, and to protect the marketplace from fraud. Processing is web-based; data resides with the subprocessors in §7.

3. Records of Processing Activities (ROPA)

Personal-data categories, purposes, legal bases, and retention. Retention detail is maintained in the companion **Data Retention Schedule (2026-07-11)**; periods marked *(counsel)* await external ratification. **Build-state** column: *Active* = collected in production now; *Gated* = shipped behind a feature flag; *Dormant* = built but not yet collecting.

#	Data category	Data subjects	Purpose	Legal basis (RA 10173)	Retention	Build-state
1	**Account / profile** — email, hashed password, display name, optional phone, profile photo	Couples, vendors, admins	Account creation + authentication; deliver the service	§ 12(a) consent; § 12(b) contract	Life of account + 30-day soft-delete tail, then purge	Active
2	**Self-profile personalization — religion, civil status, gender/sex** *(sensitive PI)* + per-field consent timestamps (`religion_consent_at`, `civil_status_consent_at`, `sex_consent_at`)	Account holders (adults)	Optional personalization — faith-appropriate suggestions, event-type relevance, salutation. Reference-only; not required to use the service	§ 13(a) **explicit consent** (self-provided, timestamped; withdrawable)	Life of account; cleared on withdrawal or account deletion	**Active** (self opt-in; no feature flag)
3	**Event data** — guest lists, vendor records, budget items, schedule, mood-board palettes	Couples (and guests they enter)	Deliver event-planning features the user is paying for	§ 12(b) contract	5 years from event date *(counsel)*	Active

4	**Event honoree / specialty details** — e.g. christening **child name, birth date, gender** + rite; gender-reveal **parents' names + expected due-date**; birthday celebrant name + age; debut celebrant; wedding **ceremony rite** *(contains sensitive PI + minors' data — see §5)*	Couples; the named honoree (may be a minor or a non-account third party)	Configure the specific event the couple is planning	§ 12(b) contract; § 13(a) consent of the enrolling account holder / guardian for the honoree's sensitive attributes	With the event record, 5 years from event date *(counsel)*	**Active** (in `events.signature_detail` no feature flag, no separate consent timestamp — documented as-is; see §11)

5	**Family graph — dependents & godparents.** A dependent is a **person, a pet, or anything the user cares for** (`dependent_kind`). Only the **person** kind may carry name + **birth date, sex, religion** (+ guardian-consent timestamps) under the age fence; **pet / other carry only a name + optional birthday — no sensitive data.** Godparent: name, **email** (a third party), role, reminder preference	Account holder; their **person-dependents (which may be a minor or an elder)**; godparents (third parties)	Optional milestone tracking (upcoming faith rites, godchild-birthday reminders)	§ 12(b) contract; § 13(a) **guardian consent** (timestamped) for a person-dependent's sensitive attributes; § 12(f) legitimate interest for godparent reminders	Life of account; deleted on withdrawal / account deletion. A **person-child** shared record is readable by a spouse account under a household model and **retained after separation** for continued co-parenting access (owner-defined)	**Enabled in production** (owner/DPO flipped `NEXT_PUBLIC_DEPENDENT_PEOPL` 2026-07-16). **Ownership transfer at majority (2026-07-16/17):** a person-dependent's record can be CLAIMED by the data subject at 18 (RA 6809 age of majority — 18 for both sexes, distinct from the 18F/21M debut celebration ladder) via a single-use, 7-day, guardian-revocable link (bearer token; excluded from data exports; optionally emailed to a recipient address that is used once and stored nowhere). On claim, **ownership of the record moves to the data subject** — they gain full control including erasure; the former guardian retains read-only history; the record thereafter survives the guardian's account deletion and is deleted with the SUBJECT's account. Elders (already past majority) are claim-eligible from day one. Pet/other records never convert to an account; care can only be reassigned guardian→guardian. Godparent edges transfer with the claimed record.

6	**In-app messages** — couple↔vendor chat	Couples, vendors	Enable coordination between parties	§ 12(b) contract	5 years from event date *(counsel)*	Active
7	**Payment metadata** — order amounts, reference codes, channel, payment-proof screenshots	Paying users	Process + reconcile in-app payments; issue Official Receipts	§ 12(c) legal obligation (NIRC / BIR)	**10 years** — legal floor (BIR RR 17-2013)	Active
8	**E-gift receiving methods (Pabuya)** — the couple's own GCash / Maya / bank / PayPal handle, account name, and uploaded receiving-QR image	Couples	Display the couple's own gift-receiving details to their guests. **Setnayan never holds, routes, or records the movement of money** — the schema stores no amount, ledger, or settlement state	§ 12(b) contract (couple's own display data)	With the event record; deletable by the couple anytime	**Active** (public guest route reported enabled in production 2026-07-13)
9	**Contracts + e-signatures**	Couples, vendors	Vendor engagement records	§ 12(c) legal obligation; Civil Code Art. 1144	**10 years** — legal floor	Active
10	**Vendor-verification identity data** — government ID, business permits / registrations, and (where applicable) liveness selfie and sanctions / PEP screening result *(sensitive PI — see §5)*	Vendors (business owners)	Verify vendor legitimacy before a profile is trusted; marketplace safety	§ 12(b) contract; § 12(c)/(f) (fraud + AMLA-adjacent diligence)	Verification documents 90 days hot → cold retention to the statutory floor *(counsel)*	**Active** (documents collected; automated verification via Persona is staged — see §7)

11	**Biometric — facial-geometry vectors** *(sensitive PI)*	Guests/users who opt in (adults 18+)	Optional automatic photo-matching within a single event	§ 13(a) **explicit opt-in consent**, timestamped at enrolment	Per-event only; never reused across events; revocable on request. **Facial-geometry vector auto-expired (nulled) at ~5 years** by a scheduled per-event sweep (anchor = later of event date / enrolment); the underlying photo is retained. Selfie-asset purge-at-expiry is a DPO decision — §11	**Built; vector storage Dormant** (enrolment image-only until the matching model activates) — see §5
12	**Device identifier** — one-way hashed, first-party per-browser id	Signed-in users	**Fraud prevention** — detect fake / duplicate / sock-puppet accounts	§ 12(f) **legitimate interest** (fraud prevention + protecting vendors)	Life of account; rolling-prune device rows unused > 24 months *(counsel)*	**Dormant** — flag `NEXT_PUBLIC_DEVICE_FING` OFF in production; collects nothing pending DPO activation (§4)
13	**Guest RSVP details** — name, contact, **meal preference / dietary restrictions** *(health-adjacent)*, plus-one, photo/face-recognition preferences	Guests entered/invited by the couple	Deliver RSVP, seating, catering counts, and media-tagging preferences	§ 12(b) contract; § 13(a) consent for dietary/health-adjacent + face-recognition preferences	With the event record, ≤5 years *(counsel)*	Active
14	**Automatic technical data** — IP address (truncated to first 3 octets for QR-scan events), browser user-agent, timestamps	Site visitors	Security, abuse-prevention, service operation	§ 12(f) legitimate interest	Provider default / with related record	Active

15	~~**Product analytics**~~ — [X] **CORRECTED 2026-10-22: PostHog removed (PR #6774); no analytics service, no analytics cookie, no consent banner.** Replaced by first-party daily Visits aggregates with a daily-destroyed salted hash (ROPA DPS-21)	Site visitors	Site operation	§ 12(f) legitimate interest	Hashes 1 day; aggregates hold no personal data	Active (Visits)
16	**Error/diagnostic logs** — stack traces (Sentry; no message bodies, payment details, or guest data)	N/A (no PII by design)	Bug diagnosis + reliability	§ 12(f) legitimate interest; data-minimization	≤ 90 days	Active
17	**Marketing consent / communication preferences** (+ `marketing_consent_at`)	Couples, vendors	Proof of consent; honor preferences	§ 12(a) consent	Life of account + audit tail	Active
18	**Support tickets**	Users who contact support	Handle support requests	§ 12(b)/(f)	2 years	Active

19	**Samahan (group) memberships** — the group's **user-chosen name**, optional description, the member's role (organizer/member), join date, and a rotating invite token. **No classification/category field exists by design** (owner 2026-07-17): the platform never labels a group's nature or affiliation — the old `kind` taxonomy (which included `parish`, a religious-affiliation signal) was **removed at the schema level**, so no query, export, or breach can enumerate members by group type. A group's free-text name is the group's own speech, not a platform-assigned category	Account holders who create or join a samahan	User-initiated group formation (barkada/clan/org/etc. as THEY name it); rosters visible to fellow members only	§ 12(b) contract (user-initiated membership)	Membership row deleted on leaving the group or account deletion; included in the data export (`samahan_memberships`)	Active (live product); disclosed in the privacy notice "Samahan (groups)" section (2026-07-17)

~~20~~	(!) **WITHDRAWN 2026-07-20 — NEVER BUILT, PRODUCT CANCELLED. Do not lodge this row.** The flag named below (`NEXT_PUBLIC_PAPIC_LITE_ENABLED`) **does not exist in the codebase** — zero matches across `apps/web` + `supabase` @ `origin/main 5b72d625d` — and the product was cancelled 2026-07-20 before any processing occurred. Replacement note + rationale: Papic_Compliance_Delta_2026-07-20.md §3. (!) *"Papic Lite" also names a SHIPPED vendor on-the-day tier and a quality alias — see Delta §3.3 before deleting anything by name.* Original row text follows for lineage: **Papic Lite — open/crowd photo capture** (public-event QR; **photos only, no video, biometric-free — no facial-geometry vectors**). A shared photo pool for a large public event; captures **photographs that may include non-participant bystanders**; optional participant **join email** (magic-link claim) + consent timestamp + device/IP-hash (Sybil control)	Public-event attendees + bystanders; the hosting organizer (controller of the pool)	Let a host collect one shared photo pool for a public/large event (concert, tournament, corporate); each joiner keeps their own shots	§ 12(b) contract (host); § 12(a) join-consent (participants); bystander images on a public-space + posted-host-notice basis *(counsel)*	Full-res 6-month window then dropped; compressed gallery ≤5y. **Erasure = a public takedown/complaint form** (routes to host + admin) — the subject-access mechanism *because Lite has no face-search*	**Gated** — `NEXT_PUBLIC_PAPIC_LITE_` OFF in production; collects nothing until enabled, **blocked on DPO + external-counsel sign-off + a CSAM matcher** (see §11)

> (!) **ROPA GAP (2026-07-20) — a row is MISSING.** No row above covers the **photographs and ≤5-second clips Papic captures on guest and shooter phones** — row 3 ("Event data") does not name media, row 11 is the biometric *vector*, row 13 is an RSVP *preference*, and row 20 is withdrawn. This media is being collected on real events today. A drafted **row 21** (purpose, lawful basis, categories, subjects, retention, recipients, build-state) is at `Papic_Compliance_Delta_2026-07-20.md` §2.2, marked **`[PENDING DPO]`**.

> (!) **2026-07-30 — DO NOT FILE THE 2026-07-20 ROW-21 TEXT AS WRITTEN.** It says *"≤5-second video clips"*; the cap became **10 seconds** on 2026-07-22, so the old text would misstate a data category to the regulator. It also predates the two-type Pool/One model and guest-purchased shots. The corrected row 21, **plus two further missing rows** — **22** guest-authored public columns and **23** in-app voice/video calls (which owes a **Cloudflare TURN** subprocessor disclosure) — are drafted in `ROPA_Drafted_Rows_2026-07-30.md`, all **`[PENDING DPO]`**. That file also records that **two undeclared privacy-sensitive controls (`papic_pool_gallery`, `guest_columns`) went ACTIVE in prod on 2026-07-27** — live processing with no filing row, which is the sharpest form of this gap.

Right-to-erasure interaction: an account-deletion request deletes the subject's personal data **except** records under a legal-hold floor (rows 7 & 9 — payments and contracts), which are retained under the legal-obligation basis for the statutory period and then disposed of. This carve-out is disclosed in the privacy notice. *(Known remediation: account hard-delete does not yet purge chat-message PII — tracked in §11 and the Data Retention Schedule §4.)*

---

4. Privacy Impact Assessment — Device-Fingerprint Capture (fraud prevention)

A PIA of the **newest and most scrutiny-worthy** processing activity (ROPA row 12). **LIVE — collecting in production since 2026-07-12.** (!) CORRECTED 2026-08-17: this was described as built-but-switched-off. Measured in production on 2026-08-17: 9 device rows across 4 accounts, first written 2026-07-12, most recent the same day as this correction. The 2026-07-23 instruction to hold it off was SUPERSEDED on 2026-07-24 by the owner-locked Interim Payments & Privacy Deferral Policy, which deliberately activated it; the live public /privacy notice discloses device-fingerprint processing accordingly. Basis relied on: RA 10173 §12(f) legitimate interest (fraud prevention). STILL OWED: the documented legitimate-interest assessment (NPC task t2-10). Collection is coarse and first-party — a random id in localStorage, hashed server-side, raw never stored; no canvas/behavioural fingerprint and no external SDK; secured accounts only. *(As of 2026-07-13 the flag `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` is confirmed OFF in production. A separate draft Anti-Fraud Policy amendment references this processing as active from 2026-07-07; that statement is ahead of the actual flag state and is being corrected — see §11.)*

4.1 What is processed and why

To protect couples and vendors from coordinated fraud (a single bad actor — often a competing vendor — spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer an inquiry), Setnayan must recognize when several "different" accounts are in fact the **same device**. On a signed-in session, the browser generates a **random identifier** stored in local storage; it is transmitted to Setnayan's server and **one-way hashed (SHA-256 with a server-side salt)**. Only the hash is stored, against the account. Two accounts sharing a device produce the same hash, which lets the existing fraud-clustering logic **flag them for human review** — it never auto-bans anyone.

4.2 Necessity and proportionality

- **Necessary:** vendors are charged per inquiry; fake inquiries are a direct, quantifiable financial harm, and account-level signals alone cannot detect one actor behind many accounts.
- **Proportionate / least-intrusive:** the signal is a **random id**, deliberately **not** a behavioral or biometric fingerprint (no canvas/font/WebGL probing) and uses **no third-party tracking SDK**. It identifies a *browser*, not a person's activity, and is never used for advertising, personalization, or cross-site tracking.

4.3 Legal basis

Legitimate interest under § 12(f): preventing fraud and protecting the marketplace and its vendors. Balancing test — the intrusion is minimal (a fraud-only pseudonymous hash), the interest is substantial, and the practice is disclosed. The data is **not** sensitive personal information.

4.4 Risks and mitigations

Risk	Mitigation
Re-identification of an individual	Value is a **one-way hash of a random id** (raw value never stored); pseudonymous; no linkage to browsing behavior
Function creep (used beyond fraud)	**Purpose limitation** enforced in code + policy; used only for identity-cluster fraud review; never sold or shared
Over-collection	**Signed-in accounts only**; one hash per (account, device) + a last-seen timestamp; **no IP stored** for this signal
Data-subject unawareness	**Already disclosed** in the public privacy notice (the "Device identifier (fraud prevention)" section), ahead of activation
Unlawful retention	Retention clock (life of account; rolling-prune > 24 months); included in data export; deleted on account deletion
Activation without oversight	**Flag-gated OFF**; activation requires DPO sign-off; fully reversible from a single toggle

4.5 Residual assessment

With the above controls, residual privacy risk is **LOW**. The privacy-notice disclosure is already published; the remaining gate is the DPO's activation decision.

---

5. Sensitive Personal Information (RA 10173 § 13)

RA 10173 § 3(l) / § 13 treats as **sensitive** an individual's race/ethnic origin, marital status, age, religious/philosophical/political affiliations, health, education, genetic or sexual life, and government-issued identifiers, and gives biometric data special status. Setnayan processes the following sensitive categories, each on the noted basis:

Sensitive category	Where it appears	Basis	Safeguards
Religion / faith	Self-profile `religion` (ROPA 2); wedding **ceremony rite** and Islamic-rite fields (mahr, seating posture, wali/witness/imam roles) and Chinese/Tsinoy rite (ROPA 4); dependent's religion (ROPA 5)	§ 13(a) explicit consent (self / guardian), timestamped where captured at profile level	Optional; withdrawable; never sold or used for advertising; faith surfaced only to the couple's own event workspace
Marital / civil status	Self-profile `civil_status` (ROPA 2)	§ 13(a) explicit consent, timestamped	Optional, reference-only

Age / minors' data	A **person**-dependent's **birth date** — only `kind=person`, and only a child (<18) or elder (>50); pets/other excluded (ROPA 5); christening **child birth date + gender**; birthday **celebrant age** (ROPA 4)	§ 13(a) guardian consent; § 12(b) contract	Minors' data arises only where the responsible adult enters a child — it is **not the defining purpose** of the dependents table; heightened-care handling
Health-adjacent	Guest **dietary restrictions / meal preference** (ROPA 13); gender-reveal **expected due-date** (ROPA 4)	§ 13(a) consent	Collected only where the event requires it; not used beyond the event
Gender / sex	Self-profile `sex` (ROPA 2); dependent / honoree sex (ROPA 4-5)	§ 13(a) consent, timestamped at profile level	Optional; reference-only
Biometric — facial geometry	Optional per-event photo-matching (ROPA 11)	§ 13(a) explicit opt-in consent, timestamped	Adults 18+; **scoped to a single event, never reused across events**; consent withdrawal permanently deletes the vector + selfie; **vector storage currently dormant** (enrolment image-only until the model activates)
Government ID + sanctions/PEP screening	Vendor verification (ROPA 10)	§ 12(b)/(c)/(f)	Vendor business owners only; restricted-access; retained to the statutory floor then disposed

Users who provide none of the optional categories (religion, civil status, gender, biometric enrolment, dependents) supply no sensitive personal information beyond what a given event type strictly requires. The presence of these sensitive categories is a basis for **NPC registration** (§ 5 IRR registration triggers).

> **Note (2026-07-13):** the public notice **already** carries an accurate opt-in **Biometric data (facial recognition)** section (explicit consent, adults 18+, per-event scope, withdrawal → permanent deletion) and a **Device identifier (fraud prevention)** section — the earlier "notice denies biometrics / omits the device identifier" concern came from a **stale local checkout**, not the deployed `origin/main`. Face-vector storage is currently **dormant** (enrolment image-only until the matching model activates), which the section's opt-in framing already accommodates.

---

6. Data Subject Rights (RA 10173 § 16)

Setnayan honors the rights to be **informed, access, object, rectify/correct, erase or block, data portability, and to lodge a complaint / claim damages**. Operationally:

- **Access + portability:** a self-service "download my data" export (iteration 0025) that includes the sensitive-personalization and family-graph fields.
- **Erasure/blocking:** soft-delete → hard-delete of account data, subject only to the legal-hold carve-out (§ 3). Withdrawing religion / civil status / gender / biometric / dependent consent deletes the corresponding data.
- **Objection/withdrawal:** (analytics opt-out retired 2026-10-22 — there is no analytics to opt out of); face-recognition consent revocation (deletes the vector); marketing-preference controls.

- **Correction:** profile/settings self-edit.
- **Complaints:** routed to the DPO at dpo@setnayan.com; **15-business-day** response SLA; the data subject retains the right to complain to the NPC.

---

7. Subprocessors and Cross-Border Transfers (§ 21)

Setnayan uses the following subprocessors. Cross-border transfers rely on § 21 and each provider's adequacy/contractual commitments.

Subprocessor	Function	Location	Notes
Supabase	Database + authentication	Singapore	Primary data store; RLS enforced
Vercel	Web application hosting	US company; functions in Singapore (`sin1`)	Updated 2026-10-22
Cloudflare	R2 object storage (media) · TURN live-video relay · Turnstile bot check · STUN	Asia-Pacific (APAC) buckets; global network	Relay and bot check only when their keys are set (updated 2026-10-22)
Resend	Transactional email	United States	
Sentry	Error monitoring — server and browser; masked replay on a browser error (all text masked, media blocked); e-mail / phone / face-vector scrubbing	United States	Updated 2026-10-22 (was "server-side, stack traces only")

~~PostHog Cloud~~	~~Product analytics~~	—	[X] **REMOVED 2026-10-22 (PR #6774)** — essential cookies only, no banner, no analytics SDK
Anthropic	Payment-receipt reading · supplier Deep Search · supplier gallery screening · theme sentence	United States	No training on user data; never decides a payment (updated 2026-10-22)
OpenAI	Moderation of published couple / guest text	United States	Added 2026-10-22
LanguageTool	Grammar check (free public API)	Germany (EU)	Added 2026-10-22 — no DPA possible on the free endpoint
Apple	Sign in with Apple; App Store in-app purchase (built, switched off); iTunes song search	United States	Added 2026-10-22
Meta · OpenStreetMap · Vimeo · browser push services	Social posting / Instagram sync · maps · poster image · web push	US / UK / various	Added 2026-10-22

~~Persona~~	~~Vendor identity verification~~	—	[X] **RETIRED 2026-07-03, struck 2026-10-22** — never engaged, no data ever sent
Google LLC	Sign-in (behind a switch); Google Drive / YouTube (only when the user connects); Gemini image model for paid mood-board renders; STUN	United States	OAuth, opt-in; Google **Limited Use** commitment (no AI/ML training). Updated 2026-10-22
TikTok	Patiktok video publish (only when the user connects the optional integration)	United States / Singapore	OAuth, opt-in; scopes limited to profile + video upload/publish
Suno	AI music, used by hand by the team	—	**Not called by the code**; no personal data — not a processor (updated 2026-10-22)

Backblaze B2	Cold object storage — Papic compressed-gallery cold tier at scale	United States	**Not yet active** — flag-gated; engaged only once the aggregate cold pile reaches ~tens of TB
CSAM hash-matching provider (e.g. PhotoDNA / NCMEC)	Known-illegal-image hash matching for **any open-crowd capture (corporate / tournament)** — *restated 2026-07-20: the cancelled "Papic Lite" product is no longer the trigger; the duty travels with open-crowd ingest (`Papic_Compliance_Delta_2026-07-20.md` §3.2)*	United States	**Not yet engaged** — and **no open-crowd capture is offered in V1**; mandatory-repo duty to be reviewed by counsel before any such capture ships

Cross-border destinations disclosed (updated 2026-10-22): Singapore (Supabase; Vercel functions), United States (Vercel company, Cloudflare account plane, Resend, Sentry, Anthropic, OpenAI, Google, Apple, Meta, Vimeo), Germany (LanguageTool), United States/Singapore (TikTok). PostHog removed; Persona retired; Suno not called. Media objects reside in Cloudflare R2 buckets in the Asia-Pacific (APAC) region (there is no Philippines region in R2).

---

8. Organizational, Physical, and Technical Security Measures

- **Access control:** database Row-Level Security (RLS) on all tables (enabled at table creation); role-scoped access; two-admin approval gates for major administrative decisions.
- **Cryptographic controls:** passwords hashed; the device identifier is a **one-way salted hash** (raw value never stored); OAuth grants encrypted at rest; transport over TLS.

- **Data minimization:** analytics carry no personal identifiers; error logs exclude message bodies, payment details, and guest data; IP truncated to 3 octets for QR-scan events. *(Minimization item: some aggregate dashboard views load fuller records than they display — a tightening pass is tracked in §11.)*
- **Content safety:** an NSFW filter is on by default and cannot be disabled.
- **Confidentiality by design:** vendor identity masking (a vendor sees only the couple's event display name + date, never their email or personal name unless shared).
- **Residency:** database in Singapore; media in Cloudflare R2 **Asia-Pacific (APAC)**. (!) **CORRECTED — there is no PH region in R2**, and the old wording implied a Philippine residency we do not have.
- **Breach response:** the DPO coordinates assessment and any NPC + data-subject notification within the periods required by the NPC's breach rules.

8a. Retention governance

Retention is bounded on both ends: **RA 10173 storage-limitation** as the maximum, and **statutory floors** as the minimum for financial and contractual records (BIR RR 17-2013 = 10 years for payments/Official Receipts; Civil Code Art. 1144 for contracts). Per-class periods are maintained in the **Data Retention Schedule (2026-07-11)**; periods marked *(counsel)* await external ratification.

> [OK] **RESOLVED 2026-08-07 — and read this before "fixing" the paragraph below.** The superseded note here told the reader that the paragraph beneath it — *"a compressed web copy is retained indefinitely"* — had to be reconciled DOWN to a 5-year purge, and declared itself blocking on "all retention marketing copy". **That is exactly backwards, and it is the single most likely cause of this error recurring a fourth time.**

> **What is true:** *"indefinitely"* for the compressed copy is **correct and stays**. It is the owner's lock ("free forever, never deleted"), it is what the code does, and the 5-year media period it was measured against has itself been retracted in `Data_Retention_Schedule_2026-07-11.md` row 2. Only the day numbers moved: the full-resolution window is **6 months from the event's first capture, floored at 3 months after the event date** (`DEFAULT_FULL_RES_RETENTION_DAYS = 183`, `FULL_RES_POST_EVENT_GRACE_DAYS = 92`), not the 90 days this note cited.

> **AND NOTHING IS DELETED.** The full-resolution original is **replaced by** the compressed copy, which the gallery keeps for good; `isEligibleForDrop` refuses to act at all when that copy is missing. Owner, twice: *"again. not delete. just compress."* **Do not re-introduce a 5-year media purge into any copy, filing or marketing sentence.**

> **What genuinely remains open** is narrower: the lawful **BASIS** for indefinite retention of photographs of identifiable people (including guests who are not our customers), not the period. That reasoning must be written down and reviewed by counsel before lodging — "the owner decided" is not a lawful basis.

Papic media lifecycle (2026-07-17). Captured photos and 5-second clips are kept at full resolution for **6 months** (for the couple to download or sync to their own Google Drive). After the window the full-res original is **replaced by the compressed web copy** in Setnayan storage (the photo itself remains in the gallery), unless the couple has synced the original to their Drive; a **compressed web copy** (photos + compressed clip copies) is retained on the couple's gallery **free, for life** as the serving copy (owner 2026-08-18, *"we keep it for life"*, superseding the 2026-08-07 five-year window and its never-built paid option; nothing was ever deleted under either) — so no media type carries an unbounded FULL-RESOLUTION tail. Optional facial-geometry vectors (ROPA 11) auto-expire per event at ~5 years; the account-level face profile is governed by account deletion, not this per-event clock. Papic Lite (ROPA 20) is photos-only and biometric-free.

9. Compliance Statement

Setnayan processes personal data under RA 10173 on the bases recorded in § 3, with retention bounded on both ends (RA 10173 storage-limitation as the maximum; BIR/Civil Code statutory floors as the minimum for financial and contractual records). Data subject rights are implemented and honored; sensitive personal information (religion, civil status, gender, minors' data, health-adjacent data, biometric, and vendor government-ID) is processed only on the bases in § 5; the fraud-prevention device identifier is minimized, pseudonymized, and DPO-gated (currently dormant). The DPO is the proprietor and is the point of contact for the NPC and for data subjects.

Prepared by (DPO): ___ (Indalecio S. Casasola II) — dpo@setnayan.com

Date: 2026-07-13

10. Appendix — companion documents

- `Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md` — the reconciliation that drove the v2.0 expansion.
- `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md` — DPO one-pager for the device-fingerprint processing.
- `Data_Retention_Schedule_2026-07-11.md` — full per-class retention schedule + `[PENDING COUNSEL]` items.
- **`Papic_Compliance_Delta_2026-07-20.md` — (!) the three open defects in THIS draft (retention 90 d vs 6 mo · missing media ROPA row · the false "Papic Lite is built" claim) plus the RSVP-consent question for DPO ruling. Read before lodging.**
- `NPC_Compliance/` pack — the deeper filing set (Privacy Manual, full RoPA, DPO Designation + NPCRS data sheet, Breach Policy, DPIA register, Face-Vector DPIA, Anti-Fraud DPIA). This dossier is the executive summary over that pack; the two must be kept consistent.
- `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` — the binding public policy (to be reconciled per §11).
- Public privacy notice — `setnayan.com/privacy`.
- `[[dpo-designation-owner]]` — DPO designation record.

11. Open items before filing (owner / DPO / external counsel)

Blocking on external counsel (this dossier is not legal advice):
1. External counsel review of this dossier + the retention periods marked *(counsel)*, with specific attention to the **§ 3(l) / minors' data** cluster (dependents, christening child data, godparent third-party notification) and the vendor **AMLC/PEP + government-ID** screening basis.
2. Confirmation of the **NPC registration threshold** applicable to the business.

Owner / DPO actions (documentation + product):
3. **Public privacy notice — DONE (app PR #3215, 2026-07-13):** added the **faith / family / honoree / e-gift** disclosures + Anthropic/Suno subprocessors; the opt-in **biometric** and **device-identifier** sections were already present. Remaining notice work is wording refinement by counsel, not a coverage gap.
4. **Reconcile the older corpus documents** to the values in §1: standardize the DPO contact to `dpo@setnayan.com` (owner-locked 2026-07-24; the `dpo@setnayan.com` variant is retired) and the 7-business-day SLA → 15 in the binding Privacy & Security Policy; add the **10-year floor** and the **vendor-verification retention class** to that policy's §4 retention table; add **Persona, TikTok, Suno** to its §10 subprocessor table.
5. **Device-fingerprint status:** correct the draft Anti-Fraud Policy amendment's "active since 2026-07-07" language to

match the confirmed **flag-OFF** state, and gate the notice disclosure to activation.
6. **Known product remediation** (tracked, not blocking this draft): account hard-delete does not yet purge chat-message PII (Retention Schedule §4); the `events.signature_details` honoree fields (christening child data, gender-reveal due-date) collect sensitive data without a per-field consent timestamp — **documented as-is per owner direction**, flagged here for a future consent-instrumentation pass; and the dashboard data-minimization tightening in §8.

Papic v3 (added 2026-07-17):
7. (!) **WITHDRAWN 2026-07-20 — this item states a falsehood about our own system.** The pool described below was **never implemented** (no flag, table, route or migration; zero code matches) and the product was **cancelled 2026-07-20** before any processing occurred. Replacement wording is drafted at `Papic_Compliance_Delta_2026-07-20.md` §3.2; the bystander / minors-in-crowd / CSAM questions are **deferred, not closed** — they attach to any future open-crowd event type. Original text for lineage: *Papic Lite public-launch gate (counsel + DPO) — blocking Lite only.* The open, public-QR photo pool (ROPA 20) is built but flag-OFF. Enabling it requires sign-off on: bystander/subject consent at QR-join; the **public takedown/complaint mechanism** that serves the erasure right absent face-search (Lite is biometric-free); a minors-in-crowd notice (concerts/reunions/tournaments); and a **CSAM known-hash matcher + mandatory-reporting** review before an anonymous public upload endpoint goes live. Wedding Papic is unaffected.
8. **Face-vector 5-year expiry (DPO).** Confirm the expiry anchor (event date vs enrolment) and whether the enrolment **selfie** biometric asset is purged at expiry or retained (default proposed: null the vector, retain the photo). Add the sweep to the Data Retention Schedule + Face-Vector DPIA.
9. **(!) Security-statement reconciliation (before filing).** §8 states "OAuth grants encrypted at rest," but the Papic build review found the Google-Drive `oauth_grants.refresh_token` / `access_token` stored **in plaintext** today. Either implement application-layer encryption to make the statement true, or correct §8 — a submission must not overstate a technical control.

> **Filing note.** This is a complete, DPO-prepared submission draft: the ROPA, PIA, sensitive-PI declaration, subprocessor list, security measures, and data-subject-rights implementation are all present and reconciled to the as-built platform as of 2026-07-13. It is **ready for external counsel review**, which — together with items 1-2 above — is the final gate before lodging with the NPC.

Setnayan — NPC / RA 10173 Compliance Documentation Pack

Date assembled: 2026-07-05 · **Revised 2026-10-22** — pack refreshed against the shipped code; start with `00_WHAT_CHANGED_2026-10-22.md`.
PIC: SETNAYAN SOFTWARE DEVELOPMENT SERVICE (sole proprietorship of Indalecio S. Casasola II · DTI Business Name No. 8297508)
DPO: Indalecio Sacdalan Casasola II · dpo@setnayan.com (published contact since 2026-09-22)
Status: NOT yet filed — filing scheduled January 2027 (owner, 2026-07-30). Three documents are ADOPTION-READY v1.1 awaiting the DPO's signature (01 Manual, 03 Designation + NPCRS, 04 Breach Policy); the rest are drafts. Every document is built to a compliant RA 10173 / NPC baseline ahead of counsel. For DPO (the owner) + PH counsel finalization, then filing/keepsake. **Not a substitute for legal review.**

What this pack is

The formal records a Personal Information Controller keeps on file and uses to register with the **National Privacy Commission (NPC)** under the Data Privacy Act of 2012 (RA 10173). This is your **keepsake + filing set**.

#	Document	Purpose
01	**Privacy Manual**	The flagship RA 10173 governance document (present to NPC on request) — 12 sections: scope, definitions, governance + security, principles, lifecycle, the 8 data-subject rights, consent, sub-processors/cross-border, breach, DPIA, complaints, versioning
02	**Records of Processing Activities (RoPA)**	Data-processing-systems inventory (**28 systems, DPS-01 → DPS-28**, revised 2026-10-22) + the NPC-registration threshold analysis
06	**DPIA — Face Vectors**	Full DPIA for biometric face matching (revised 2026-10-22)
07	**Compliance Facts Register**	Single source for the owner-supplied facts + sub-processor table (revised 2026-10-22)
08	**DPIA — Anti-Fraud, Trust & Integrity**	Full DPIA for identity clustering + auto-suspend (revised 2026-10-22)
—	**`00_WHAT_CHANGED_2026-10-22.md`**	One page: what changed, what the DPO signs, what is still open
—	**`Setnayan_Data_Privacy_Summary_2026-10-22.pdf`**	Printable 1-page summary: what we provide · what the website promises · how we comply
03	**DPO Designation + NPC Registration data sheet**	The owner's formal DPO appointment record (PIC = DPO) + the field-by-field data to complete NPC registration

04	**Data Breach Management Policy**	Per NPC Circular 16-03 — 72-hour rule, response team, notification, breach register
05	**DPIA Register + Person-Graph DPIA**	Impact-assessment register + one completed DPIA (person graph); flags what still needs one

The adoption-ready files are `01_Privacy_Manual_ADOPTED_2026-07-24.md`, `03_DPO_Designation_and_NPCRS_ADOPTED_2026-07-24.md`, `04_Data_Breach_Management_Policy_ADOPTED_2026-07-24.md` (the `_DRAFT_` twins are kept for lineage only). All carry the same and the "compliant baseline, not a substitute for legal review" footer.

How to actually file (this pack is the content, not the filing)

1. **Fill in the `[TO CONFIRM]` facts** below (one pass supplies them across all docs).
2. **You review & adopt as both PIC and DPO** — sign the designation + manual; set the effectivity dates. (PH counsel to review before publishing any policy text.)
3. **Register with the NPC online** via the **NPC Registration System (NPCRS)** at `register.privacy.gov.ph` — this registers the PIC, the DPO's contact details, and the Data Processing System(s). *(This online filing is the DPO/owner's action — I can't file on your behalf.)*
4. **Keep the adopted set as your accountability records** (the "keepsake"); update on the review cadence in the Manual.

Master list — facts you must supply (`[TO CONFIRM]`, 98 occurrences → these distinct items)

Business identity
- Registered / principal place of business address
- BIR TIN / Form 2303 number
- Existing NPC PIC + DPO registration number (after you file)

Scale (required registration fields)
- Total headcount / employees (and how many have access to personal data)
- Number of data subjects — customers, vendors, guests (approx.)
- Number of data subjects whose **sensitive** personal info you hold

DPO (the owner) details
- Contact email · mobile/landline · designation effectivity date · **the PIC = DPO conflict-of-interest note** (the proprietor also serves as DPO — record a short independence rationale; NPC generally prefers DPO autonomy from the controller, but this is commonly accepted for a 2-person sole proprietorship)

Data Breach Response Team
- Names for: Technical/Engineering Lead · Security/Ops Coordinator · Comms/Legal liaison (external PH counsel) · the 24/7 escalation phones + email · the DPO breach hotline number

Sub-processors (jurisdiction + executed DPA on file)
- [OK] Rebuilt 2026-10-22 from the code — see Privacy Manual § 8.2. **No DPA is signed with any processor** (task `t2-8`). PostHog removed; Suno not called; face matching is in-house; SendGrid does not exist.
- (!) **Suno is not in the Privacy Policy's sub-processor table** — add it (or confirm it processes no personal data)

Processing specifics
- Exact RSVP special-data fields (dietary/health/religious?) — decides whether the guest system is a formal sensitive-PII system
- Automated-decision inventory: the Anti-Fraud auto-suspend (DPS-12 / R-08) **is** a solely-automated decision with a significant effect (reversible); confirm the RA 10173 §16(c)/§34 contest/appeal path is documented
- Maya Business (V1.5 payment gateway) contract status
- Personnel controls: signed NDAs on file · privacy-training cadence · device/endpoint policy
- DPIA review + sign-off dates

Two things flagged for your attention

1. **Biometric face vectors likely need their own dedicated full DPIA.** The person-graph DPIA (doc 05, Part 2) is complete, but face-vector processing is sensitive (biometric) and is flagged as needing a *separate* HIGH-risk DPIA — not folded into the person-graph one. Worth doing before scaling that feature.
2. **Publish order:** the **Privacy Policy amendment** (person-graph, in `01_Contracts/`) and doc 05's person-graph DPIA should be **finalized with the DPO (owner) + PH counsel before the amendment goes public** — the features are live behind flags, but the public policy text publishes on sign-off.

Companion documents (outside this folder)

- `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` — the binding public policy (now with the 2026-07-05 person-graph amendment)
- `03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md` — consent notices + the source person-graph DPIA
- `03_Strategy/Phase2_Counsel_Review_Brief_2026-07-05.md` + `Phase3_Minors_and_Legacy_Counsel_Brief_2026-07-05.md` — the two counsel briefs (for the DPO/owner + PH counsel)

Prepared to a compliant baseline ahead of counsel per the standing compliance-by-default rule. Finalize with Indalecio Sacdalan Casasola II (DPO) + PH counsel before filing/publishing.

Setnayan Privacy Manual

> **ADOPTION-READY · 2026-07-24 — formatted for the DPO's signature and NPC filing.**
> Date prepared for adoption: **2026-07-24**
> Document ID: `NPC_Compliance/01_Privacy_Manual_ADOPTED_2026-07-24.md`
> Governing law: Republic Act No. 10173 (Data Privacy Act of 2012), its Implementing Rules and Regulations (IRR), and issuances of the National Privacy Commission (NPC).

> **Revised 2026-10-22 (v1.1) — still ADOPTION-READY; the DPO re-signs § 12.** Measured against the shipped code on `origin/main` (`aceb080a0a`) and the live `/privacy`, `/cookies`, `/terms` and `/refunds` pages. Changes in this revision: the published DPO contact is now **dpo@setnayan.com** (owner ruling 2026-09-22) · **PostHog removed, essential cookies only, no banner** (PR #6774) · first-party **site Visits** (daily aggregates, daily-salted hash) added · **sign-in with Google and Apple** and **Apple in-app purchase (built, switched off)** added · the **supplier Papic capture lane** and the **supplier photo takedown** added · sub-processor table (§ 8.2) rebuilt from the hosts the code actually calls · account deletion (§ 5.3, § 5.5, § 6) re-stated as request → 24-hour admin review → anonymise-and-retain · face-data consent (§ 7) re-stated as an explicit, default-off, adults-only opt-in · the face-data and supplier-upload sweeps marked as built (PR #4735) · `setnayan.ph` struck (we do not own it). See `00_WHAT_CHANGED_2026-10-22.md` and the § 12 version table.

> ### [OK] ADOPTION POSTURE — adopt now, counsel later
>
> This Manual is prepared for the DPO to **adopt as v1.0 now**, on the DPO's own authority — a sole proprietor may adopt their own RA 10173 compliance documents. To adopt: the owner supplies the **6 fields** in the checklist immediately below, signs the approval block in § 12, and sets the effectivity date.

> **External Philippine counsel review is recommended, not blocking.** It is not required to adopt this Manual or to file NPC registration. Where counsel or the NPC later requires a change, it is applied by a **dated amendment** (see the § 12 version table); any affected live feature can also be switched off immediately via the in-app Data Privacy control board (`/admin/data-privacy`).

> **Two things stay firm before any NPC filing:** (1) the 6 owner fields below must be **real values, not placeholders** — do not file with blanks; and (2) the risk items flagged in the text — especially minors' data (dependents, face matching at christenings/debuts), the automated fraud suspension and the processors with no signed DPA — remain visible and should get a counsel pass when one is engaged. (Updated 2026-10-22 — the vendor gov-ID + AMLC item is resolved: retired 2026-07-03.)

Fields the owner must supply before signing

1. **Barangay + ZIP** for the principal address (76 Sampaguita Avenue, Quezon City — complete it).
2. **BIR TIN / Form 2303 number** — enter this at filing from admin → Compliance; **never write it into this file.**
3. **Exact DPO position/title string** (the precise wording of the DPO's designated title).
4. **A contact phone number** — one mobile suffices; it serves as the PIC contact, DPO contact, and breach hotline.
5. **Which sub-processors have a signed DPA on file.** (!) UPDATED 2026-10-22: the code's own register (`apps/web/lib/subprocessors.ts`) records `dpa_on_file: false` for **every** processor. The "PostHog instance region" question is retired — PostHog was removed on 2026-10-22 (PR #6774).
6. **The adoption / signature date.**

This Privacy Manual is the flagship governance document of the Personal Information Controller. It states how the organization collects, uses, stores, discloses, and disposes of personal data; how it upholds the rights of data subjects; and how it manages security, breaches, and cross-border transfers. It is intended to be kept on file and presented to the NPC on request.

1. Introduction, Purpose & Scope

1.1 The Personal Information Controller (PIC)

Field	Value
Legal entity	**SETNAYAN SOFTWARE DEVELOPMENT SERVICE** — a sole proprietorship of **Indalecio Sacdalan Casasola II**
DTI Business Name Registration	**No. 8297508** (national scope; valid **25 Jun 2026 – 25 Jun 2031**)
Brand	Setnayan
Domains / platform	`setnayan.com` ((!) CORRECTED 2026-10-22 — `setnayan.ph` struck: we do not own it, owner 2026-08-11)
Nature of business	Philippines-first life-events (weddings-first) planning platform serving three roles — customers (couples/organizers), vendors, and guests
Registered address / principal place of business	76 Sampaguita Avenue, Quezon City, **‹OWNER TO SUPPLY: barangay + ZIP›**
Number of employees / personnel with access to personal data	**2 of 2** — Indalecio S. Casasola II (proprietor + DPO) and Claire E. Buanhog (VP, co-founder)
Approximate number of data subjects	(!) **Not re-measured 2026-10-22** (no production access from this session) — read the live count from `/admin/compliance/data-sheet` on filing day. Last measurement: **48 as measured in production 2026-08-17** (9 accounts + 39 guests; 2 shops; 6 events; 0 active biometric face vectors). (!) CORRECTED 2026-08-17 — this field read **~401** from the 2026-07-05 pre-launch snapshot (19 customers + 50 vendors + 332 guests; 61 events). That test data was purged; `07_Compliance_Facts_Register` recorded the ~10× drop on 2026-07-31 and the correction was never propagated to the headline fields. The registration-threshold analysis is UNAFFECTED and strengthened: 48 subjects and 0 biometric vectors sit further below the ≥1,000-SPI trigger than the stale figures did
NPC registration number (PIC/DPO registration)	DPO registered on the NPC DPO system **2026-07-07**; DPS registration reference to be captured after NPCRS filing

1.2 Purpose

This Manual:

- Documents the PIC's personal data processing activities and the safeguards applied to them.
- Serves as the reference for all personnel who process personal data on the PIC's behalf.
- Demonstrates the PIC's accountability and compliance posture to the NPC, to data subjects, and to partners.
- Operationalizes the binding **Setnayan Privacy & Security Policy** (`01_Contracts/Setnayan_Privacy_and_Security_Policy.md`), which every account holder accepts at registration.

1.3 Scope

This Manual applies to **all personal data** processed by the PIC across all systems, personnel, contractors, and sub-processors, in every format (electronic and, where applicable, physical). It covers the personal data of **customers, vendors, and guests**, and the internal personnel data the PIC processes as an employer/engager (2 personnel with personal-data access — see § 1.1).

1.4 Commitment to RA 10173

The PIC commits to upholding the three data privacy principles — **transparency, legitimate purpose, and proportionality** — and to protecting the rights of every data subject. The platform is built on a **privacy-by-design + compliance-by-default** posture: privacy safeguards are engineered into the systems (row-level access control, encryption, per-event scoping) rather than bolted on. The organization's person-graph features are **adults-only**; processing of minors' data and legacy/post-mortem data is a future, counsel-first phase and is **not undertaken now**.

---

2. Definitions

Terms used in this Manual carry the meanings assigned by RA 10173 and its IRR:

Term	Meaning
Personal Information (PI)	Any information from which the identity of an individual is apparent or can reasonably and directly be ascertained, or when put together with other information would directly and certainly identify an individual.
Sensitive Personal Information (SPI)	PI about an individual's race, ethnic origin, marital status, age, colour, religious/philosophical/political affiliations; health, education, genetic or sexual life; any proceeding for any offence; government-issued identifiers (SSS, TIN, etc.); and information specifically established by law as classified.
Privileged Information	Any and all forms of data which, under the Rules of Court and other pertinent laws, constitute privileged communication.
Personal Information Controller (PIC)	A person or organization who controls the collection, holding, processing, or use of personal information — here, SETNAYAN SOFTWARE DEVELOPMENT SERVICE.
Personal Information Processor (PIP)	Any natural or juridical person to whom a PIC may outsource or instruct the processing of personal data (the PIC's sub-processors — see § 8).
Data Subject	The individual whose personal information is processed — Setnayan's customers, vendors, and guests.
Processing	Any operation performed upon personal data — collection, recording, organization, storage, updating, retrieval, consultation, use, consolidation, blocking, erasure, or destruction.
Consent	Any freely given, specific, informed indication of will by which the data subject agrees to the processing of personal data about them.
Data Protection Officer (DPO)	The individual designated by the PIC to be accountable for compliance with RA 10173.

Personal Data Breach	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data.

---

3. Governance & Organizational Structure

3.1 Data Protection Officer (DPO)

Field	Value
Designated DPO	**Indalecio Sacdalan Casasola II**
DPO position / title	**‹OWNER TO SUPPLY: exact DPO position/title string›**
DPO contact	**dpo@setnayan.com** (published on every legal page — owner ruling 2026-09-22, `apps/web/lib/contact-addresses.ts`) · **‹OWNER TO SUPPLY: contact phone number (serves PIC + DPO + breach hotline)›**. (!) UPDATED 2026-10-22 — this read iscasasolaii@gmail.com, which is still the address on the NPC DPO-system registration of 2026-07-07; update that registration to dpo@setnayan.com at NPCRS filing so the two agree.
NPC DPO registration	Registered on the NPC DPO system **2026-07-07**; DPS registration reference to be captured after NPCRS filing

The DPO is the organization's accountable officer for data privacy and the single point of contact for data subjects and for the NPC. The DPO's responsibilities include:

- Monitoring and ensuring the PIC's compliance with RA 10173, its IRR, NPC issuances, and this Manual.
- Serving as the contact point for data subject requests and complaints (access, rectification, erasure, objection, portability, and breach inquiries).
- Overseeing the conduct of Data Privacy Impact Assessments (DPIAs — see § 10) and maintaining the DPIA register.
- Leading the security incident and breach response process (see § 9), including NPC and data-subject notification.
- Cultivating a privacy-aware culture through personnel training and periodic review of policies.
- Reviewing and advising on sub-processor engagements and cross-border transfers.

3.2 Security Measures — Overview

The PIC maintains organizational, physical, and technical security measures proportionate to the nature of the personal data processed and the risks involved. The measures below summarize the controls already in place per the binding Privacy & Security Policy.

3.2.1 Organizational measures

- **Binding policy acceptance.** Every customer, vendor, and guest accepts the Privacy & Security Policy at registration; acceptance is logged with timestamp, IP, and user-agent in a `policy_acceptances` record per user.
- **Role-based responsibility.** Internal (admin) access is gated to granular roles; each role can only reach the surfaces it is permitted.

- **Two-admin approval** for high-impact actions — role provisioning, brand-configuration changes, refunds above PHP 10,000, and unlimited-use grants above PHP 10,000 retail value.
- **Confidentiality obligations** on personnel and contractors — **‹OWNER TO ADOPT: short signed confidentiality note + basic-hygiene policy recommended›**.
- **Privacy training** for personnel who process personal data — **‹OWNER TO ADOPT: short signed confidentiality note + basic-hygiene policy recommended›** (training cadence to be set with the same policy).

3.2.2 Physical measures

- **No self-hosted data centre.** The PIC does not operate physical servers; personal data resides with managed cloud processors (Supabase, Cloudflare) under their physical-security controls and data-processing agreements.
- Access to workstations and administrative credentials is restricted to authorized personnel — **‹OWNER TO ADOPT: short signed confidentiality note + basic-hygiene policy recommended›** (device/endpoint hygiene to be set with the same policy).

3.2.3 Technical measures

Control	Implementation
Access control (deny-by-default)	Row-Level Security (RLS) on the Postgres database — every query is gated so no client can read another user's row. Deny-by-default is the baseline; access is granted only by explicit policy.
Encryption in transit	TLS 1.3 on all external connections and WebSocket channels; HSTS enabled in production; mixed content blocked.
Encryption at rest	AES-256 on the database and object storage; keys managed by the cloud providers' key-management services. Face vectors are stored as event-scoped rows in the encrypted Postgres database (`guest_face_enrollments.face_vector`), under the same RLS deny-by-default gate as all other personal data — *not* in a separate object-storage index (corrected 2026-07-31; see § 5.3).
Authentication	E-mail + password (hashed by Supabase Auth, never plaintext), an e-mailed sign-in link, or Sign in with Google / Apple (each behind a switch). Cloudflare Turnstile bot check on sign-up / sign-in forms when its key is set. (!) **CORRECTED 2026-10-22 — two statements here were not true in code:** there is **no mobile + OTP sign-in** (no SMS in V1), and **no two-factor authentication is built** — `origin/main` contains no MFA / TOTP enrolment or `aal2` check, so it is neither offered to users nor mandatory for admins. Admin access rests on the password plus server-side role checks (`is_admin()`). Building admin 2FA is an open security item.
Session management	The Supabase sign-in cookie lasts up to 1 year (longer in the installed app; until the browser closes if "Stay signed in" is off), per `/cookies`. (!) CORRECTED 2026-10-22 — this read "30-day inactivity expiry", which the shipped cookie does not do. Switching between several accounts on one phone (PR #6784) is **not shipped** (PR open, not merged, 2026-10-22).

Short-lived media access	Object storage is private; access is via short-lived signed URLs (5 minutes for sensitive media). No public reads.
Application hardening	Input validation at every entry point; parameterized queries (no SQL injection); output escaping + CSP (no XSS); CSRF tokens on state-changing requests; rate limiting on auth endpoints.
Audit logs	Every admin action is logged append-only (no UPDATE permission) with timestamp, actor, action type, target entity, before/after state, and rationale.
Backups	**NONE — there are no automated database backups.** The database runs on the Supabase FREE plan, which provides no scheduled snapshots, and no backup job of our own exists — the platform's ~16 cron-free periodic jobs are application sweeps, none of which is a database backup. (!) CORRECTED 2026-08-17 — this row previously declared "Daily encrypted database backups retained 30 days", which was never true. Owner ruling 2026-08-10 (*"let's stay free for the moment"*) records the absence of backups as a CONSCIOUSLY ACCEPTED cost, to be revisited before launch; the paid tier would give daily backups with 7-day (not 30-day) retention. Encryption at rest, TLS 1.3 in transit and RLS isolation are unaffected and remain in force.

---

4. Data Processing Principles Applied

The PIC applies the three RA 10173 principles to every processing activity:

4.1 Transparency

Data subjects are informed of the nature, purpose, and extent of processing before or at collection. Mechanisms:

- Registration-time acceptance of the Privacy & Security Policy (logged per user).
- A published privacy notice on `setnayan.com/privacy` (last updated 2026-10-22), a cookie list on `setnayan.com/cookies` (essential cookies only, no banner) and a Google-access summary on `setnayan.com/privacy/google-access`. (!) CORRECTED 2026-10-22: there is **no** `/privacy/changelog` page and the live notice has no "changes to this policy" section; the 30-day notice + re-consent commitment is the adopted rule, not yet reflected on the public page (open item in `00_WHAT_CHANGED_2026-10-22.md`).
- The DPO's contact (**dpo@setnayan.com**) is published on `/privacy`, `/terms`, `/refunds`, `/cookies` and `/acceptable-use` as the channel for questions and rights requests. (Updated 2026-10-22 — was the owner's personal mailbox.)

4.2 Legitimate Purpose

Processing is limited to declared, specified, and legitimate purposes and is never incompatible with them. Concrete examples:

- **Service delivery** — providing the planning tools, gallery, RSVP, and vendor-matching a customer contracts for (basis: performance of contract / legitimate interest).
- **Payments** — apply-then-pay reconciliation using **reference data only**; no card, CVV, or full bank-account numbers are stored (basis: performance of contract).
- **Vendor verification** — business-document review (DTI, BIR 2303, Mayor's Permit, bank proof, portfolio, references) and a 15-minute Google Meet identity call at onboarding (bases: consent, legitimate interest). (!)

CORRECTED 2026-10-22: no government ID, no liveness check and no AML sanctions screening — those were retired 2026-07-03, so the AMLA basis is struck.

- **Face auto-tagging** — matching a guest to their own photos, per-event only, on **explicit, separate, default-off consent, adults 18+ only** (basis: consent, §13(a)). (Corrected 2026-10-22 — "implied" struck; the shipped opt-in is a separate checkbox and enrolment refuses a known minor, `app/papic/face-enroll-actions.ts`.)

4.3 Proportionality

Only data adequate, relevant, and necessary to the declared purpose is processed:

- **Payment data minimization** — reference and receipt data only, never full credentials.
- **Per-event face scoping** — face vectors are generated and used **per event only, never reused across weddings**, and are deleted with the event data. There is **no cross-event face recognition**.
- **Person-graph minimization** — connections require **mutual confirmation**; cross-person visibility is **name-only**; extended relationships are **derived, never stored**; trusted-circle signals are **aggregated/computed (≥5 minimum), never per-person records**.

---

5. Data Lifecycle: Collection → Use → Storage → Disclosure → Disposal

5.1 Collection

Personal data collected, by role:

Role	Categories collected
Customer (couple/organizer)	Full name, mobile, email, optional profile photo; optional religion / civil status / birth date / dietary needs (each consent-stamped); event details (date, venue, target pax, role, ceremony type); payment **reference/receipt** data and proof screenshots (no full credentials); dependents' details for christenings and milestones (entered by the parent); uploaded content (photos, invitation customizations); chat messages with vendors/coordinators; sign-in identity from Google or Apple where chosen.
Vendor	Business + identity documents (DTI Business Name Certificate, BIR Form 2303, Mayor's Permit, government ID, bank-account proof, portfolio, client references, live selfie + liveness); service profile; payout account and transaction history; behavioral data; chat messages. Includes **SPI** (government-issued identifiers).
Guest	Full name, mobile, optional profile photo; event linkage and role; RSVP status, dietary needs, table assignment; captured/tagged photos and clips; QR-scan records (IP truncated; the guest may switch them off); optional push-notification subscription. (!) Updated 2026-10-22: **the RSVP no longer asks guests for e-mail and guests receive no e-mail** (owner 2026-09-29).
Face vectors (special category)	Per-event face vectors computed **in the guest's browser** from a selfie taken after a separate, default-off consent tick (adults 18+ only), used only to find that guest's photos within that one event. (Corrected 2026-10-22 — the RSVP-photo / kiosk description was the old design.)

5.2 Use

Primary uses: providing contracted services, vendor matching, payment processing, per-event photo auto-tagging, event/payment notifications, and aggregated admin reporting. **There is no product-analytics service** (PostHog removed 2026-10-22, PR #6774); site traffic is counted first-party as daily aggregates with a salted hash that is destroyed each day (ROPA DPS-21), with no cookie. Secondary uses (anonymized aggregate improvement/ML, marketing samples, promotional communications) require **separate, revocable consent**. Personal data is **never sold**, never used for external targeted advertising, and never shared with government except as required by Philippine law (subpoena/court order).

5.3 Storage, Residency & Retention

System	Location	Content
Database (Postgres)	**Supabase — Singapore**	PII + transactional data, RLS-gated, AES-256 at rest. **Includes the biometric face vectors** — `guest_face_enrollments.face_vector` (JSONB) and `user_face_profiles` (corrected 2026-07-31, see note)
Object storage	**Cloudflare R2 — APAC region**	Photos/videos, the **source selfie images** for face enrolment, vendor verification documents; private + signed-URL access

> ** Corrected 2026-07-31 — where the biometric data actually sits. **This table previously placed a *"per-event encrypted face-vector index"* on Cloudflare R2.** Verified against shipped code, that is not how it was built. **The face vectors are `JSONB` columns in** Supabase Postgres (Singapore) **— `guest_face_enrollments.face_vector` (migration `20260901000000`) and the account-level descriptor in `user_face_profiles` (migration `20270306508746`). R2 holds the** source selfie image **(`guest_face_enrollments.asset_url` = `r2://…`), not the vector.** No R2 vector index exists. **Both locations are outside the Philippines, so § 10's cross-border conclusion is unchanged — but the NPC registration sheet asks *where sensitive personal information resides*, and biometric data is the most scrutinised category, so the location must be stated accurately. Same correction applied to `02_Records_of_Processing_Activities` DPS-04 and `03_DPO_Designation_and_NPCRS` § sub-processors. | Email |** Resend** | Transactional/notification email delivery |

Representative retention windows (full table in the Privacy & Security Policy § 4):

Data type	Retention	Deletion trigger
Customer/vendor account profile	Active	**Deletion request → admin review within 24 hours → erasure at once (anonymise-and-retain, § 5.5).** (!) CORRECTED 2026-10-22 — this read "Account deletion + 30-day grace then purge"; no grace period and no scheduled purge exist in code (finding #6 of 2026-08-24). (!) The live `/privacy` retention table still says "a short 30–90 day tail" and `/terms` says "30 days" — both are open copy fixes (`00_WHAT_CHANGED_2026-10-22.md`).

Customer event data	**Kept for the LIFE OF THE ACCOUNT**, deleted when the couple closes or deletes their account. Owner ruling 2026-08-17. ((!) CORRECTED 2026-10-22: "plus the existing 30-day tail" struck — no tail exists in code.) (!) **CORRECTED — the previous "5 years post-event, auto-purge at T+5y" rule is WITHDRAWN, not merely unbuilt.** Building it as written would have DELETED THE PHOTOS: in the live schema the photo rows, the guest list, the tags, the schedule and the supplier list all cascade from the event, so removing a wedding removes its album — contradicting the owner's twice-locked rule that no photo is ever deleted, only compressed. Retention is therefore bound to the purpose that is still running (the couple's own album and its context) rather than to a timer, matching the treatment of account data. Any future end date must be built to remove planning details WITHOUT touching the photos.	Deleted with the account
Photo/video originals	Full-resolution ORIGINAL: the later of 6 months from the event's first capture and 3 months after the event ENDS (the celebration's last day: `event_end_date` where the event spans several days, else `event_date` — owner 2026-08-10), then **replaced by** a compressed web copy. **Compressed web copy: free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** No scheduled deletion at any point. **No photo is ever deleted on a schedule.** Disposal occurs only on organizer removal, a validated erasure request, or account deletion. Originals synced to the couple's own Google Drive are theirs permanently and are never touched.	(!) **CORRECTED 2026-08-07.** This row previously declared a **5-year hard limit** with 90-day-hot/5-year-cold tiering. That tiering was never built, no R2 lifecycle rule exists, and the compressed copy is kept indefinitely — so the row committed us, in a filing, to destroying photos we in fact keep. Declaring a purge that never happens is the more dangerous direction of drift: a commitment to the regulator broken every day.

Face vectors	[OK] **UPDATED 2026-10-22: the selfie, enrolment and vector are erased when the event's Papic closes, 12 hours after the event ends** (owner 2026-09-30, *"face will be only saved for that day"*, PR #6195). Backstop: **deleted 3 MONTHS AFTER THE EVENT ENDS** (`event_end_date` where the celebration spans several days, else `event_date`) — owner ruling 2026-08-17. Earlier deletion any time via the guest's "Delete my face data" link or Photo Consent OFF (≤ 5-minute revocation), which DO work today. [OK] **UPDATED 2026-10-22 — ENFORCEMENT IS BUILT:** PR #4735 (merged 2026-08-23) added the 3-month face-data sweep and the 90-day supplier-upload sweep; the qualifier "ENFORCEMENT NOT YET BUILT" that these rows carried from 2026-08-17 is no longer true. The sweeps are cron-free (they run on request traffic), so their timing depends on traffic; that they have run against production data was not verified from this session. (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one. **Deleting face data does NOT remove photo tags** — verified in the live schema: a tag carries the guest link itself and has no reference to face data, so nothing cascades. Guests keep every photo already delivered; only FUTURE automatic matching is lost, which is why the 3-month mark is safe. (!) CORRECTED 2026-08-17 — this row previously declared a "per-event lifetime + 5 years, auto-purge with event data" rule, which nothing implemented — and which had silently become "never deleted" when the media row moved to indefinite retention on 2026-08-02.	Revoke link works today

Vendor verification audit trail / permits	(!) **CORRECTED 2026-08-24 — THE COLLECTION THIS ROW DESCRIBES WAS RETIRED 2026-07-03; it now governs LEGACY uploads made before that date, not an ongoing collection.** Raw uploads (government ID, selfie + liveness video, bank micro-deposit, portfolio): **deleted 90 DAYS AFTER the approve/reject decision** — owner ruling 2026-08-17, which makes true the promise this row already made. The DECISION RECORD ONLY (outcome, deciding admin, timestamp, screening result) is retained **7 years** (BIR §235 + AMLC AML/CTF). DTI / BIR 2303 / Mayor's Permit: 7 years. Transaction history: 5 years (policy §4). [OK] **UPDATED 2026-10-22 — ENFORCEMENT IS BUILT:** PR #4735 (merged 2026-08-23) added the 3-month face-data sweep and the 90-day supplier-upload sweep; the qualifier "ENFORCEMENT NOT YET BUILT" that these rows carried from 2026-08-17 is no longer true. The sweeps are cron-free (they run on request traffic), so their timing depends on traffic; that they have run against production data was not verified from this session. (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one.	BIR § 235 + AMLC AML/CTF
Chat messages / audit logs	5 years	Aligned with event / tax-legal retention
Anonymized aggregate data	Indefinite (no PII)	Not auto-purged

5.4 Disclosure / Sharing

Disclosure is limited to the sub-processors in § 8, each engaged under a data-processing agreement and used only for the declared purpose. Internal (Setnayan Team) access to event media is read-only, case-scoped to mediation, and never bulk-exported.

5.5 Disposal

Disposal occurs by automated sweep at the retention boundary (where a sweep exists — see § 5.3) or on a validated deletion request. **Account deletion is anonymise-and-retain, not a cascade** ((!) CORRECTED 2026-10-22 — the previous text described a cascade, which the code does not do; finding #16 of 2026-08-24): an admin approves the request, then `eraseUserAccount` blanks the person's own personal fields (name, contact details, photo, optional profile details), removes their face data and device hashes, revokes a Sign in with Apple grant, and keeps the **anonymised** business records other people rely on (a supplier's reviews and statistics, an event's ledger, BIR receipts, which are kept for their statutory period). The code docstring states this is deliberate: erasure must destroy the personal data, not other people's business records. Known gap: the name/e-mail/avatar copy that Google sign-in leaves in the sign-in provider's identity record (`auth.identities.identity_data`) is not yet blanked (DECISION_LOG 2026-10-22) — an open engineering item.

---

6. Data Subject Rights

Every data subject has the following rights under RA 10173. All are exercised by contacting **dpo@setnayan.com** (and, for several, via in-app settings surfaces).

#	Right	How to exercise / PIC response
1	**Right to be informed**	Via this Manual, the published privacy notice, and registration-time disclosures.
2	**Right to access**	Request a copy of personal data held, via dpo@setnayan.com. **Response: within 15 business days** for non-urgent requests.
3	**Right to object**	Opt out of specific data uses (e.g., marketing samples, promotional email) via settings or dpo@setnayan.com.
4	**Right to rectification**	Edit profile in-app; request corrections via dpo@setnayan.com.
5	**Right to erasure or blocking**	Profile → "Delete my account" → type DELETE. An admin reviews within **24 hours** (active events, bookings, balance) and erasure runs on approval — anonymise-and-retain per § 5.5, with statutory-retention exceptions. ((!) CORRECTED 2026-10-22 — was "confirmed within 30 days; cascade".) A guest may also ask for a photo of them to be taken down — including a **supplier's own copy and portfolio** (owner ruling 2026-09-16, shipped as TD-1) — and may withdraw face-matching consent at any time.
6	**Right to damages**	File a complaint with the NPC for violations; the PIC cooperates with any NPC proceeding.

7	**Right to data portability**	Profile → download a JSON archive (`/api/profile/export`); photos via the album ZIP download. Raw face vectors are excluded from the export. (!) Known gap (DECISION_LOG 2026-09-16): the export omits several record types; not yet fixed.
8	**Right to be notified**	Notification of any breach affecting the subject's data, per § 9.

Person-graph specific rights: a data subject may decline connection requests, remove confirmed connections, hide individual life-story items per-person (without affecting the host's gallery), and opt out of an event's story entirely; deletion cascades to their connections and story-item references.

---

7. Consent Management

- **Registration consent.** Acceptance of the Privacy & Security Policy is captured and logged (timestamp + IP + user-agent) at account creation.
- **Face detection.** (!) CORRECTED 2026-10-22 — the "implied consent by uploading an RSVP photo" description was the old design. Today a guest ticks a **separate, default-off** box (*"face recognition for this wedding"*), confirms they are **18 or older**, and only then takes a selfie; the server refuses a vector without that consent and refuses a guest the host has marked as a minor, and stamps the time, source and consent-copy version. The guest can withdraw at any time; withdrawal deletes the face data and, since PR #4747 (2026-08-24), **blurs the guest's face and keeps the photo** (owner ruling 2026-08-17 — one guest opting out does not delete a table's group shot). Blur applies on the venue wall, the shared pool and the public event page; the couple's own album is unblurred. Face processing is **per-event only**.
- **Vendor verification consent.** Vendors give explicit, itemized consent at registration for DTI lookup, third-party ID/liveness verification, portfolio reverse-image search, reference calls, and AMLC sanctions screening. [OK] **STATUS CONFIRMED 2026-08-24, AND IT RESOLVES THE FLAG AS "NOT A STUB — REMOVED".** These slots were **retired by the owner on 2026-07-03**; identity confirmation is a 15-minute Google Meet. **No third-party ID/liveness verification and no AMLC screening is consented to, requested, or performed.** The itemized consent must not ask for them.
- **Marketing samples.** Use of a customer's renders/captures as marketing samples requires a **separate written opt-in**, revocable at any time; existing materials are removed within 90 days of revocation.
- **Person graph.** Connections require **mutual confirmation** (no one-sided edges); life-story items rely on existing event photo-consent and are individually hide-able/opt-out-able; trusted-circle recommendations are aggregate-only.
- **Withdrawal.** Consent may be withdrawn at any time through settings or dpo@setnayan.com, without affecting the lawfulness of prior processing.
- **Material changes** to processing carry 30 days' advance notice and a re-consent prompt at next login where the change affects data use.

---

8. Data Sharing, Sub-Processors (PIPs) & Cross-Border Transfers

8.1 Hosting & cross-border disclosure

The PIC's primary infrastructure is hosted **outside the Philippines**: the database in **Singapore** (Supabase) and object storage in the **APAC region** (Cloudflare R2). Routine application operations therefore involve **cross-border**

processing. All such transfers are encrypted in transit (TLS 1.3), governed by the providers' data-processing agreements, and remain subject to NPC oversight; the PIC remains accountable for personal data transferred to any processor.

8.2 Sub-processors (Personal Information Processors)

> **Rebuilt 2026-10-22 from the hosts the shipped code actually calls** (`origin/main` `aceb080a0a`: every `fetch` host, SDK and CSP entry), not from earlier documents. Where a service only runs once a key or a switch is set, that is stated; **whether each key or switch is set in production cannot be read from the code and was not verified.** The code's own register (`apps/web/lib/subprocessors.ts`) records **no signed DPA with any processor** (`dpa_on_file: false` on every row).

Sub-processor	Jurisdiction	Data shared	Purpose	Runs when
Supabase	Singapore	All structured personal data (accounts, guests, events, orders, chat), **including the biometric face vectors**	Database, sign-in, realtime	Always
Vercel	US company; app functions pinned to Singapore (`vercel.json` `sin1`)	Every request in transit — IP, headers, request bodies	Application hosting	Always
Cloudflare	R2 storage: Asia-Pacific (APAC). Relay / bot check: global network	**R2:** photos, videos, enrolment selfies, payment-proof screenshots, supplier documents, chat files. **TURN relay:** call and camera media and the IP address, in transit only. **Turnstile:** the visitor's IP and browser signals on sign-in / sign-up forms. **STUN:** the device IP	Storage; live-video relay; bot check	R2 always; TURN and Turnstile only when their keys are set
Resend	United States	Recipient e-mail, subject, message body	Transactional e-mail	When the e-mail key is set
Sentry	United States	Error stack traces and breadcrumbs; on a browser error, a **masked** screen replay (all text masked, all media blocked); e-mails, phone numbers and face vectors are scrubbed before sending; `sendDefaultPii` off	Error monitoring	When the DSN is set (production)

Anthropic	United States	Payment-receipt screenshots (to read the reference typed); a supplier's own public business information (Deep Search); supplier mood-board gallery photos (to catch logos / contact details); a couple's theme sentence; supplier category requests; admin search phrases	AI assistance — **never** approves a payment, never trains on our data	When the API key is set
OpenAI	United States	Text of a couple's event story / editorial and of guest-written columns	Content moderation	When the API key is set
LanguageTool (LanguageTooler GmbH)	Germany (EU)	The same editorial text, sent to the free public API	Spelling and grammar check	Always, when an editorial is scanned — **no DPA, free public endpoint** (open owner decision since 2026-08-24)
Google	United States	**Sign-in:** name and e-mail. **YouTube (Live Watch):** OAuth tokens, broadcast details. **Drive:** event photos copied into the couple's own Drive (`drive.file`). **Gemini:** mood-board pictures on a paid render. STUN: device IP	Sign-in; live broadcast; photo delivery; image render	Sign-in behind `NEXT_PUBLIC` YouTube / Drive only after the user connects; Gemini only on a paid render

Apple	United States	**Sign in with Apple:** Apple ID token (name, e-mail — possibly a private-relay address); the refresh token is kept so the grant can be revoked on erasure. **In-app purchase:** signed App Store transactions and Apple's server notifications, verified offline. **iTunes search:** the song search term and the visitor IP	Sign-in; iOS purchases; song previews	Sign-in behind `NEXT_PUBLIC` **in-app purchase built but switched off** (`NEXT_PUBLI` default off)
Meta (Facebook, Instagram)	United States	Setnayan's own promotional posts; a supplier's own Instagram posts after the supplier connects	Social publishing; supplier Instagram sync	Only with the page token / after a supplier connects; Facebook sign-in switched off
TikTok	Singapore / United States	OAuth tokens, the rendered video, post details	Patiktok posting	Only after the user connects
OpenStreetMap (Nominatim + map tiles)	United Kingdom (OSM Foundation) — not verified	A venue or shop address typed in; the viewer's IP for map tiles	Address → map pin; maps	When an address is placed on a map
Vimeo	United States	A supplier's Vimeo link	Video poster image	Only for Vimeo links
Browser push services (Apple / Google / Mozilla)	Browser vendor	Notification title, body and link	Web push notifications	When push keys are set and the user allows notifications

Public CDNs (jsDelivr, unpkg, Google storage)	Global	The visitor's IP only	Downloading the face-check and video-compression libraries	When those features run
~~Persona / Veriff / Onfido~~ · ~~AMLC API / ComplyAdvantage~~	—	—	[X] **NOT SUB-PROCESSORS — retired 2026-07-03, struck 2026-08-24.** No relationship, no data ever sent.	
~~PostHog~~	—	—	[X] **REMOVED 2026-10-22 (PR #6774)** — no analytics SDK, no analytics cookie, no consent banner.	
Suno	—	—	**Not called by the code** (a team member uses it by hand to make music; no personal data). Not a sub-processor.	

Payments are not a processor relationship. Customers pay by manual transfer to Setnayan's own GCash / BDO accounts and upload a proof; an admin matches it by hand. The code calls **no** payment API (PayMongo, Maya, Stripe and GCash/BDO APIs are not called). The proof screenshot reaches only R2 and, when its key is set, Anthropic.

Face matching has no outside processor. Face descriptors are computed in the guest's browser (and, for the one end-of-event rescan, by the same open model inside our own Vercel function); the model files are self-hosted. No face data is sent to any AI company.

All non-ASEAN sub-processors are to be bound by Standard Contractual Clauses (SCCs) or equivalent data-processing agreements. (!) **CORRECTED 2026-10-22: none is signed yet** — this is NPC filing task `t2-8`. **‹OWNER TO SUPPLY: which sub-processors have a signed DPA on file›.**

---

9. Security Incident & Personal Data Breach Management

The PIC maintains a documented incident-response and breach-management process. Summary posture:

- **Detection & assessment.** Incidents are assessed by the DPO and response team to determine whether a **personal data breach** has occurred and its severity.
- **NPC notification.** Where the breach is notifiable, the NPC is notified **within 72 hours** of knowledge/confirmation, consistent with RA 10173 and NPC Circular 16-03.
- **Data-subject notification.** Affected data subjects are notified **within 72 hours** (in-app + email) of what data was involved, when, remedial actions taken, and recommended protective steps.
- **Public disclosure.** A breach summary is posted on the site within 7 days where appropriate. (!) CORRECTED 2026-10-22: no `setnayan.com/security` page exists yet; the summary would be published on `/privacy` or a new page at the time. The live `/privacy` page does not yet state the breach-notification promise (open copy item).
- **DPO channel.** Breach inquiries go to **dpo@setnayan.com**; a hotline (**‹OWNER TO SUPPLY: contact phone number (serves PIC + DPO + breach hotline)›**) is used for high-severity incidents.
- **Records.** All incidents and responses are documented for the mandatory breach report and NPC review.

> The full procedure — response team, severity matrix, containment/eradication/recovery steps, notification templates, and the breach register — is maintained in the **Data Breach Management Policy**: `NPC_Compliance/04_Data_Breach_Management_Policy_ADOPTED_2026-07-24.md` (corrected 2026-10-22 — this pointed at the superseded draft).

---

10. Data Privacy Impact Assessments (DPIA)

The PIC conducts a **DPIA** before undertaking any processing that is likely to pose a risk to the rights and freedoms of data subjects — in particular new features involving sensitive or high-volume personal data (e.g., face vectors, the person graph, vendor identity verification, and any future minors/legacy processing). Each DPIA identifies data flows, risks, and mitigations, and is reviewed by the DPO before the processing goes live.

> The DPIA methodology and the register of completed/pending assessments are maintained in: `NPC_Compliance/05_DPIA_Register_DRAFT_2026-07-05.md`.

Minors' data and legacy/post-mortem processing are **not undertaken now**; when contemplated, each will be **counsel-first** and gated on a dedicated DPIA and guardian-consent/post-mortem mechanics.

---

11. Inquiries, Complaints & NPC Contact

- **Data subject inquiries and complaints** are directed to the DPO at **dpo@setnayan.com**. The DPO acknowledges and responds within the timelines in § 6, coordinates rectification/erasure/objection, and maintains a record of complaints and their resolution.
- **Escalation to the NPC.** A data subject who is not satisfied may lodge a complaint with the **National Privacy Commission**:

> National Privacy Commission
> 5th Floor, Philippine International Convention Center (PICC) Complex, Vicente Sotto St., Pasay City, Metro Manila 1307
> Email: info@privacy.gov.ph · Website: privacy.gov.ph
> `[TO CONFIRM current NPC address/contact at time of filing]`

---

12. Review, Version Control & Effectivity

- **Ownership.** This Manual is owned by the DPO (Indalecio Sacdalan Casasola II) and approved by the PIC (Indalecio Sacdalan Casasola II).
- **Review cadence.** Reviewed at least **annually**, and additionally upon any material change to systems, sub-processors, or applicable law/NPC issuances.
- **Change control.** Material changes to processing are communicated to data subjects per § 7 and § 11 of the Privacy & Security Policy (30 days' notice; re-consent where required; public changelog).
- **Effectivity.** This Manual takes effect upon (a) the owner supplying the six fields in the "Fields the owner must supply before signing" checklist and (b) sign-off by the DPO/PIC below with an effectivity date. External PH counsel review is **recommended, not a precondition**; any change counsel or the NPC later requires is applied by a **dated amendment** (version table below). Until the owner fields are supplied and the block is signed, this Manual is **not yet adopted** and should not be filed.

Version	Date	Author	Status

0.1 (DRAFT)	2026-07-05	Prepared for DPO/counsel review	Not yet adopted
1.0 (Adoption-ready)	2026-07-24	Formatted for DPO signature	Pending owner fields + signature (counsel review recommended, non-blocking)
1.0 corrections	2026-08-17 / 2026-08-24	DPO-directed corrections	Backups, retention, photo lifetime, vendor verification, Vercel/Sentry/LanguageTool
1.1 (Revised)	**2026-10-22**	Refresh against `origin/main` `aceb080a0a`	DPO contact → dpo@setnayan.com; PostHog removed / essential cookies only; Visits; Google + Apple sign-in; Apple in-app purchase (off); supplier capture lane + takedown; sub-processor table rebuilt; deletion = anonymise-and-retain; face consent explicit + 18+, selfie erased 12 h after the event; sweeps built; no 2FA; `setnayan.ph` struck. **Still unsigned — the DPO signs v1.1 (not v1.0).**
Adopted	**‹OWNER TO SUPPLY: adoption date›**	Indalecio Sacdalan Casasola II (DPO)	Effective on signature (after owner fields; counsel review recommended, applied by amendment)

Approval blocks (to be completed on adoption):

Sign this version (v1.1, revised 2026-10-22).

- PIC / Owner: Indalecio Sacdalan Casasola II — Signature: __ Date: _____
- DPO: Indalecio Sacdalan Casasola II — Signature: __ Date: _____

> **Footnote.** This document was drafted to a compliant RA 10173 baseline **ahead of counsel** to accelerate finalization. It **is not a substitute for legal review**, and external Philippine counsel review is **recommended** — but per the adoption posture above it is **not a precondition** to adoption or filing; any change counsel or the NPC later requires is applied by a **dated amendment**. Before filing, the DPO (Indalecio Sacdalan Casasola II) should still confirm every remaining owner-supplied fact is a real value and confirm each sub-processor's DPA status (§ 8.2). The identity-verification / sanctions-screening question is resolved (retired 2026-07-03; revised 2026-10-22).

Setnayan — Records of Processing Activities (RoPA) / Data Inventory

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05**

> **Revised 2026-10-22** — measured against the shipped code on `origin/main` (`aceb080a0a`), not against older documents. What changed in this revision (full list: `00_WHAT_CHANGED_2026-10-22.md`):
> - **DPS-02** re-stated: the government ID, live selfie / liveness video and AMLC screening were **retired 2026-07-03**; Persona / Veriff / Onfido / ComplyAdvantage / AMLC are **not** recipients (finding #8/#9 of `NPC_Pack_Findings_VERIFIED_2026-08-24.md`, applied here for the first time).
> - **DPS-09** re-stated: **PostHog was removed** (PR #6774, merged 2026-10-22). There is no product-analytics processor.
> - **DPS-11** re-stated: **essential first-party cookies only, no cookie banner** (`/cookies`, effective 2026-10-22).
> - **New rows DPS-21 → DPS-28:** first-party site Visits (daily aggregates, daily-salted hash) · sign-in with Google and Apple · Apple in-app purchase (built, switched off) · the supplier Papic capture lane and supplier photo takedown · text checks sent to OpenAI and LanguageTool · error monitoring (Sentry) · connected accounts (YouTube, Drive, TikTok, Instagram, Gemini) · Pabuya gift records.
> - **DPS-03/04/08/10/14** updated: guests get no e-mail (2026-09-29); the face selfie is erased 12 hours after the event; receipt screenshots are read by Anthropic; payment records 10 years; the withdrawn "5 years post-event" window struck where it lingered.
> - **Shared-infrastructure table** brought in line with the processors the code actually calls (§ 0).
> - **Account deletion** re-stated in DPS-01: request → admin review → anonymise-and-retain (finding #6/#16), not "30-day grace then purge".
> - The face-data (3-month) and supplier-upload (90-day) deletion sweeps **now exist in code** (PR #4735, merged 2026-08-23); DPS-02 and DPS-04 say so.

The accountability record RA 10173 (Data Privacy Act of 2012) and its IRR require a Personal Information Controller (PIC) to maintain: a register of the Data Processing Systems (DPS) it operates. Each row below is **one DPS**. Sourced from `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` (§1 data collected, §3 where data lives, §4 retention, §6 consent, §10 sub-processors) and `03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md`. Facts not established in those sources are marked `[TO CONFIRM]` — none invented.

---

0. Controller & governance identification

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	BN 8297508 · valid 25 Jun 2026 – 25 Jun 2031
Brand / trade name	Setnayan
Public domains	setnayan.com ((!) CORRECTED 2026-10-22 — `setnayan.ph` struck: not owned)
Registered business address	76 Sampaguita Avenue, Quezon City — barangay + ZIP `[OWNER TO SUPPLY]`

Total headcount / employees	2 (owner + VP), both with personal-data access
NPC registration number (if already registered)	`[TO CONFIRM]`
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · **dpo@setnayan.com** (published contact, owner ruling 2026-09-22) · registered on the NPC DPO system 2026-07-07
DPO response SLA	15 business days (non-urgent); immediate for breach notifications
Breach notification	NPC + affected users within 72 hours of confirmation (policy §8)
Estimated data-subject counts (customers / vendors / guests)	Last measured 2026-08-17: 9 accounts · 39 guests · 2 shops · 6 events · 0 active face vectors. **Not re-measured 2026-10-22 (no production access from this session)** — read live from `/admin/compliance/data-sheet` on filing day

Shared infrastructure (applies across DPS's unless a row narrows it)

> **Rebuilt 2026-10-22 from the hosts the shipped code calls** (`origin/main` `aceb080a0a`). Rows that only run when a key or a switch is set say so; production key/switch values were not readable from this session. Full per-processor table: Privacy Manual § 8.2.

Layer	Provider	Location	Role
Web / application hosting	Vercel	US company; functions pinned to **Singapore** (`vercel.json` `sin1`)	Processor — every request in transit
Primary database (PII + transactional **+ biometric face vectors**)	Supabase / Postgres	**Singapore**	Processor · AES-256 at rest · RLS. **Face vectors live HERE** (`guest_face_enrollments.face_vecto` `user_face_profiles`)
Media (photos / video / enrolment selfies / payment proofs / supplier documents / chat files)	Cloudflare R2	**Asia-Pacific (APAC)** [OK] *confirmed in the Cloudflare dashboard 2026-08-01*	Processor · private buckets, short-lived signed URLs. **Does NOT hold face vectors**
Live-video relay · bot check · STUN	Cloudflare (TURN, Turnstile, STUN) · Google STUN	Global network	Processor — IP + media in transit only; TURN/Turnstile only when keys are set
Transactional email	Resend	United States	Processor. (!) Since 2026-09-29 **guests receive no e-mail** (owner ruling); couples, hosts and suppliers do
Error monitoring	Sentry	United States	Processor — stack traces + masked replay on error; e-mail/phone/face-vector scrubbing

AI assistance	Anthropic	**US**	Processor — receipt reading, supplier Deep Search, mood-board screening, theme sentence, category requests (when the key is set)
Text moderation / grammar	OpenAI (moderation) · LanguageTool (public API, Germany)	US · EU	Processor — couple editorial and guest-column text
Connected accounts	Google (sign-in, YouTube, Drive, Gemini) · Apple (sign-in, in-app purchase) · Meta · TikTok	US / SG	Processor or independent controller per connection — only after the user connects or the switch is on
Maps / embeds	OpenStreetMap Nominatim + tiles · Vimeo oEmbed	UK · US	Address text / link only
Web push	Browser push services (Apple / Google / Mozilla)	Browser vendor	Notification content, when push keys are set
~~Vendor ID verification~~	~~Persona / Veriff / Onfido~~	—	[X] **Struck 2026-10-22 — retired 2026-07-03, never engaged**
~~Product analytics~~	~~PostHog~~	—	[X] **Removed 2026-10-22 (PR #6774)**
Music generation	Suno	—	**Not called by the code**; no personal data — not a processor

Cross-border baseline: routine operation crosses the SG↔PH border, and several processors are in the US or EU; encrypted in transit (TLS 1.3), subject to NPC oversight (policy §10). (!) CORRECTED 2026-10-22: **no DPA or SCC is signed with any processor yet** (`dpa_on_file: false` on every row of `apps/web/lib/subprocessors.ts`; NPC task `t2-8`). The earlier wording asserted signed DPAs.

---

1. Records of Processing Activities — one record per Data Processing System

Legend — Legal basis per RA 10173 §12 (personal info) / §13 (sensitive personal info): **Contract** = §12(b) performance of contract; **Consent** = §12(a)/§13(a); **Legitimate interest** = §12(f); **Legal obligation** = §12(c)/§13(b)/§13(f). SPI = Sensitive Personal Information per RA 10173 §3(l).

DPS-01 · Customer / Couple Account & Event Planning

Field	Detail
Purpose	Provide the contracted planning platform: account, event setup, vendor matching (Guided + DIY), seating, save-the-date, in-app services
Legal basis	Contract (§12(b)) — service delivery; Consent (§12(a)) for marketing-sample opt-in (policy §6.2)

Data subjects	Customers (couples / organizers)
Personal data categories	Full name, mobile, email, optional profile photo; event data (date, venue, target pax, role); behavioral/in-app activity, Guided-mode decisions, search queries; uploaded content (Save-the-Date photos, invitation customizations)
SPI?	**N** (no SPI in the core account record)
Recipients / sub-processors	Supabase (DB), Vercel (hosting), Cloudflare R2 (content); Setnayan Team on mediation only
Cross-border transfer	SG (Supabase); APAC (R2)
Retention	Account profile: kept while the account is open. **On deletion: the user files a request (type DELETE on Profile) → an admin reviews it within 24 hours (active events, bookings, balance) → approval runs the erasure at once, which BLANKS the personal fields and keeps the anonymised business records** (`eraseUserAccount`, anonymise-and-retain; tax/receipt records kept for their legal period). (!) CORRECTED 2026-10-22 — this read "active + 30-day grace on deletion, then purge"; no grace period and no scheduled purge exist in code (findings #6/#16 of 2026-08-24, migration `20261106000000_account_deletion_requests.sql`). Event data: **Kept for the LIFE OF THE ACCOUNT**, deleted when the couple closes or deletes their account. Owner ruling 2026-08-17. ((!) CORRECTED 2026-10-22: "plus the existing 30-day tail" struck — no tail exists in code.) (!) **CORRECTED — the previous "5 years post-event, auto-purge at T+5y" rule is WITHDRAWN, not merely unbuilt.** Building it as written would have DELETED THE PHOTOS: in the live schema the photo rows, the guest list, the tags, the schedule and the supplier list all cascade from the event, so removing a wedding removes its album — contradicting the owner's twice-locked rule that no photo is ever deleted, only compressed. Retention is therefore bound to the purpose that is still running (the couple's own album and its context) rather than to a timer, matching the treatment of account data. Any future end date must be built to remove planning details WITHOUT touching the photos.
Security measures	AES-256 at rest; RLS per-user isolation; TLS 1.3; bcrypt passwords; optional 2FA; signed URLs for media
Risk level	**Medium**

DPS-02 · Vendor Account, Profile & Verification

Field	Detail
Purpose	Vendor (supplier) onboarding, business profile, and the business verification checklist

Legal basis	Contract (§12(b)); Legitimate interest (§12(f)) — business-document review, portfolio check, reference calls; Consent captured at registration. (!) **CORRECTED 2026-10-22 — the AMLC sanctions/PEP basis is struck: no screening is performed (retired 2026-07-03).**
Data subjects	Vendors (business owners / primary representatives)
Personal data categories	The **eight** live checklist slots (`DOC_SLOTS`, `apps/web/lib/vendor-verification.ts`): DTI certificate · BIR Form 2303 · Mayor's Permit · bank-account proof · portfolio samples · client references · social media links · a 15-minute Google Meet (identity confirmation). Plus the service profile; financial (bank/e-wallet payout account, transaction history); behavioral (response times, conversion). (!) **CORRECTED 2026-10-22: the government ID, live selfie, liveness video, phone/email OTP and AMLC screening slots were retired 2026-07-03 and are no longer collected** (code comment above `DOC_SLOTS`: *"government_id, live_selfie, phone_email_otp, and amlc_screening are RETIRED"*).
SPI?	**Y — re-based.** The **BIR Form 2303 carries the Tax Identification Number**, a government-issued identifier (RA 10173 §3(l)). (!) CORRECTED 2026-10-22: the classification previously rested on a government ID and a liveness video, which are no longer collected; the classification is kept, its basis changed (owner, 2026-08-24). Legacy uploads made before 2026-07-03 may still exist in storage and are governed by the retention line below.
Recipients / sub-processors	Supabase (Postgres, Singapore); Cloudflare R2 (APAC) private verification bucket, admin-only access; Google (the Meet call itself, run on the vendor's and our own Google accounts). (!) **CORRECTED 2026-10-22 — Persona / Veriff / Onfido and AMLC API / ComplyAdvantage were never engaged and are NOT recipients** (retired 2026-07-03; no relationship exists and no personal data has flowed). The "DTI Database" is **not a data feed**: the code makes no call to DTI (the only DTI address in the code is a help link to the public BNRS site), so any check is a manual look-up by an admin.
Cross-border transfer	SG (Supabase); APAC (R2). (!) Previously declared US/UK/PH transfers to identity and screening providers are retired — none occur.

Retention	Raw uploads (and any legacy government ID / selfie / liveness video from before 2026-07-03, bank micro-deposit, portfolio): **deleted 90 DAYS AFTER the approve/reject decision** — owner ruling 2026-08-17. The DECISION RECORD ONLY (outcome, deciding admin, timestamp) is retained **7 years** (BIR §235). DTI / BIR 2303 / Mayor's Permit: 7 years. Transaction history: 5 years (policy §4). (!) **UPDATED 2026-10-22 — the qualifier this row carried from 2026-08-17 ("ENFORCEMENT NOT YET BUILT") is no longer true:** the 90-day supplier-upload sweep shipped in PR #4735 (merged 2026-08-23, *"Delete what we said we would delete"*). Whether it has run against production data cannot be read from a session without production access. (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one.
Security measures	Extra-restricted R2 bucket (single admin role); no third-party verification call; AES-256; RLS; audit log on all admin decisions
Risk level	**Medium–High** (SPI: the TIN on BIR Form 2303; legacy pre-2026-07-03 ID uploads until the 90-day sweep removes them). (!) CORRECTED 2026-10-22 — was "High (SPI: gov ID + biometric liveness)", which described the retired collection

DPS-03 · Guest List & RSVP

Field	Detail
Purpose	Manage the couple's guest list, RSVP status, roles, table assignment, and special requests
Legal basis	Contract (§12(b)) — organizer's event service; Consent (§12(a)) for guest-provided data / photo consent at RSVP (policy §6.1)
Data subjects	Guests
Personal data categories	Full name, mobile, email, optional profile photo; event linkage + role (principal/secondary sponsor, family, friend), RSVP status, table assignment; behavioral (reels built, re-shares)
SPI?	**Y (health / religion, possible)** — `guests.dietary_restrictions` + `meal_preference` are confirmed in the live schema and `/privacy` labels them sensitive. A wedding guest list also reveals family relationships. [OK] `[TO CONFIRM]` resolved 2026-10-22

Recipients / sub-processors	Supabase; event organizer (couple); coordinator within join-permission scope; browser push services for a guest who allows notifications. Plain guests' names are visible only to recognised guests and hosts, never the public (`/[slug]/everyone` is `noindex`). (!) UPDATED 2026-10-22: **guests receive no e-mail** (owner 2026-09-29, *"No email. Either use the qr and link only"*; extended 2026-10-02 to the Save-the-Date fan-out) — the RSVP no longer asks for one
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event — kept for the life of the couple's account (DPS-01); a removed guest is soft-deleted (`deleted_at`). (!) CORRECTED 2026-10-22 — this read "5 years post-event", the window WITHDRAWN on 2026-08-17. QR-scan records keep the IP truncated, and a guest may switch their own scan record off (`guests.scan_tracking_opt_out`, 2026-09-02)
Security measures	RLS event-scoping; TLS 1.3; guest opt-out toggles; AES-256
Risk level	**Medium** (High if dietary/health SPI confirmed)

DPS-04 · Face Vectors / Auto-Tagging (per-event, consented)

Field	Detail
Purpose	Auto-tag guests in an event's photo gallery via face matching (couple-scoped only)
Legal basis	Consent (§13(a)) — guest opts in by uploading RSVP profile photo for this purpose; revocable via "Delete my face data" / Photo Consent toggle (policy §6.1)
Data subjects	Guests
Personal data categories	128-dimension **face vectors** computed **in the guest's browser** from a selfie the guest takes after ticking a separate, default-off consent box; the selfie itself (R2); consent timestamp, source and copy version. **Adults 18+ only** — enrolment refuses a guest the host has marked as a minor (`app/papic/face-enroll-actions.ts`). One end-of-event rescan runs the same open model inside our own server function and stores no face of anyone not enrolled. (!) Corrected 2026-10-22 — "derived from RSVP photo + check-in kiosk" described the old design
SPI?	**Y — BIOMETRIC** data (RA 10173 §3(l)). Highest-sensitivity category in the platform

Recipients / sub-processors	**Supabase (Singapore) — the vectors themselves**, as JSONB in `guest_face_enrollments.face_vector` + `user_face_profiles`; Cloudflare R2 (APAC) holds only the **source selfie image** (`asset_url`). [OK] **`[TO CONFIRM]` RESOLVED 2026-07-31 from shipped code: there is NO third-party matching engine.** Embedding runs **on-device / in-browser** (face-api.js / MediaPipe, `lib/face-embed.ts`) and matching runs against our own Postgres rows — **no face data is sent to any AI sub-processor.** *(Prior text placed a "per-event encrypted vector index" on R2; no such index was ever built.)*
Cross-border transfer	**Singapore** (Supabase — the vectors) + **APAC** (R2 — the source selfie images). Corrected 2026-07-31; both outside PH, so the § cross-border conclusion is unchanged, but the *location of the biometric SPI* is now stated accurately.
Retention	[OK] **UPDATED 2026-10-22.** The selfie, the enrolment row and its vector are **erased when the event's Papic closes, 12 hours after the event ends** (owner 2026-09-30, *"face will be only saved for that day"*; job `face-selfie-papic-close`, PR #6195). Backstop: **deleted 3 MONTHS AFTER THE EVENT ENDS** (92 days; job `face-data-retention`, PR #4735 merged 2026-08-23). Earlier deletion any time by withdrawing consent. (!) The qualifier this row carried from 2026-08-17 ("ENFORCEMENT NOT YET BUILT") is **no longer true** — both sweeps exist in code; they run on request traffic (cron-free), so their timing depends on traffic; that they have run in production was not verified from this session. (!) The live `/privacy` table states only the 3-month rule — the 12-hour erase is not yet on the page (open copy item). Owner ruling 2026-08-17 (history): (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one. **Deleting face data does NOT remove photo tags** — verified in the live schema: a tag carries the guest link itself and has no reference to face data, so nothing cascades. Guests keep every photo already delivered; only FUTURE automatic matching is lost, which is why the 3-month mark is safe. (!) CORRECTED 2026-08-17 — this row previously declared a "per-event lifetime + 5 years, auto-purge with event data" rule, which nothing implemented — and which had silently become "never deleted" when the media row moved to indefinite retention on 2026-08-02.
Security measures	**Per-event scoped — vectors never reused across events**; encrypted at rest; no cross-event face recognition (design lock, Person Graph DPIA #6); confidence-gated auto-tag
Risk level	**High** (biometric SPI)

DPS-05 · Papic / Photo & Video Capture & Delivery

Field	Detail
Purpose	Capture, store, tag, and deliver event photos/clips to couples and guests; Personal Reel rendering
Legal basis	Contract (§12(b)) — paid capture/delivery service; Consent (§6.1) for likeness/photo participation; opt-out → face-blur
Data subjects	Guests, customers (couples); incidental non-account attendees appearing in media
Capture sources *(added 2026-08-02 — closes DPO gate 0d)*	Three, and the RoPA previously named none of them explicitly: (1) **designated paparazzi seats** (a friend/family member claims a seat and shoots); (2) **the guests' OWN PHONES** — a guest buying or being granted Papic captures on their personal device, which is the dominant source now that Papic Pool sells as a shared-shot pool; (3) a **paired DSLR** bridged through a paired phone. Source (2) is the one this amendment exists to state: the media in this system is largely captured by ordinary attendees on their own handsets, not by an operator Setnayan or the couple controls. [+] **(4) Added 2026-10-22: a booked SUPPLIER's own phone** — see DPS-24
Personal data categories	Photos and video clips; likeness; capture metadata (`captured_at`, geo when available, device model, paired camera brand/model); tag associations
Delivery mechanism *(added 2026-08-02 — closes DPO gate 0d)*	Media is **sorted to a guest by face matching** where that guest consented to it (DPS-04), and delivered to their personal gallery. So a guest's likeness, captured on a *stranger's* phone, reaches them through an automated biometric match. The untagged-still-delivered rule means the couple receives everything regardless
SPI?	**N** in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI (health, religion). Treat as elevated
Recipients / sub-processors	Cloudflare R2 (originals, signed-URL only); Supabase (tags/metadata); hierarchical read: organizer / coordinator / guest (tagged + global) / vendor (booking-relevant)
Cross-border transfer	APAC (R2)

Retention	Full-resolution ORIGINAL: the later of 6 months from the event's first capture and 3 months after the event ENDS (the celebration's last day: `event_end_date` where the event spans several days, else `event_date` — owner 2026-08-10), then **replaced by** a compressed web copy. **Compressed web copy: free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** No scheduled deletion at any point. **No photo is ever deleted on a schedule.** Disposal occurs only on organizer removal, a validated erasure request, or account deletion. Originals synced to the couple's own Google Drive are theirs permanently and are never touched. Geo stripped on outbound shares; the original on R2 retains it (policy §4). (!) **CORRECTED 2026-08-07.** This row previously declared a **5-year hard limit** with 90-day-hot/5-year-cold tiering. That tiering was never built, no R2 lifecycle rule exists, and the compressed copy is kept indefinitely — so the row committed us, in a filing, to destroying photos we in fact keep. Declaring a purge that never happens is the more dangerous direction of drift: a commitment to the regulator broken every day.
Security measures	Signed URLs (5-min for sensitive media); no public reads; NSFW filter on-by-default (non-disableable); untagged-still-delivered; opt-out face-blur; couple review window before public unlock
Risk level	**Medium–High**

DPS-06 · Person Graph — Connections, Life Stories & Trusted-Circle (adults-only)

Field	Detail
Purpose	Durable person node; mutually-confirmed relationship connections; per-person life-story references; aggregate trusted-circle vendor signal (Person Graph pack)
Legal basis	Consent (§12(a)) — **mutual, opt-in confirmation** required for every edge; life stories rely on existing RSVP photo consent
Data subjects	Customers, guests (**adults only** — minors NOT processed)
Personal data categories	Person node (name, optional photo, events participated); first-degree connection edges (type + confirmed/pending state); life-story items = **references (pointers), not copies**; trusted-circle signal = **computed on read, not stored**
SPI?	**Potentially Y** — relationship data can infer SPI (e.g., civil status, family/religious ties). Mitigated: extended kin **derived not stored**; min-N ≥5 on aggregates

Recipients / sub-processors	Supabase (edges + references); no third-party sharing; connections never broadcast/browsable
Cross-border transfer	SG (Supabase)
Retention	Edges + references follow event/account retention (policy §4 / Compliance Pack §3); declined/hidden/opted-out suppressed immediately; reference dies with source media; trusted-circle not stored
Security measures	Mutual-confirmation gate; name-only + confirmed-only cross-person visibility; participant-scoped deny-by-default RLS; no "people you may know"; **no cross-event face recognition**; DPIA completed (Compliance Pack §2, residual Low)
Risk level	**Medium** — **Status: DRAFT, live behind flags; pending DPO/counsel sign-off.** Minors/legacy (Phase 3) counsel-first, DPIA scoped-not-complete, **not processed**

DPS-07 · In-App Communications / Chat (0019)

Field	Detail
Purpose	Text chat between couples ↔ vendors ↔ coordinators; document/sheet/PDF/image sharing on threads
Legal basis	Contract (§12(b)) — coordination is core service
Data subjects	Customers, vendors, coordinators
Personal data categories	Chat message content; attached files (doc/sheet/PDF/image); pasted external meeting links (plain text). Vendor identity masked (company logo, not personal photo)
SPI?	**N** structurally, but free-text/attachments may contain SPI — treat as elevated
Recipients / sub-processors	Supabase Realtime (ephemeral) + Postgres (history); Cloudflare R2 thread-files bucket. **Video meetings RETIRED 2026-05-16 — no video data stored**
Cross-border transfer	SG (Supabase); APAC (R2)
Retention	Messages: 5 years (aligned to event retention). Pasted meeting links follow parent message (policy §3.3, §4)
Security measures	RLS thread-scoping; per-thread coordinator join permission; vendor-identity masking; TLS 1.3; AES-256
Risk level	**Medium**

DPS-08 · Payments & Reconciliation (apply-then-pay)

Field	Detail

Purpose	Process PHP-direct service orders: BDO/GCash apply-then-pay to Setnayan's own accounts, reference codes, manual reconciliation of proof-of-payment against orders, and an AI read of the proof screenshot to check the reference the customer typed
Legal basis	Contract (§12(b)); **Legal obligation** (§12(c)) — PH tax/BIR record retention
Data subjects	Customers, vendors
Personal data categories	Payment receipts, transaction references, **partial** bank/e-wallet details for receipts/refunds; payment-proof screenshots; reconciliation inbox messages. **No complete card numbers, CVVs, or full bank account numbers stored**
SPI?	**N**
Recipients / sub-processors	Supabase (`payments`, `orders`, `receipts`, `payment_receipt_reads`); Cloudflare R2 (proof screenshot, private bucket); **Anthropic (US)** reads the screenshot to type out the reference and amount — it keeps the matched reference, amount, a match flag and one sentence, **not** the transcript, and it can never approve, reject or settle a payment (owner as DPO 2026-08-29, PR #4947, disclosed on `/privacy` §"Reading your payment receipt"); Setnayan Team (manual reconciliation). (!) CORRECTED 2026-10-22: no payment gateway is called — Maya and PayMongo are dormant in code (no API call). Apple in-app purchase: see DPS-23
Cross-border transfer	SG (Supabase); APAC (R2); US (Anthropic, receipt read)
Retention	Transaction/receipt records: **10 years** per the live `/privacy` schedule (BIR floor) — (!) corrected 2026-10-22 from "5 years"; earlier docs disagree, the public page governs. Pending orders expire 7 days (policy §4, CLAUDE.md)
Security measures	No card/full-account storage; two-admin approval for refunds >PHP 10K; append-only audit log; RLS; reference codes 8-char Crockford
Risk level	**Medium**

DPS-09 · In-App Activity Records & Admin Reporting (no product-analytics processor)

Field	Detail
Purpose	Operate the platform and report to Setnayan admins in aggregate: orders, bookings, inquiries and the per-page view counts suppliers, couples and storytellers see on their own pages
Legal basis	Legitimate interest (§12(f)) for aggregated operational reporting
Data subjects	Customers, vendors, guests

Personal data categories	The platform's own records (orders, inquiries, bookings, searches saved by the user) read in aggregate. Page-view counters for a supplier profile, storyteller chapter or Save-the-Date are kept with a one-way hash of a first-party cookie value only (`sn_vw`, `sn_vc`, `sn_vp`, `sv` on `/cookies`) so one browser is not counted twice. **Aggregated — never individually identified to admins outside dispute-mediation context**
SPI?	**N**
Recipients / sub-processors	Supabase (Postgres, Singapore) only. (!) **CORRECTED 2026-10-22 — PostHog is no longer a recipient.** The `posthog-js` dependency, its loader and the cookie-consent banner were removed in PR #6774 (merged 2026-10-22, *"essential cookies only — remove PostHog and the cookie banner"*). No third-party analytics service receives any data
Cross-border transfer	SG (Supabase)
Retention	Anonymized aggregate: indefinite (no PII). View-counter hashes: per the cookie lifetimes on `/cookies` (90 days to about 13 months). Underlying rows follow account/event retention
Security measures	Aggregation + de-identification for admin views; hashed counters only; admin-only RLS on reporting tables. (!) CORRECTED 2026-10-22 — the "opt-out toggle" previously listed here never existed (finding #13 of 2026-08-24); with PostHog gone there is no analytics stream to opt out of
Risk level	**Low**

DPS-10 · Email Notifications (Resend)

Field	Detail
Purpose	Transactional + milestone email: payment instructions/confirmation, refunds, vendor messages/status, RSVP received, wedding-day reminder, save-the-date, security alerts
Legal basis	Contract (§12(b)) for transactional mail; Consent (§12(a)) for promotional/marketing mail (revocable; RFC 8058 one-click unsubscribe)
Data subjects	Customers, vendors, guests
Personal data categories	Email address, recipient name, event/order context embedded in the message
SPI?	**N**
Recipients / sub-processors	Resend (delivery); browser push services for web-push notifications (when push keys are set). (!) Corrected 2026-10-22: no SendGrid fallback exists in code. **Guests receive no e-mail since 2026-09-29** (owner ruling) — notices to guests are in-app / QR / link only

Cross-border transfer	US (Resend)
Retention	Follows the underlying record; our own delivery log (`email_deliveries`) keeps a **masked** recipient, subject and outcome; provider-side log retention not verified
Security measures	TLS in transit; one-click unsubscribe; RA 10173 + CAN-SPAM compliant templates
Risk level	**Low**

DPS-11 · Public Site & Cookies (essential cookies only)

Field	Detail
Purpose	Run the public site (setnayan.com) and keep people signed in, carry guest passes and remember screen choices
Legal basis	Legitimate interest (§12(f)) / contract (§12(b)) for strictly necessary, first-party cookies. (!) **CORRECTED 2026-10-22 — the "consent for analytics/advertising cookies" basis is retired: there are no analytics or advertising cookies, so there is nothing to consent to and no banner** (`/cookies`, effective 2026-10-22)
Data subjects	Website visitors, account holders, guests
Personal data categories	First-party cookies only, each listed by name and lifetime on `/cookies`: the Supabase sign-in cookie (`sb-…-auth-token`), guest-pass cookies (`setnayan_guest_session`, `setnayan_guest_passes`), Terms-tick carriers, theme and screen-pairing choices, staff-only switches, and the view-count cookies of DPS-09. Browser storage: `sn_did` (fraud-protection random value — only its hash is stored, see DPS-12) and a Sentry masked-replay session key (DPS-26). Policy acceptance is logged with timestamp + IP + user-agent
SPI?	**N**
Recipients / sub-processors	Vercel (hosting); Supabase (sign-in). **No third-party cookies** — every cookie is first-party. Third-party display ads (AdSense) were retired 2026-05-19. The YouTube embed uses the privacy-enhanced player, which sets no tracking cookie until someone presses play
Cross-border transfer	US (Vercel hosting); SG (Supabase)
Retention	As printed per cookie on `/cookies` (5 minutes to about 13 months; the sign-in cookie up to 1 year). (!) CORRECTED 2026-10-22 — the "12-month consent-state persistence" previously referenced is retired with the banner
Security measures	First-party only; httpOnly sign-in cookie; TLS 1.3; HSTS; CSP; `essential-cookies-only.test.ts` guards the no-banner claim in the code
Risk level	**Low**

DPS-12 · Anti-Fraud & Trust Integrity (identity clustering · fraud scoring · enforcement)

Field	Detail
Purpose	Protect marketplace trust signals from manipulation: cluster likely-same-person/household accounts by shared strong signals; de-duplicate vendor review/rating/booking stats per cluster with arm's-length exclusion; score per-vendor fraud anomalies; two-stage enforcement (reversible auto-suspend + human four-eyes wipe/ban). Spec `03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md`
Legal basis	**Legitimate interest (§12(f))** — fraud prevention / marketplace integrity. **Requires** a documented legitimate-interest balancing + **disclosure** (both outstanding — DPIA R-08 §6). Automated-suspension effect engages §16(c) (right to object) + §34 (automated processing) `[TO CONFIRM]` counsel
Data subjects	Couples / guests (whose device/address/payment signals are clustered — **they never see cluster membership**) + vendors (scored, and subject to auto-suspend / ban)
Personal data categories	**Repurposed inputs (no new collection):** device fingerprint (`user_devices.device_hash`), normalized home address (`users.address_normalized`), payment-sender identity (`payments.reference_number`→paying user). **Derived:** identity `cluster_id`; per-vendor fraud signals + 0–100 scores with **non-PII** evidence (counts/ratios/opaque labels); enforcement state + append-only audit. **IP deliberately NOT captured**
SPI?	**N** — inputs are personal information, not §3(l) SPI. Elevated because it is **involuntary profiling with an automated decision that has a significant effect** (vendor livelihood)
Recipients / sub-processors	Supabase (Postgres, Singapore) only — no third-party/AI sub-processor. **Service-role / admin ONLY** (`REVOKE ALL FROM anon, authenticated` + `is_admin()` RLS at CREATE); Setnayan admins via `/admin/fraud` + two-admin approval gate
Cross-border transfer	SG (Supabase)
Retention	`identity_clusters` / `vendor_fraud_scores` = recomputed matviews (no history). `fraud_signals` + `fraud_enforcement_audit` persist — **explicit retention rule not yet defined `[TO CONFIRM]`**. Signal inputs follow their source systems (device/address = account retention; payment = 5-yr tax, DPS-08)
Security measures	Service-role/admin-only + deny-by-default RLS at CREATE; non-PII evidence; reversible auto-suspend at high threshold (score ≥90); **irreversible ban never automated** — four-eyes gate + typed confirmation; append-only audit; help-center appeal path; AES-256; TLS 1.3

Risk level	**High** — **Status: LIVE in production since 2026-07-07, ahead of counsel sign-off (owner-elected).** DPIA R-08 drafted (`08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md`); Privacy Policy Anti-Fraud disclosure + LIA + formal contest path outstanding

DPS-13 · Vendor AI Assistant — automated replies + business deep-search (0022)

Field	Detail
Purpose	The paid Vendor AI add-on, two capabilities: **(a) Auto-reply** — reads a couple's inbound messages + Event Brief (event date, guest count, budget-per-head, venue) in that couple↔vendor thread and drafts/auto-sends replies (and, if the vendor allows, accepts a booking) on the vendor's behalf, shown to the couple labelled " AI auto-reply"; **(b) Deep Search** — runs AI web-research over the **vendor's own** business across public sources (own website, directories, review sites) and stores a structured business dossier (`vendor_web_dossiers`) the vendor reviews to auto-fill its profile. Both are gated behind the `/admin/data-privacy` controls `vendor_ai_autoreply` + `vendor_deep_search` (fail-closed until DPO-activated)
Legal basis	**Contract (§12(b))** — the vendor's paid add-on operating on the vendor's own shop; **Consent (§12(a))** — the couple's own act of messaging that vendor grounds the auto-reply reading their thread. Auto-reply is **automated processing (§34)** with a standing " AI auto-reply" label and a §16(c) object path (every message still reaches the vendor). Deep Search of already-public third-party content relies on **legitimate interest (§12(f))**, minimised to a business summary with a 180-day retention limit `[TO CONFIRM]` counsel
Data subjects	Couples (inbound message text + Event Brief the auto-reply reads) + vendors (own business researched, dossier stored) + incidental third parties named on public web pages (Deep Search, e.g. a reviewer's public name)
Personal data categories	**Auto-reply:** couple inbound chat text + structured Event Brief fields (date, pax, budget band, venue) + the vendor's own package/pricing config; generated reply text. **Deep Search:** the vendor's own public business info (name, contact, services, review-derived facts) → `vendor_web_dossiers`. **Never** consumes SPI, face vectors, religion/faith, or the guest list
SPI?	**N** — no SPI; biometric, faith, and guest-PII consumption are explicitly carved out
Recipients / sub-processors	Supabase (Postgres, Singapore); **Anthropic web_search (US, Deep Search only)** — zero-retention API mode. **Single-tenant isolation**: a vendor's assistant reads only that vendor's own threads/business, never across vendors or across the couple's events
Cross-border transfer	SG (Supabase); **US (Anthropic — Deep Search only)**

Retention	Deep Search dossier `vendor_web_dossiers` — rolling **180-day** TTL `[TO CONFIRM]`. Auto-reply reads live thread + Event Brief data in place (no separate store beyond the chat system, DPS-07)
Security measures	Per-vendor single-tenant isolation; both capabilities **fail-closed** until DPO-activated on the `/admin/data-privacy` control board; " AI auto-reply" transparency label; SPI / face / guest-list carve-out enforced in code; TLS 1.3; AES-256
Risk level	**Medium** — automated processing (§34) of couple message content + AI web-research that may store incidental third-party PII. Public Privacy Policy §"Vendor AI assistant" + §"Vendor Deep Search" disclosures **LIVE**; the `/admin/data-privacy` controls hold both OFF until DPO sign-off; retention rule + LIA finalization outstanding

DPS-14 · Coordinator Delegated Access — consent scopes + prep-then-release (0021)

Field	Detail
Purpose	Let a couple delegate planning access to a **coordinator** they invite (a planner / family / friend — host-side, not Setnayan staff). At invite the coordinator accepts an RA 10173 **consent modal** scoping access to the couple's **guest list, seating, schedule, and vendor chats**. The couple may optionally grant **"Can finalize vendors"** and **"Can handle payments"** scopes (lock vendors + complete an apply-then-pay checkout on the couple's behalf). **Prep-then-release** lets the coordinator stage run-of-show/schedule blocks privately and release them to the couple (staged blocks hidden from couple/guests/vendors until released). Gated behind the `/admin/data-privacy` controls `coordinator_consent_money` + `coordinator_prep_release` (fail-closed)
Legal basis	**Consent (§12(a))** captured on the invite modal + **Contract (§12(b))** — service delivery. Money scopes are **opt-in by the couple**; consistent with the platform-wide rule that **Setnayan never HOLDS and never MOVES money** — settlement is direct couple↔vendor, off-platform, and the coordinator merely prepares the same off-platform payment. (!) **CORRECTED 2026-08-17 — the word “records” was struck: it was FALSE.** Setnayan DOES record couple→supplier payments the couple enters in their own budget — amount, date, method and reference number, with the supplier able to confirm receipt in-app. Measured in production 2026-08-17: **3 payment records totalling PHP 111,500** (2026-05-28 → 2026-06-05). Those records are declared at **DPS-20** below. The 0%-commission position is untouched: we never touch the money, we only write down that the couple says they paid it.
Data subjects	Couples (planning data + optional money authority delegated) + guests (whose PII the coordinator sees within scope) + coordinators

Personal data categories	Guest list + RSVP data, seating, schedule / run-of-show, vendor chat threads — scoped to the granted permissions; optional money-adjacent actions (vendor finalize, checkout) when the couple grants the scope; staged prep-release schedule blocks (hidden until released). **Face / biometric data excluded**
SPI?	**N** — no new SPI collection; scoped delegated access to the couple's existing planning data (incl. guest PII)
Recipients / sub-processors	Supabase (Postgres, Singapore) — RLS event/thread scoping + per-thread coordinator join permission (see DPS-07). **No new sub-processor**
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event data (DPS-01 / DPS-03 / DPS-07) — life of the couple's account ((!) corrected 2026-10-22 from "5 years post-event", withdrawn 2026-08-17). Coordinator access is **revocable by the couple** at any time; revocation removes access prospectively
Security measures	RLS event/thread scoping; consent captured at invite (durable proof); money scopes opt-in **and** separately gated; face/biometric excluded; staged prep-release hidden until released; controls **fail-closed** until DPO-activated; TLS 1.3; AES-256
Risk level	**Medium** — widens a coordinator's access over guest PII and, if the couple grants it, money-adjacent actions. Public Privacy Policy §"Coordinators you invite" disclosure **LIVE**; confirm the DPO ruling before activating the `coordinator_consent_money` control

DPS-15 · Guest-Written Columns — guest-authored text published to the open web (2026-08-02)

Field	Detail
Purpose	Let a guest write one short column (title + body) for the couple's event page. After the couple approves it, the column is **published on the open web** on the public event page and may carry into the post-event editorial, under a byline drawn from the guest-list name
Legal basis	**Consent (§12(a))** — captured at submit time and stored as a durable timestamp (`consent_captured_at`, NOT NULL backstop); publication additionally requires the couple's approval. Withdrawal is self-serve and immediate
Data subjects	Guests (authors); persons named inside a guest's free text (incidental)
Personal data categories	Guest-authored free text (title ≤60 chars, body ≤280 chars) + the author's **byline** (their name as it appears on the event's guest list). No contact details are published

SPI?	**N by design, but elevated** — free text is unbounded in content and a guest may volunteer health, religious or political statements about themselves or others. Tier-1 automatic screening runs on every submit; treat as elevated
Recipients / sub-processors	**The open web** (public event page; post-event editorial). Supabase (Postgres, SG) for storage. **No new sub-processor**
Cross-border transfer	SG (Supabase); the published page is world-readable by nature
Retention	Lives with the guest record and the event. **Withdrawal by the author removes it from the page immediately**; deleting the guest record or the event removes it with them
Security measures	Two independent gates before any publication (automatic screening **and** couple approval — nothing auto-publishes); consent timestamp captured at submit so consent is never assumed; self-serve takedown (RA 10173 right to erasure/blocking); capability held **fail-closed** by the `/admin/data-privacy` control `guest_columns`
Risk level	**Medium** — publication of a named individual's words to the open web. Public Privacy Policy §"Guest-written columns on an event page" disclosure **LIVE** (scope, approval gate, byline, withdrawal, consent capture all stated)

DPS-16 · Papic Shared Pool — event-wide guest media visibility + self-linking (2026-08-02)

Field	Detail
Purpose	When the host opens the shared pool for their event, let **every signed-in guest of that same event** browse the event's whole capture pool, and let a guest **self-link** to a photo they appear in ("I'm in this"), which joins that photo to their personal gallery, ZIP download and Story reel
Legal basis	**Contract (§12(b))** — the capture/delivery service the couple bought; **Consent (§12(a))** — the guest's capture-time opt-in and the per-photo consent state; the host's per-event toggle (`events.pool_gallery_open`, default FALSE) is the additional gate
Data subjects	Guests whose likeness appears in the media; guests as viewers; incidental non-account attendees appearing in media
Personal data categories	**Compressed web copies only** of photos and short clips (never the geo-bearing original); `manual_pick` photo tags created by a guest self-linking
SPI?	**N** in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI. Treat as elevated — see DPS-05
Recipients / sub-processors	**Other signed-in guests of the SAME event only** — never the public, never anyone outside that event, never across events. Cloudflare R2 (web copies, signed-URL), Supabase (tags). **No new sub-processor**

Cross-border transfer	APAC (R2) + SG (Supabase) — unchanged from DPS-05
Retention	Follows DPS-05 — full-resolution ORIGINAL held the later of 6 months from the event's first capture and 3 months after the event ENDS, then **replaced by** a compressed web copy; the compressed copy is free, **for life** (owner 2026-08-18, *"we keep it for life"*, superseding the 2026-08-07 five-year window and its never-built paid option). [X] **No photo is ever deleted on a schedule — only its resolution changes. The host's toggle closes the pool retroactively** — turning it off withdraws event-wide visibility from media already captured. (!) **CORRECTED 2026-08-17.** This row was drafted 2026-08-02 and back-referenced DPS-05 as *"90 days hot + 5 years IA cold"* — the tiering that DPS-05 itself had already retired on 2026-08-07. It was never built, no R2 lifecycle rule exists, and it declared a destruction we do not perform.
Security measures	The pool read is a single RPC that bakes in **all three** protections: the FaceBlock blur rule, the consent-withdrawal rule ((!) updated 2026-10-22: since PR #4747/#4766 a withdrawn guest's face is **blurred and the photo kept**, no longer vetoed — owner ruling 2026-08-17), and **web-copy-only keys** so a geo-bearing original can never be served here; automatic screening must have passed; scoping is per-event and cannot drift; capability held **fail-closed** by the `/admin/data-privacy` control `papic_pool_gallery`
Risk level	**Medium–High** — this is the widening from *per-guest tagged delivery* to *event-wide visibility*: a guest's shots become visible to every other guest at that celebration. Public Privacy Policy §"Photos and videos — location data and guest capture" discloses the shared pool explicitly (scope, web-copies-only, screening, event-scoping, self-linking, and how to avoid it) — **LIVE**

DPS-17 · Same-Date Demand Signal — cross-couple aggregate (2026-08-02)

Field	Detail
Purpose	Tell a couple how many **other couples have inquired** with the same vendor for the **same exact date**, and feed that number to the "In demand right now" ranking lens as a sub-score
Legal basis	**Legitimate interest (§12(f))** — marketplace transparency so a couple can judge urgency on real activity rather than on a scarcity claim. Balancing test rests on the three minimisations below
Data subjects	Customers (couples) — both the couple who sees the number and the couples counted in it
Personal data categories	**An aggregate count only.** No identity, no event id, no vendor-couple pairing and no date of any other couple leaves the server — the recipient receives an integer
SPI?	**N**

Recipients / sub-processors	The inquiring couple, in-app only. **No new sub-processor**; the aggregation is a Postgres read
Cross-border transfer	SG (Supabase)
Retention	**None** — the count is computed per request and never stored
Security measures	Three minimisations, all server-side: (1) **inquiry-only** — the count discriminates on `chat_threads` existence, so a vendor a couple merely *saved* contributes zero (a save is not competition — owner ruling 2026-06-02); (2) **min-3 floor** — nothing below `MIN_DEMAND_COUPLE_COUNT = 3` is returned at all, because n=1 on a solo vendor for an exact date in a small municipality is functionally re-identifying; (3) **exact-date only**, with no month/year fallback, so a couple without a fixed date generates and receives nothing. Capability held **fail-closed** by the `/admin/data-privacy` control `same_date_demand` (seeded **inactive**)
Residual concern for the DPO	**There is no per-couple opt-out.** A couple cannot exclude their own inquiry from the counts other couples see. The mitigation is that what is disclosed is an aggregate at or above 3, never an identity — but the absence of an opt-out is the point on which a ruling is asked
Risk level	**Low–Medium** — the only cross-couple disclosure on the marketplace, but bounded to an integer ≥ 3. Public Privacy Policy §"Vendor interest counts (what other couples can see)" disclosure **LIVE**

DPS-18 · Live Video Connections — WebRTC signalling + TURN relay (2026-08-02)

Field	Detail
Purpose	Carry live audio/video **directly between two devices** for: voice/video calls inside a vendor conversation; a camera operator's phone feeding the couple's Live Studio control room; a guest tapping a side camera on an event page; and the homepage live demo. Relay the media through a TURN server **only** when a direct path is impossible
Legal basis	**Contract (§12(b))** — delivery of the calling / Live Studio features the user initiated
Data subjects	Couples, vendors, coordinators, guests, camera operators — anyone who joins a live connection
Personal data categories	**IP addresses**, as ICE candidates. A direct connection is only possible if each device learns the other's address; this is inherent to WebRTC everywhere, not something Setnayan adds. Plus a per-connection technical record of **whether the path was direct or relayed and the general network type**
SPI?	**N**

Recipients / sub-processors	The **other participant's device** (inherently receives the IP). **STUN** address discovery: Google or Cloudflare public servers. **TURN relay** (relayed sessions only). Setnayan's own infrastructure carries the setup messages **in transit**
Cross-border transfer	Yes — STUN/TURN endpoints are outside PH
Retention	**Addresses are not retained.** The candidate addresses pass through the signalling path in transit and are **not written to the database, not logged, and not used for anything else**. What is kept per connection is direct-vs-relayed + general network path type, for sizing relay cost — that record contains **no IP address and no audio or video**
Security measures	**Calls are never recorded** (platform lock). Media is end-to-end between the two devices on a direct path; on a relayed path the TURN server forwards encrypted media it cannot read. No content of any call is stored
Risk level	**Medium** — IP exposure between participants is unavoidable for the feature to exist and is disclosed in plain language rather than buried. Public Privacy Policy §"Live video connections (calls and event cameras)" explains the IP exchange, the STUN contact, the in-transit-only signalling, and exactly what is kept — **LIVE**. *(This entry closes the RoPA item owed for WebRTC/TURN — security handoff task #42.)*

DPS-19 · Coordinator Day-of Operations — filtered run-of-show · announcements · requests desk (2026-08-02)

Field	Detail
Purpose	The three surfaces a coordinator *acts* from on the event day, as distinct from the planning-phase delegation in DPS-14: (1) the **filtered run-of-show** — one master timeline auto-filtered per audience; (2) **day-of announcements** — a short broadcast to the event; (3) the **requests desk** — a single inbox of things raised on the floor
Why a separate entry	DPS-14 declares the coordinator's *consent scopes* and *prep-then-release*, i.e. what a coordinator may **see** and stage. It never named these three, and all three are **active in production**. Two of them are outward actions rather than reads — one of which reaches the couple's **guests** — so they belong on the register in their own right
Legal basis	**Contract (§12(b))** — running the event the couple engaged the platform for; **Consent (§12(a))** — the coordinator's own access consent captured at invite (DPS-14)
Data subjects	Couples; guests (as announcement recipients and as the subject of floor requests); vendors (as filtered-timeline recipients and requesters); coordinators
Personal data categories	**Run-of-show:** schedule blocks + responsible-party tags. **Announcements:** free text ≤500 chars + the sender's identity and timestamp; immutable once posted. **Requests desk:** the request's free text + who raised it + its lane/status

SPI?	**N** — no new sensitive category. Free text in an announcement or a request is unbounded in principle; both are event-scoped and short-lived
Recipients / sub-processors	**Announcements are read by everyone on the event** — couple, guests and vendors alike (RLS Pattern B member read + delegate read + admin observability). Run-of-show is *narrowed* per audience: a vendor sees only blocks they are tagged responsible on, a guest sees only public rows, the couple sees the master. Requests stay between the raiser and the coordinator/couple. Supabase (Postgres, SG). **No new sub-processor**
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event — deleted with it (`ON DELETE CASCADE`). (!) Corrected 2026-08-17: this read "inside the 5-year event-data window"; that window is WITHDRAWN — event data is now kept for the life of the account (see DPS-01)
Security measures	All three held **fail-closed** by their own `/admin/data-privacy` controls (`coordinator_run_of_show`, `coordinator_day_of_broadcast`, `coordinator_requests_inbox`); event-scoped RLS with **canonical patterns only**; announcements are **immutable and attributed** — no silent edit or anonymous post; the run-of-show filter is a genuine **minimisation** (a vendor cannot read the parts of the day that are not theirs); **no acknowledgment tracking** was built, so reading an announcement is not recorded against a guest
Risk level	**Low–Medium** — the outward reach to guests is the notable part, and it is bounded to a short, attributed, event-scoped message. Public Privacy Policy §"Coordinators you invite (delegated access)" gained both missing paragraphs on 2026-08-02 (announcements + requests desk) — **LIVE**

DPS-20 · Couple→Supplier Payment Log — amounts the couple records against their own bookings (2026-08-17)

Field	Detail
Purpose	Let a couple keep their own record of what they have paid each supplier, against the payment milestones of a booking, and let the supplier confirm receipt. This is a LEDGER THE COUPLE WRITES — it is not a payment rail.
Why a separate entry	(!) **This activity was undeclared until 2026-08-17.** The register relied on a platform-wide sentence that Setnayan *"never holds, moves, or records the transfer of any money"*, and used it as the reason the coordinator's money scopes needed no financial-data declaration. **The "records" half was false**, so the only financial records that exist in the product were undeclared on the strength of it.

Legal basis	**Contract (§12(b))** — the budget/vendor-management service the couple engaged the platform for
Data subjects	Couples (organizers); suppliers (as payees); coordinators, where the couple has granted the money scope
Personal data categories	Amount in PHP, payment date, method (e.g. bank transfer, GCash), a free-text reference number, optional notes, an optional uploaded proof image, and the supplier + booking the payment is against. Plus who confirmed receipt and when
SPI?	**N** — financial information about a transaction the couple discloses themselves. No card numbers, no bank credentials and no account numbers are collected by the platform
Recipients / sub-processors	Supabase (Postgres, Singapore); Cloudflare R2 (Asia-Pacific) for an uploaded proof image. The supplier named on the row; a coordinator only where the couple granted the money scope
Cross-border transfer	SG (Supabase); APAC (R2, only where a proof image is uploaded)
Retention	Follows the parent event — life of the account (see DPS-01). (!) Financial records may attract the BIR/statutory floors of policy §4 where they evidence a taxable transaction; **the couple↔supplier settlement is off-platform and is not Setnayan revenue**, so the floor is not automatic. `[TO CONFIRM WITH COUNSEL]`
Security measures	RLS scoped to the event; the supplier sees only rows naming them; the coordinator's access is gated by the couple's opt-in money scope and the `coordinator_consent_money` control; proof images are signed-URL only
Risk level	**Low–Medium** — small volume, self-disclosed, no payment credentials. Measured in production 2026-08-17: **3 records totalling PHP 111,500** (2026-05-28 → 2026-06-05)
Note on the 0% commission position	Unchanged and still true: Setnayan **never holds and never moves** this money. The couple pays the supplier directly, off-platform. We record only what the couple tells us they paid

---

DPS-21 · First-party Site Visits — daily aggregates, daily-salted hash (added 2026-10-22)

Field	Detail
Purpose	Show Setnayan admins how many people visit which kinds of page, from where and on what device, without analytics cookies or a third-party analytics service (owner 2026-10-22: traffic stats *"belong in Admin › App Performance, not in Vercel; no cookies, no banner"*)
Legal basis	Legitimate interest (§12(f)) — operating and improving the site; balancing rests on the minimisations below
Data subjects	Every site visitor (signed in or not)

Personal data categories	**Processed for an instant, not stored:** the visitor's IP address and browser user-agent, combined into `sha256(IP | user-agent)` inside the request middleware. **Stored for one Manila day only:** that key hashed again with a random salt minted for the day (`site_visit_seen`, `site_visit_salts`). **Stored long-term, no personal data:** a daily aggregate row per route **pattern** (e.g. `/v/[slug]`, never a real address), referrer domain, `utm_source`, device class, two-letter country, signed-in yes/no, with view and visitor counts (`site_visit_days`)
SPI?	**N**
Recipients / sub-processors	Supabase (Singapore) only; Vercel provides the country header. **No cookie, no browser ID, no third party.** Admin-only read (`is_admin()` RLS) at `/admin/app-performance?tab=visits`
Cross-border transfer	SG (Supabase); US company (Vercel) in transit
Retention	Salt and salted hashes: **deleted by the first visit of the next Manila day**, after which two days' visitors can never be linked. Aggregates: kept (no personal data). Bots, admin pages, prefetches and previews are not counted
Security measures	Migration `20271282829207_site_visits_daily.sql` (PR #6771, merged 2026-10-22): RLS at CREATE; write only through a service-role function; CHECK constraints reject any path holding a 4+ digit run, a UUID, an `S89` id, `@`, `?` or `#`
Risk level	**Low.** (!) **Disclosure gap:** `/cookies` says *"beyond the view counts above, nothing measures how you use Setnayan"* and `/privacy` says *"No product analytics"* — neither mentions this cookie-less visit count. One sentence on both pages closes it (open copy item)

DPS-22 · Sign-in with Google and Apple (added 2026-10-22)

Field	Detail
Purpose	Let a person create or open their account with their Google or Apple account instead of a password, on the web and in the iPhone app
Legal basis	Contract (§12(b)) — account creation the user asks for; Consent (§12(a)) — the user's own choice of provider on the provider's consent screen
Data subjects	Account holders who choose Google or Apple
Personal data categories	From the provider: name, e-mail (for Apple possibly a **private-relay** address, stored as an ordinary e-mail), Google avatar URL — kept by Supabase Auth in the identity record. **Apple:** the user's Apple **refresh token**, sealed with AES-256-GCM in `apple_sign_in_tokens`, kept **only** so account erasure can revoke the Apple grant (App Store rule 5.1.1(v)); deleted at erasure. The iPhone sheet asks Apple for full name + e-mail

SPI?	**N**
Recipients / sub-processors	Google LLC / Apple Inc. (the identity provider — independent controllers of their own account data); Supabase Auth (Singapore)
Cross-border transfer	US (Google, Apple); SG (Supabase)
Retention	Life of the account. At erasure the Apple grant is revoked and its token row deleted. (!) **Known gap:** the Google/Apple name, e-mail and avatar copy in `auth.identities.identity_data` is **not** blanked by erasure today (DECISION_LOG 2026-10-22) — open engineering item
Security measures	Each provider is behind its own switch (`NEXT_PUBLIC_OAUTH_GOOGLE_ENABLED`, `NEXT_PUBLIC_OAUTH_APPLE_ENABLED`; code default off — **production values not readable from this session**); Facebook sign-in is hard-off in code; sealed Apple token, service-role only
Risk level	**Low.** (!) **Disclosure gap:** `/privacy` on `origin/main` does not describe sign-in with Google or Apple (only the sign-up line *"By continuing with Google or Apple, you agree…"*). A `/privacy#google-user-data` section is drafted on branch `rd/google-can-verify-setnayan` for Google's branding review — **not merged on 2026-10-22**

DPS-23 · Apple In-App Purchase (built, switched off — added 2026-10-22)

Field	Detail
Purpose	Let an iPhone-app user buy a digital add-on through Apple, as App Store rules require
Legal basis	Contract (§12(b)); Legal obligation (§12(c)) — the purchase is a financial record kept for BIR
Data subjects	Account holders buying in the iPhone app
Personal data categories	`app_store_purchases`: an app account token, user id, event id, product, Apple transaction ids, environment, price, currency, purchase / verification / revocation times, the last Apple notification type; each purchase also writes `orders` + `payments` rows. Apple's signed transactions are **verified offline** against Apple's pinned root certificate — **no outbound call to Apple**
SPI?	**N**
Recipients / sub-processors	Apple Inc. (the store — sees the purchase as its own transaction); Supabase (Singapore)
Cross-border transfer	US (Apple); SG (Supabase)

Retention	Kept as a financial record (10-year BIR floor); not removed by account erasure (`lib/erasure/coverage-guardrail.test.ts`)
Security measures	RLS on, no policy — service role only. **Switched off in code:** `NEXT_PUBLIC_APPLE_IAP_ENABLED` (default off) **and** a store-build user-agent check. The first App Store submission (iOS 1.0) went without in-app purchase (owner 2026-09-20)
Risk level	**Low** — and dormant until switched on. Not yet described on `/privacy` (to add before it is switched on)

DPS-24 · Supplier Papic Capture Lane, Supplier Copies & Guest Takedown (added 2026-10-22)

Field	Detail
Purpose	Let a supplier booked on an event (e.g. a caterer, stylist, photographer) take photos and short clips **of their own work** on their own phone, keep them as their own copy and portfolio, and let any guest pictured have a photo taken down — from the couple's gallery **and** from the supplier's own copy
Legal basis	Contract (§12(b)) — the supplier's booking; Consent (§12(a)) / legitimate interest (§12(f)) for the event's photo-consent model. Owner as DPO, 2026-09-16: a supplier's day-of photos are *"their own copy. they get to keep it for portfolio"*, and the guest is told *"before the first photo"*; on a takedown, *"we will honour the guest"*. Portfolio use after a 7-day guest notice (owner 2026-10-03)
Data subjects	Guests and couples appearing in supplier photos; suppliers
Personal data categories	`vendor_papic_captures`: supplier, event, R2 object key, photo or clip (≤10 s), device model, consent basis, NSFW check, hidden time. **No location stored.** `vendor_papic_portfolio_photos`: the supplier's imported portfolio album. Credit grants (`vendor_papic_capture_grants`, `vendor_papic_portfolio_credit_grants`)
SPI?	**N** in the general case; images may incidentally reveal SPI — treat as elevated (as DPS-05)
Recipients / sub-processors	Cloudflare R2 (APAC); Supabase (SG). The couple and event members see supplier captures only once NSFW-checked and not hidden. The supplier keeps its own copy
Cross-border transfer	APAC (R2); SG (Supabase)
Retention	Compresses like every other Papic photo (original replaced by the web copy, PR #4767); the supplier's camera closes on event day (PR #4971). **A takedown sets `hidden_at` on all four capture tables** — `papic_photos`, `papic_guest_captures`, `vendor_papic_captures`, `vendor_papic_portfolio_photos` (`lib/hide-a-reported-photo.ts`, held by `a-takedown-reaches-every-suppliers-copy.db.test.ts`); the supplier is told it came down, without the guest's name

Security measures	Insert only by a supplier booked on that event (RLS `current_vendor_booked_event_ids()`); NSFW screen on upload; gated by the `/admin/data-privacy` control `vendor_papic_capture` (seeded inactive; a code comment says active in production since 2026-07-16 — **not measured**). The capture count could not be re-measured (last reading 0 rows, 2026-09-22) — **no production access from this session**
Risk level	**Medium.** (!) **Two gaps:** (1) the takedown is **moderator-mediated** — a guest files a report and an admin hides it; (2) the guest's report button accepts only couple/guest photos, so **a guest cannot yet file a takedown against a supplier-held photo** — the machinery honours it, the entry point does not exist (DECISION_LOG 2026-09-16 / 10-02). Migration header still reads *"COUNSEL-GATED"*

DPS-25 · Text Checks — OpenAI moderation and LanguageTool (added 2026-10-22)

Field	Detail
Purpose	Screen text that will be published on an event page (the couple's story / editorial, guest-written columns) for abuse, and suggest spelling fixes
Legal basis	Legitimate interest (§12(f)) — keeping published pages safe; Contract (§12(b))
Data subjects	Couples (authors); guests (column authors); anyone named in the text
Personal data categories	The text itself, which may contain names and personal stories
SPI?	**N** by design; free text may volunteer SPI — treat as elevated
Recipients / sub-processors	**OpenAI (US)** — Moderation API, when its key is set; **LanguageTool (LanguageTooler GmbH, Germany)** — free public API, **always called** when an editorial is scanned, **no account and no DPA** (`apps/web/lib/editorial-scan.ts`)
Cross-border transfer	US (OpenAI); EU (LanguageTool)
Retention	Not stored by us beyond the text itself; provider-side retention not verified
Security measures	Text only, no account identifiers sent; both named on `/privacy`
Risk level	**Low–Medium.** Open owner decision since 2026-08-24: keep LanguageTool (no DPA) or drop the call

DPS-26 · Error Monitoring — Sentry (added 2026-10-22)

Field	Detail
Purpose	Find and fix software faults

Legal basis	Legitimate interest (§12(f)) — reliability and security
Data subjects	Any user whose request errors
Personal data categories	Stack traces, breadcrumbs, request context; on a **browser** error, a screen replay with **all text masked and all media blocked** (session sample 0, on-error sample 100%). The browser scrubs e-mails, phone numbers and keys named like e-mail / phone / token / password / address; the server scrubs face vectors and drops the event if scrubbing fails. `sendDefaultPii` is off
SPI?	**N**
Recipients / sub-processors	Sentry (US). Sets no cookies; the replay key lives in session storage
Cross-border transfer	US
Retention	Sentry's own retention; our `/privacy` promises error logs ≤ 90 days — (!) **no purge job found in code** for our own logs (open item)
Security measures	As above; runs only when the DSN is set
Risk level	**Low**

DPS-27 · Connected Accounts — YouTube (Live Watch), Google Drive, TikTok, Instagram; Gemini renders (added 2026-10-22)

Field	Detail
Purpose	Do what the user asks with an account they connect: run a Live Watch broadcast on YouTube; copy their event photos into their own Google Drive; post a Patiktok video to their TikTok; show a supplier's Instagram posts on their shop; render a paid mood board with Google's image model
Legal basis	Consent (§12(a)) — each connection is optional, off by default and asked for at the point of use; Contract (§12(b))
Data subjects	Couples, suppliers who connect an account; guests appearing in the media sent
Personal data categories	OAuth tokens (YouTube `youtube` scope; Drive `drive.file` only — Setnayan can touch only files it created; TikTok `user.info.basic`, `video.upload`, `video.publish`); broadcast details; the photos/videos sent; mood-board pictures sent to Gemini
SPI?	**N**
Recipients / sub-processors	Google LLC (YouTube, Drive, Gemini), TikTok, Meta (Instagram) — each under its own terms; Supabase holds the tokens
Cross-border transfer	US / SG

Retention	Until the user disconnects or deletes the account; keys erased on disconnect; files already written stay in the user's own Drive / channel. Google data deleted within 30 days of a request (`/privacy`)
Security measures	Google API Services User Data Policy incl. Limited Use, stated on `/privacy` and `/privacy/google-access`. (!) The Google and TikTok OAuth tokens are stored **unencrypted at the column level** (encrypted at rest by the database only) — a documented V1 posture with an encryption follow-up pending
Risk level	**Low–Medium**

DPS-28 · Pabuya — Gift Records on the Wish List (added 2026-10-22)

Field	Detail
Purpose	Let a couple show their gift-receiving details (GCash / Maya / bank handle or QR) and let a guest record that they sent a gift, so the couple can thank them
Legal basis	Consent (§12(a)) — the couple publishes their own handle; the guest chooses to record a gift; Contract (§12(b))
Data subjects	Couples; guests who record a gift
Personal data categories	The couple's e-wallet / bank handle and QR (`event_egift_methods`); per gift (`event_gift_records`, since 2026-10-08): the giver's name, amount in pesos, a message, an optional payment screenshot
SPI?	**N** — financial information the people disclose themselves; no credentials
Recipients / sub-processors	Supabase (SG); Cloudflare R2 (screenshot). Gift records visible only to the hosts and admins
Cross-border transfer	SG; APAC
Retention	Follows the parent event (life of the account)
Security measures	Host-only RLS; Setnayan never holds or moves the money
Risk level	**Low–Medium.** (!) **Disclosure gap:** `/privacy` §"Gift-receiving details (Pabuya)" says there is *no transaction ledger*; since 2026-10-08 gift records exist — the page should describe them (open copy item; NPC task `t1-5` already lists the e-gift disclosure)

---

2. Threshold analysis — mandatory NPC registration

Under **RA 10173 and NPC Circular 17-01** (as amended), a PIC/PIP must register its DPS and DPO with the NPC when **any** of the following triggers is met. Assessment below.

#	Registration trigger (Circular 17-01 §4 / related issuances)	Setnayan assessment	Met?
1	Processing **sensitive personal information of** ≥ **1,000 individuals**	Setnayan processes SPI: **biometric face vectors** (DPS-04), the **TIN on suppliers' BIR 2303** (DPS-02), **health/religious** data via dietary fields (DPS-03), religion / civil status / minors' details (dependents), and the marital status every wedding reveals. Last measured 2026-08-17: 48 data subjects, 0 face vectors — **not met today**; likely to be met at scale. (!) Corrected 2026-10-22 — "government ID + liveness" struck (retired 2026-07-03)	**Not yet — likely at scale**
2	PIC/PIP with ≥ **250 employees**	Sole proprietorship; headcount `[TO CONFIRM]` but almost certainly **< 250**	No (assumed)
3	Processing is **likely to pose a risk to the rights and freedoms** of data subjects	Yes — biometric processing, guest likeness/media captured on guests' and suppliers' phones, relationship graph, minors' details entered by parents, **and (DPS-12) involuntary identity-profiling with an automated decision that has a significant effect (auto-suspend/ban of a vendor's livelihood)**. This is high-risk processing by nature	**YES**
4	Processing is **not occasional** (i.e., regular/systematic core-business processing)	Yes — data processing is the platform's core, continuous business function, not incidental	**YES**

Conclusion. Registration triggers **#3 and #4 are met** (#1 not yet by count, likely at scale). Trigger #2 is not (sole prop, sub-250 headcount). Under Circular 17-01 the criteria are **disjunctive** — meeting even one obligates registration, and Setnayan meets at least two independently (risk-to-rights + not-occasional), with the SPI-volume trigger also likely once counts are confirmed.

> **Recommendation: Setnayan should register its DPO and Data Processing Systems with the National Privacy Commission** (NPC registration system), and appoint/confirm Indalecio Sacdalan Casasola II as the registered DPO. Registration is advisable on the risk-to-rights and not-occasional grounds alone; the SPI-volume trigger reinforces it. Confirm exact SPI data-subject counts `[TO CONFIRM]` and current NPC registration number `[TO CONFIRM]` before filing to determine whether this is an initial registration or an amendment.

3. Open items for DPO/counsel before filing

> Re-stated 2026-10-22. Filing is scheduled for **January 2027** (owner, 2026-07-30: *"we will do everything on january 2027 but let this run truthfully until then"*). The 15 tasks are tracked in `npc_filing_tasks` (`/admin/npc-readiness`); their current status lives in production and was not read from this session.

- `[OWNER TO SUPPLY]` Barangay + ZIP; BIR TIN (at filing, from admin → Compliance); DPO title; contact phone; adoption date.
- **Re-measure on filing day** the data-subject and SPI counts (`/admin/compliance/data-sheet`).
- **DPAs / SCCs:** none signed with any processor (task `t2-8`). Priority: Supabase, Vercel, Cloudflare, Resend, Sentry, Anthropic, OpenAI. Decide LanguageTool (no DPA possible on the free endpoint — keep or drop).
- **Public-page copy gaps** found 2026-10-22 (engineering PRs, not corpus): `/privacy` + `/cookies` do not mention the Visits count (DPS-21), sign-in with Google/Apple (DPS-22; the Google section is on an unmerged branch), Apple in-app purchase (DPS-23), the 12-hour face-selfie erase (DPS-04), Pabuya gift records (DPS-28), guest push notifications, breach notification, policy changes, portability or the right to complain to the NPC; `/privacy` still says "30–90 day tail" and `/terms` "30 days" for account deletion (no tail exists).
- **Product gaps:** no guest entry point to take down a supplier-held photo (DPS-24); `auth.identities` not blanked at erasure (DPS-22); no purge for support tickets (2 yrs), our error logs (90 days) or stale device records (24 months) that `/privacy` promises; no admin two-factor; no breach register in the product (task `t3-15`).
- DPS-06 (Person Graph) — minors/legacy (Phase 3) still need their own DPIA + NPC consultation before any build-to-live.
- DPS-13 / DPS-14 / DPS-15 / DPS-16 / DPS-17 / DPS-19 / DPS-24 are each held by an `/admin/data-privacy` control; a 2026-09-22 measurement read all 20 controls **active** — confirm on the board that each active control has the DPO ruling it needs.
- `same_date_demand` (DPS-17) — the per-couple opt-out ruling is still open.
- **Counsel:** external PH counsel review is task `t0-1` (recommended; owner's 2026-09-09 ruling is that it is not a gate to filing).

Draft compliance artifact prepared to a compliant baseline ahead of counsel. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel; this document is not a substitute for legal review and is not yet adopted for NPC filing.

DPO Designation & Accountability Record + NPC Data Processing System Registration Data Sheet

> **ADOPTION-READY · 2026-07-24 · revised 2026-10-22 (v1.1).**

> **Revised 2026-10-22 (v1.1) — still ADOPTION-READY; the DPO re-signs A.5 and B.9.** Measured against `origin/main` (`aceb080a0a`). Changes: published DPO e-mail is **dpo@setnayan.com** (owner ruling 2026-09-22) · `setnayan.ph` struck · B.4 government-ID and AMLC rows struck (retired 2026-07-03) and the SPI basis re-stated · B.5 retired Contract Intelligence struck and the receipt-reading AI added · B.6 points to the 27-row ROPA · B.7 backup and two-factor claims corrected (neither exists) · B.8 sub-processor table rebuilt from the hosts the code calls (PostHog removed; Google, Apple, OpenAI, LanguageTool, Sentry, Meta, TikTok, OpenStreetMap, Vimeo added). See `00_WHAT_CHANGED_2026-10-22.md`.

> This single document holds two related RA 10173 (Data Privacy Act of 2012) filing records for **Setnayan**:
> **Part A** — the Data Protection Officer (DPO) Designation & Accountability record (RA 10173 § 21 accountability + NPC Advisory No. 2017-01 on the designation of DPOs).
> **Part B** — the NPC Data Processing System Registration data sheet: the field-by-field information required to complete registration through the **NPC Registration System (NPCRS)**. Once its ‹OWNER TO SUPPLY› tokens are filled, **Part B IS the consolidated fillable NPCRS data sheet.**

> Grounding source for security measures + data flows: `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` (Policy v1, locked 2026-05-12; Person-Graph amendment 2026-07-05 in DRAFT). Cross-referenced Records of Processing Activities: `NPC_Compliance/02_Records_of_Processing_Activities_DRAFT_2026-07-05.md`.

> **Never-invent rule:** every value not supplied verbatim is either filled from confirmed facts or rendered as a bold **‹OWNER TO SUPPLY: …›** token. Do not guess.

[OK] ADOPTION POSTURE — adopt now, counsel later

> This document is prepared for the DPO to **adopt as v1.0 and file now**, on the DPO's own authority — a sole proprietor may adopt their own RA 10173 records and file NPC registration directly through the NPCRS without a lawyer. To proceed: the owner supplies the **6 fields** in the checklist immediately below, then signs Part A.5 / B.9 and sets the effectivity date.

> **External Philippine counsel review is recommended, not blocking.** Where counsel or the NPC later requires a change, it is applied by a **dated amendment**; any affected live feature can be switched off immediately via the in-app Data Privacy control board (`/admin/data-privacy`). The items most worth a counsel pass when one is engaged: the **PIC = DPO self-designation** (A.3), the **sensitive-PII categorization** (B.4), and the **automated-decision declaration** (B.5).

> **Two things stay firm before filing:** (1) the 6 owner fields below must be **real values, not placeholders** — do not file with blanks; and (2) the (!) STATUS-TO-CONFIRM flags in B.4 / B.5 / B.8 (whether third-party ID verification and AMLC screening are actually active) must be resolved so the declaration is accurate.

Fields the owner must supply before signing / filing

1. [ ] **Principal address — barangay + ZIP.** Complete the principal/registered office address (street already on file: 76 Sampaguita Avenue, Quezon City).
2. [ ] **BIR TIN / Form 2303 number.** Enter this **directly at filing** from admin → Compliance. **Do NOT write the number into this file.**
3. [ ] **Exact DPO position / title string.**

4. [ ] **Contact phone number.** One mobile number suffices, used as PIC contact + DPO contact + breach hotline.

5. [ ] **Sub-processor DPA status.** Which sub-processors have a signed DPA on file. (The code's register says none. The PostHog-region question is retired — PostHog was removed 2026-10-22.)

6. [ ] **Adoption / signature / effectivity date.**

Master fact block (shared by Part A and Part B)

Field	Value
Personal Information Controller (PIC) — legal name	**SETNAYAN SOFTWARE DEVELOPMENT SERVICE** (sole proprietorship of Indalecio Sacdalan Casasola II)
Business / brand name	Setnayan
Business registration	DTI Business Name Registration No. **8297508** · Territorial scope: **National** · Validity: **25 June 2026 – 25 June 2031**
Registration type	DTI Business Name (sole proprietorship). SEC/CDA: not applicable (sole prop).
BIR registration (Form 2303 / TIN)	**‹OWNER TO SUPPLY at filing — held in admin → Compliance; do NOT store the number in this file›**
Proprietor / owner	Indalecio S. Casasola II · owner sign-up email: iscasasolaii@gmail.com
Domains / public surfaces	setnayan.com ((!) CORRECTED 2026-10-22 — `setnayan.ph` struck: not owned)
Registered / principal office address	76 Sampaguita Avenue, Quezon City **‹OWNER TO SUPPLY: barangay + ZIP›**
Data Protection Officer (DPO)	**Indalecio Sacdalan Casasola II** · **dpo@setnayan.com** (published contact, owner ruling 2026-09-22; verified reachable 2026-09-13) · registered on NPC DPO system 2026-07-07 under iscasasolaii@gmail.com — **update that registration to dpo@setnayan.com at filing**
DPO position / title	**‹OWNER TO SUPPLY: exact title string›**
DPO employment basis (employee / contractor / outsourced)	Internal — the proprietor / PIC also serves as DPO (2-person founding team). See A.3 for the independence rationale.
DPO other contact (mobile / landline)	**‹OWNER TO SUPPLY: contact number›**
Total employees / headcount	**2** — Indalecio S. Casasola II (proprietor + DPO) · Claire E. Buanhog (VP, co-founder)

Total number of data subjects	**48 as measured in production 2026-08-17** (9 accounts + 39 guests; 2 shops; 6 events; 0 active biometric face vectors). (!) CORRECTED 2026-08-17 — this field read **~401** from the 2026-07-05 pre-launch snapshot (19 customers + 50 vendors + 332 guests; 61 events). That test data was purged; `07_Compliance_Facts_Register` recorded the ~10× drop on 2026-07-31 and the correction was never propagated to the headline fields. The registration-threshold analysis is UNAFFECTED and strengthened: 48 subjects and 0 biometric vectors sit further below the ≥1,000-SPI trigger than the stale figures did
Number of data subjects with sensitive personal information	Not a fixed count — see B.4. (!) UPDATED 2026-10-22: the counts in this sheet were last measured in production on 2026-08-17 and **could not be re-measured from this session (no production access)**. Read them on filing day from `/admin/compliance/data-sheet`, which computes them live. Suppliers no longer submit a government ID (retired 2026-07-03); the SPI they submit is the TIN on BIR Form 2303.
Sector / industry	Information & communications technology — online life-events / weddings platform (marketplace + SaaS)

PART A — Data Protection Officer (DPO) Designation & Accountability Record

Prepared under RA 10173 § 21 (Principle of Accountability) and NPC Advisory No. 2017-01 (Designation of Data Protection Officers).

A.1 Appointment

SETNAYAN SOFTWARE DEVELOPMENT SERVICE ("the PIC"), a sole proprietorship of **Indalecio Sacdalan Casasola II**, hereby designates:

Field	Value
Designated DPO	**Indalecio Sacdalan Casasola II**
Official DPO email	dpo@setnayan.com (updated 2026-10-22 — was iscasasolaii@gmail.com)
Position / title within the organization	**‹OWNER TO SUPPLY: exact title string›**
Employment basis	Internal — the proprietor / PIC concurrently serves as DPO (2-person founding team). See A.3.
Other contact (mobile / landline)	**‹OWNER TO SUPPLY: contact number›**
Effectivity date of designation	**‹OWNER TO SUPPLY: sign date›**
Reports to	The proprietor, **Indalecio S. Casasola II** (highest management level)

as its **Data Protection Officer**, accountable for the organization's compliance with RA 10173, its Implementing Rules and Regulations, and all applicable NPC issuances.

> **NPC registration of DPO contact details (required).** RA 10173 and NPC issuances require that the DPO's contact details be **registered with the National Privacy Commission** and made available to data subjects and the NPC. The DPO's contact details are carried into Part B (NPC registration data sheet) and are published to data subjects on `/privacy` and every legal page (`dpo@setnayan.com`). The owner has already registered on the **NPC DPO system (2026-07-07)**. This designation is not complete for NPC purposes until the DPO's details are filed through the NPC Registration System.

A.2 Duties and functions of the DPO

Per NPC Advisory No. 2017-01, the DPO shall, at minimum:

1. **Monitor compliance** — oversee the PIC's compliance with RA 10173, its IRR, NPC issuances, and internal data-protection policies, including the assignment and periodic review of the same.
2. **Advise on Data Privacy Impact Assessments (DPIAs)** — ensure the conduct of DPIAs for new or materially changed processing systems and features; advise the PIC on their necessity, application, and outcomes. *(Explicitly flagged as DPO-first in the Policy's Person-Graph and Minors/Legacy forward-notice — those phases each carry their own guardian-consent mechanics and DPIA before activation.)*
3. **Breach response** — ensure the organization's Personal Data Breach Management procedure (assessment, containment, and the **72-hour NPC notification** and affected-data-subject notification obligations already committed in Policy § 8) is in place and followed; serve as the point of contact during breach handling.
4. **Act as the NPC contact point** — serve as the primary liaison between the PIC and the National Privacy Commission on all matters relating to data privacy and security, including responding to NPC information requests and inquiries.
5. **Handle data-subject requests** — receive, coordinate, and ensure timely response to data-subject requests to be informed, to access, to object, to rectify, to erase/block, to data portability, and to be notified of breaches (Policy § 9 and Appendix A; committed response window: **within 15 business days** for non-urgent requests, **immediate** for breach notifications).
6. **Cultivate awareness** — inform and cultivate awareness on privacy and data-protection matters within the organization, including orientation/training of personnel involved in processing.
7. **Advocate for privacy by design and by default** — advise on embedding privacy safeguards into product design (e.g., RLS access control, per-event-scoped face vectors, signed-URL media access, zero-retention AI mode — see Policy §§ 3, 5, 7, 10).
8. **Maintain records** — support the maintenance of the Records of Processing Activities (RoPA) and the organization's registration with the NPC, and keep both current.
9. **Cooperate with the NPC** — coordinate registration, respond to compliance checks, and facilitate any NPC audit or investigation.

A.3 Independence, resources, and safeguards

- **Independence.** The DPO shall perform the role independently and shall not be dismissed or penalized for performing DPO duties. The DPO shall not hold a position that gives rise to a conflict of interest with the DPO role. (!) **PIC = DPO self-designation.** Here the DPO **is** the proprietor (Indalecio Sacdalan Casasola II), the highest management level — which is itself the concurrent role to assess. NPC Advisory No. 2017-01 favours a DPO with autonomy from the controller; for a **2-person sole proprietorship** the owner acting as DPO is commonly accepted as a practical necessity. **Interim rationale to record (PH counsel to confirm):** no independent employee exists to hold the role, so the proprietor is designated DPO in the interim; the PIC will re-evaluate designating an independent DPO or a **Compliance Officer for Privacy (COP)** as headcount grows. The owner

has already registered on the **NPC DPO system (2026-07-07)**.

- **Direct reporting line.** The DPO reports directly to the **highest management level** of the PIC — here, the proprietor, **Indalecio S. Casasola II**.
- **Resources & access.** The PIC shall provide the DPO the resources necessary to carry out the functions above, and timely and unimpeded access to personal data processing activities, systems, and records reasonably required for the role.
- **Involvement.** The DPO shall be involved, in a timely manner, in all issues relating to the protection of personal data.

A.4 Contact details for publication

Channel	Value
DPO email (published to data subjects)	dpo@setnayan.com
In-policy contact point	Policy § 9 — Data subject access / rectification / erasure / restriction / breach inquiries
Breach hotline (severity-high)	**‹OWNER TO SUPPLY: contact number›** (one mobile suffices — same number may serve PIC contact + DPO contact + breach hotline; Policy § 8 references a phone hotline for severity-high incidents)

A.5 Signature block

This designation (v1.1, revised 2026-10-22 — DPO e-mail now dpo@setnayan.com) takes effect on **‹OWNER TO SUPPLY: sign date›** and remains in force until revoked or superseded in writing.

For the Personal Information Controller (PIC):

Signature	_____
Name	**Indalecio Sacdalan Casasola II**
Title	Proprietor, SETNAYAN SOFTWARE DEVELOPMENT SERVICE
Date	_____

Accepted by the Data Protection Officer:

Signature	_____

Name	**Imalecio Sacdalan Casasola II**
Title	Data Protection Officer . **‹OWNER TO SUPPLY: exact title string›**
Date	_____

PART B — NPC Data Processing System Registration Data Sheet

This is the consolidated fillable field-by-field information to be entered into the NPC Registration System (NPCRS). Values are drawn from the master fact block; bold ‹OWNER TO SUPPLY: …› tokens mark the genuine unknowns that must be settled before filing, and clearly-labelled post-filing blanks mark values that only exist after submission. The actual online filing is performed by the DPO / owner through the NPC Registration System — this sheet is the data to file, not the filing itself.

B.0 Eligibility / threshold note — assess before filing

NPC mandatory registration of a data processing system is generally triggered when **any** of the following applies to the PIC:

Trigger (mandatory-registration indicator)	Setnayan status
Processes **sensitive personal information of at least 1,000 individuals**	**NOT met by count at the last measurement (2026-08-17: 48 data subjects, 0 active biometric face vectors).** Suppliers no longer submit a government ID (retired 2026-07-03); the SPI they submit is the TIN on BIR Form 2303; some guest dietary fields may incidentally reveal health/religion; weddings reveal marital status. (!) Re-measure on filing day — counts could not be read from this 2026-10-22 session.
Has **at least 250 employees**	**NO** — headcount is **2**, far below 250.
Processing is **likely to pose a risk to the rights and freedoms of data subjects**	**YES** — biometric face matching, minors' details entered by parents (dependents), an automated vendor-suspension decision, guest likeness captured on other guests' and suppliers' phones, and cross-border transfers together pose more than negligible risk to rights. (Corrected 2026-10-22 — "government-ID verification" struck: retired 2026-07-03.)
Processing is **not occasional** (i.e., regular / part of core operations)	**YES** — processing is continuous and central to the platform.

Assessment: the two numeric thresholds (≥1,000 sensitive-PII data subjects; ≥250 employees) are **NOT currently met**. However, the **risk-to-rights** and **not-occasional** triggers are independently met. **Recommendation: register the PIC and its data processing system(s) with the NPC** on the risk-based and non-occasional grounds. This posture should be re-checked as the sensitive-PII population grows (e.g., once biometric face vectors are activated at scale or verified-vendor volume rises), at which point the ≥1,000 count trigger may also apply.

B.1 Personal Information Controller (PIC) details

NPC field	Value
Registered name of PIC	**SETNAYAN SOFTWARE DEVELOPMENT SERVICE**
Trade / brand name	Setnayan
Type of organization	Sole proprietorship (private)
Business registration	DTI Business Name No. **8297508** (National · valid 25 Jun 2026 – 25 Jun 2031)
SEC / CDA registration	Not applicable (sole proprietorship)
BIR TIN / Form 2303	**‹OWNER TO SUPPLY at filing — held in admin → Compliance; do NOT store the number in this file›**
Proprietor / authorized representative	Indalecio Sacdalan Casasola II
Sector / industry classification	Information & communications technology — online platform / marketplace + SaaS (life-events / weddings)
Nature of operations	A Philippines-first life-events platform (V1 surface: weddings). Couples/organizers plan events end-to-end; vendors run business profiles; the Setnayan team runs operations. Includes RSVP + guest management, vendor marketplace & verification, in-app paid services (photo/video capture, livestream, renders, AI-assisted planning), payments (apply-then-pay), and communications.
Principal / registered office address	76 Sampaguita Avenue, Quezon City **‹OWNER TO SUPPLY: barangay + ZIP›**
Contact number	**‹OWNER TO SUPPLY: contact number›**
Official email	dpo@setnayan.com
Website(s)	setnayan.com

B.2 Data Protection Officer details (as filed with NPC)

NPC field	Value
DPO full name	**Indalecio Sacdalan Casasola II**
DPO position / title	**‹OWNER TO SUPPLY: exact title string›**
DPO email	dpo@setnayan.com

DPO contact number	**‹OWNER TO SUPPLY: contact number›**
DPO office address	76 Sampaguita Avenue, Quezon City **‹OWNER TO SUPPLY: barangay + ZIP›** (same as PIC principal office)
Registered on NPC DPO system	2026-07-07

B.3 Scale of processing

NPC field	Value
Total number of employees	**2** (Indalecio S. Casasola II — proprietor + DPO; Claire E. Buanhog — VP, co-founder)
Total number of data subjects	**48 as measured in production 2026-08-17** (9 accounts + 39 guests; 2 shops; 6 events; 0 active biometric face vectors). (!) CORRECTED 2026-08-17 — this field read **~401** from the 2026-07-05 pre-launch snapshot (19 customers + 50 vendors + 332 guests; 61 events). That test data was purged; `07_Compliance_Facts_Register` recorded the ~10× drop on 2026-07-31 and the correction was never propagated to the headline fields. The registration-threshold analysis is UNAFFECTED and strengthened: 48 subjects and 0 biometric vectors sit further below the ≥1,000-SPI trigger than the stale figures did
Number of data subjects whose **sensitive personal information** is processed	**No fixed count today — 0 active biometric face vectors**; a subset of the 50 vendors submit government IDs at verification; some guest dietary fields may reveal health/religion (see B.4).
Categories of data subjects	Customers (couples / organizers) · Guests · Vendors (business representatives) · (internal: Setnayan team / admins)

B.4 Does the system process sensitive personal information? — YES (capability present; low volume today)

Enumerated categories of sensitive personal information / regulated data processed (grounded in Policy §§ 1, 3, 10):

Category	Detail	Data subject	Source in policy
Government-issued identifiers	The **Tax Identification Number** printed on the supplier's BIR Form 2303 (and the TIN a customer may give for an official receipt). (!) **CORRECTED 2026-10-22 — the government-ID image + liveness verification row is struck: retired 2026-07-03, never sent to any provider.** Legacy ID uploads from before that date are deleted 90 days after the review decision by the sweep shipped in PR #4735.	Vendors (and customers requesting a receipt)	BIR 2303 slot in `apps/web/lib/vendor-verification.t` `receipts.issued_to_tin`

Biometric data — face vectors	128-dimension face vectors computed **in the guest's browser** from a selfie the guest takes after ticking a separate, default-off consent box (adults 18+ only; a guest the host marks as a minor is refused), used to find that guest's photos **within one event**. **0 active vectors at the 2026-08-17 measurement**; not re-measured 2026-10-22.	Guests (and couples where they appear)	Policy § 1.4
Financial reference data	Payment receipts, transaction references, partial bank/e-wallet details for receipts and refunds; vendor payout account details. (Full card numbers, CVVs, and full bank account numbers are NOT stored.)	Customers, Vendors	Policy § 1.1, § 1.2
~~**Sanctions / PEP screening data**~~	[X] **STRUCK 2026-10-22 — no AMLC / ComplyAdvantage screening is performed** (retired 2026-07-03).	—	—
Religion · marital status · minors' data	Optional profile religion / civil status (consent-stamped); a wedding's ceremony type (reveals religion) and the couple's marital status; **dependents** (a child's name, birth date, sex, religion) entered by the parent for christenings and milestones. Never shown on a public page.	Customers; their children	`/privacy` §"Minors, dependents, and religious information"
Health / dietary information *(possible)*	Guest and account `dietary_restrictions` + `meal_preference` (confirmed in the live schema) may reveal health/religious information; `/privacy` labels it sensitive.	Guests, customers	`guests.dietary_restrictions`, `users.dietary_restrictions`

> Note: some of the above (e.g., government IDs, financial account data) are "sensitive" and/or specially-regulated categories under RA 10173 / related law. Their inclusion here is for completeness of the NPC declaration; the DPO/counsel should confirm final categorization. **On count:** the ≥1,000 sensitive-PII threshold in B.0 is NOT currently met — see B.0 and B.3.

B.5 Automated processing / AI decision-making

NPC field	Value
Does the system involve automated processing?	**YES** — automated processing is used.
AI / automated features present	(a) Automated **face-matching auto-tag** of event photos (per-event-scoped; confidence-gated). (b) ~~AI contract analysis~~ — **retired 2026-05-18** (corrected 2026-10-22). (c) **AI reading of a payment-receipt screenshot** (Anthropic) to check the reference the customer typed — it can never approve, reject or settle a payment; an admin decides. (d) AI content moderation of couples' and guests' published text (OpenAI). (e) Supplier Deep Search and mood-board screening (Anthropic). (f) Fuzzy payment-inbox → order matching (rule-based). (g) **Anti-Fraud identity clustering + vendor fraud scoring + auto-suspend** (DPS-12 / DPIA R-08 — live 2026-07-07).
Solely-automated decisions producing legal or similarly significant effects on data subjects?	**YES — one, as of 2026-07-07.** The Anti-Fraud engine (DPS-12 / R-08) can **automatically suspend** a vendor's public listing at a high fraud score — a **reversible** decision with a significant effect. The **irreversible** wipe/ban is **not** automated (routed through a two-admin/four-eyes gate). All other automated features remain assistive/human-reviewed (vendor verification + payment reconciliation are admin-reviewed; face auto-tag surfaces suggestions below high-confidence thresholds). [OK] Resolved 2026-10-22: third-party identity verification is **retired**, not a stub — nothing to declare. Reversal of an auto-suspend returns the shop to *hidden*, and an admin re-publishes it (owner lock 2026-07-27). **Follow-up (RA 10173 §16(c)/§34):** document a formal contest/appeal path for the automated suspension — see `08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md` §6.

B.6 Data processing systems / activities (RoPA reference)

The full Records of Processing Activities are maintained in `NPC_Compliance/02_Records_of_Processing_Activities_DRAFT_2026-07-05.md` — **28 data processing systems, DPS-01 → DPS-28, revised 2026-10-22** against the shipped code. (Updated 2026-10-22 — this section said the RoPA was "to be created/finalized" and listed 7 indicative systems.)

Group	DPS rows
Accounts, events, guests, sign-in	DPS-01 · DPS-03 · DPS-06 · DPS-22
Suppliers and verification	DPS-02 · DPS-13 · DPS-17 · DPS-24
Photos, video, face matching, live video	DPS-04 · DPS-05 · DPS-15 · DPS-16 · DPS-18 · DPS-24 · DPS-27
Payments, gifts, purchases	DPS-08 · DPS-20 · DPS-23 · DPS-28
Communications	DPS-07 · DPS-10
Coordinators	DPS-14 · DPS-19
Site, cookies, reporting, monitoring	DPS-09 · DPS-11 · DPS-21 · DPS-25 · DPS-26

Anti-fraud	DPS-12

B.7 Security measures (summary — full detail in Policy §§ 5, 7, 10)

Area	Measure
Encryption at rest	AES-256 on Supabase Postgres + Cloudflare R2; keys via provider KMS
Encryption in transit	TLS 1.3 on all external connections; HSTS; mixed-content blocked
Access control	Supabase Row-Level Security (per-user isolation, enabled at table creation); short-lived signed URLs for private media; granular admin roles; two-admin approval for the irreversible fraud ban. (!) CORRECTED 2026-10-22: **no two-factor authentication is built** (no MFA code on `origin/main`) — "TOTP 2FA (mandatory for admins)" struck; an open security item
Face-vector safeguards	Computed in the guest's browser; explicit default-off opt-in; adults 18+ only; per-event scoped, never reused across events; selfie and vector erased 12 hours after the event (3-month backstop); withdrawal at any time
Application security	Input validation, parameterized queries, XSS/CSRF protections, rate limiting on auth
Audit	Append-only admin audit log (timestamp, actor, action, before/after, rationale)
Breach response	72-hour NPC + affected-user notification per the adopted Data Breach Management Policy. (!) No breach register exists in the product yet (task `t3-15`); the live `/privacy` page does not yet state the breach-notification promise
Backups	**None.** (!) CORRECTED 2026-10-22 — this row previously declared "Daily encrypted DB backups, 30-day retention", which was never true: the database is on the Supabase free plan with no scheduled snapshots, an absence the owner accepted on 2026-08-10 (*"let's stay free for the moment"*), to be revisited before launch

B.8 Cross-border data transfers

YES — the system involves cross-border transfers. The database is in Singapore, media in Cloudflare R2 Asia-Pacific, and several processors are in the US or EU. All transfers are encrypted in transit (TLS 1.3). (!) **CORRECTED 2026-10-22: no DPA or SCC is signed with any processor yet** (the code's register, `apps/web/lib/subprocessors.ts`, reads `dpa_on_file: false` for every row; task `t2-8`).

> **Rebuilt 2026-10-22 from the hosts the shipped code calls.** "Runs when" matters: several only run once a key or a switch is set, and production values were not readable from this session. Full detail: Privacy Manual § 8.2.

Recipient / sub-processor	Jurisdiction	Data shared	Purpose	Lawful basis	DPA on file?

Supabase	Singapore	All structured personal data, incl. the biometric face vectors	Database, sign-in, realtime	Contract	**No** ‹OWNER TO CONFIRM›
Vercel	US company; functions in Singapore (`sin1`)	Every request in transit	Hosting	Contract	**No**
Cloudflare (R2, TURN relay, Turnstile, STUN)	APAC (R2); global network	Media, selfies, payment proofs, supplier documents; call media + IP in transit; visitor IP for bot checks	Storage; relay; bot check	Contract / legitimate interest	**No**
Resend	United States	Recipient e-mail + message	Transactional e-mail (no guest e-mail since 2026-09-29)	Contract	**No**
Sentry	United States	Error traces; masked replay on error	Error monitoring	Legitimate interest	**No**
Anthropic	United States	Payment-proof screenshots; supplier public business info; supplier gallery photos; a couple's theme sentence	AI assistance (never decides a payment)	Contract / legitimate interest	**No**
OpenAI	United States	Couple editorial + guest-column text	Moderation	Legitimate interest	**No**
LanguageTool (LanguageTooler GmbH)	Germany (EU)	Same editorial text, free public API	Grammar check	Legitimate interest	**No — none possible on the free endpoint** (owner decision open)
Google	United States	Sign-in name/e-mail; YouTube tokens + broadcast; Drive photos (`drive.file`); Gemini mood-board pictures	Sign-in; Live Watch; photo delivery; renders	Consent / contract	**No** (Google API terms)

Apple	United States	Sign-in ID token (refresh token kept for revocation); App Store purchases (feature off); song search term	Sign-in; iOS purchases; previews	Contract	**No** (Apple terms)
Meta (Facebook / Instagram)	United States	Our own posts; a supplier's Instagram posts after it connects	Social publishing / sync	Consent	**No**
TikTok	Singapore / US	Tokens + the video the user posts	Patiktok	Consent	**No**
OpenStreetMap	UK (not verified)	Address typed; viewer IP for tiles	Maps	Legitimate interest	n/a (public service)
Vimeo	United States	A supplier's Vimeo link	Poster image	Legitimate interest	n/a
Browser push services	Browser vendor	Notification content	Web push	Consent (the user allows notifications)	n/a
~~PostHog~~	—	—	[X] **Removed 2026-10-22 (PR #6774)**	—	—
~~Persona / Veriff / Onfido~~ · ~~AMLC / ComplyAdvantage~~	—	—	[X] **Retired 2026-07-03 — never engaged**	—	—
~~Anthropic contract analysis~~ · ~~OpenAI GPT-4 fallback~~	—	—	[X] **Contract Intelligence retired 2026-05-18**	—	—
Suno	—	No personal data; **not called by the code**	—	n/a	n/a
DTI Database	PH	—	**Not a data feed** — the code makes no call to DTI; any check is a manual look-up	n/a	n/a

B.9 Filing action & sign-off

- **This document is the DATA to be filed, not the filing itself.** The actual NPC registration of the data processing system(s), and the registration of the DPO's contact details, are **online filing actions performed by the DPO (Indalecio Sacdalan Casasola II) and/or the owner (Indalecio S. Casasola II)** through the **NPC Registration System (NPCRS)**.

- Before filing, resolve **all ‹OWNER TO SUPPLY› tokens** with real values, confirm the RoPA (§ B.6) exists and is current, and have the DPO validate the sensitive-PII categorization (§ B.4) and the automated-decision answer (§ B.5). A counsel pass on these is **recommended** when one is engaged, but is **not a precondition** to filing.

Prepared / reviewed	Name	Date
Version signed	**v1.1 — revised 2026-10-22**	
Reviewed by DPO	Indalecio Sacdalan Casasola II	___
Approved by PIC	Indalecio S. Casasola II	___
Filed with NPC (NPCRS) — reference no.	`[POST-FILING — NPCRS reference no. assigned on submission]`	___
NPC registration number issued	`[POST-FILING — NPC registration number issued after acceptance]`	___

Footer — This ADOPTION-READY document establishes a compliant baseline. It is not a substitute for legal review; external Philippine counsel review — including blessing the PIC=DPO self-designation — is recommended but not a precondition to adoption or filing (per the adoption posture above), and any change it requires is applied by a dated amendment. The actual NPC online registration of the data processing system(s) and the registration of the DPO's contact details are the DPO's / owner's filing actions. · 2026-07-24 · revised 2026-10-22 (v1.1).

Setnayan — Data Breach / Security Incident Management Policy

> **ADOPTION-READY · 2026-07-24.**

> [OK] **ADOPTION POSTURE — adopt now, counsel later.** This policy is prepared for the DPO to **adopt as v1.0 now**, on the DPO's own authority. To adopt: the owner supplies the fields in the checklist below, signs the § 11 approval block, and sets the effectivity date. **External PH counsel review is recommended, not blocking** — it is not required to adopt this policy; where counsel or the NPC later requires a change, it is applied by a **dated amendment**. Note: the 72-hour NPC + affected-data-subject breach-notification duty applies from adoption regardless of counsel status.

> This policy is issued under the Data Privacy Act of 2012 (Republic Act No. 10173, "**RA 10173**"), its Implementing Rules and Regulations (IRR), and **NPC Circular No. 16-03 (Personal Data Breach Management)**. It sets out how SETNAYAN SOFTWARE DEVELOPMENT SERVICE prevents, detects, assesses, contains, and reports personal data breaches and security incidents.

Field	Detail
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name No. 8297508. Brand: **Setnayan**.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · **dpo@setnayan.com** (updated 2026-10-22 — published contact per owner ruling 2026-09-22)
Document owner	Data Protection Officer
Version / date	ADOPTION-READY · 2026-07-24 · **Revised 2026-10-22 (v1.1) — the DPO re-signs § 11**
What changed in v1.1	Processor list (§ 1.2) rebuilt from the code — PostHog removed, identity-verification providers struck, Sentry/Anthropic/OpenAI/LanguageTool/Google/Apple added · monitoring (§ 3.2, § 4.1) limited to what exists (Sentry, Vercel/Supabase logs) — PostHog and Better Stack are not in the code · § 6.2 guest notification channel flagged (guests get no e-mail since 2026-09-29) · § 8.1 states that no breach register exists in the product yet · DPO contact → dpo@setnayan.com. See `00_WHAT_CHANGED_2026-10-22.md`.
Review cadence	At least annually, and after any notifiable breach
Legal basis	RA 10173 §§ 20, 26–31; IRR Rule VIII (Security Measures); Rule IX (Security Incidents & Breaches); **NPC Circular 16-03**

(!) Fields the owner must supply before signing

This policy is complete except for the following facts, which only the owner can provide. Each appears inline in the text as a bold **‹OWNER TO SUPPLY: …›** token. Supply all of them, then the DPO may sign.

1. **Breach-response hotline / 24-7 escalation contact** — a **single mobile number suffices to start** (the § 2.1 "DBRT contacts" line and the § 6.2 high-severity hotline both reference it): **‹OWNER TO SUPPLY: one mobile number›**
2. **Adoption / effectivity date** — the date this policy takes effect once the owner fields are supplied and the DPO signs (header + § 11 approval block): **‹OWNER TO SUPPLY: adoption date›**
3. **Technical / Engineering Lead** — name/holder for the § 2.1 DBRT role (was `[TO CONFIRM]` in the draft; no confirmed value provided): **‹OWNER TO SUPPLY: Technical/Engineering Lead holder›**
4. **Security / Operations Coordinator** — name/holder for the § 2.1 DBRT role (was `[TO CONFIRM]` in the draft; no confirmed value provided): **‹OWNER TO SUPPLY: Security/Operations Coordinator holder›**
5. **Communications / Legal liaison** — external PH counsel liaison, added when engaged (was `[TO CONFIRM]` in the draft; not yet engaged): **‹OWNER TO SUPPLY: external PH counsel liaison, once engaged›**

> Note: pending items 3–5 do not prevent the DBRT from operating — under § 2, in a 2-person founding team these responsibilities currently rest with the DPO and the supporting co-founder until the roles are formally filled or counsel is engaged.

---

1. Purpose & Scope

1.1 Purpose

This policy establishes Setnayan's mandatory procedure for managing **security incidents** and **personal data breaches** so that the PIC can:

- prevent breaches through documented organizational, physical, and technical measures;
- detect and assess incidents promptly and consistently;
- **notify the National Privacy Commission (NPC) and affected data subjects within 72 hours** where the breach is notifiable;
- contain, eradicate, and recover from incidents while preserving evidence; and
- maintain records and continuously improve through post-incident review.

1.2 Scope

This policy applies to **all** personal data processed by Setnayan across every processing system, whether stored, transmitted, or handled by:

- Setnayan personnel (the sole proprietor, the DPO, any engaged contractors / team members);
- Setnayan's processing systems — the Next.js web application, admin console, and databases; and
- Setnayan's **sub-processors / personal information processors** — Supabase, Vercel, Cloudflare (R2, relay, bot check), Resend, Sentry, Anthropic, OpenAI, LanguageTool, Google, Apple, Meta, TikTok and the others in Privacy Manual § 8.2 (rebuilt 2026-10-22). (!) Corrected 2026-10-22: Persona / Veriff / Onfido struck — retired 2026-07-03, never engaged; PostHog struck — removed 2026-10-22.

It covers customer (couple/organizer), vendor, and guest personal data, including **sensitive personal information** and the special category of **face vectors** described in the Privacy & Security Policy § 1.

1.3 Definitions

Term	Meaning (per NPC Circular 16-03 & RA 10173 IRR)

Security incident	An event or occurrence that **affects or tends to affect** data protection, or may compromise the availability, integrity, or confidentiality of personal data. Includes incidents that would result in a personal data breach if not for safeguards that were in place. **All** security incidents are logged; not all are breaches.
Personal data breach	A breach of security leading to the **accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to** personal data transmitted, stored, or otherwise processed.
Availability breach	Loss, accidental or unlawful destruction, or **loss of access** to personal data (e.g. R2/Supabase outage causing data loss; ransomware locking records).
Integrity breach	**Unauthorized or accidental alteration** of personal data (e.g. tampered records, corrupted face-vector store, malicious edits via a compromised admin account).
Confidentiality breach	**Unauthorized or accidental disclosure of, or access to,** personal data (e.g. leaked credentials, an RLS bypass exposing another user's rows, a mis-issued signed URL).
Sensitive personal information (SPI)	As defined in RA 10173 § 3(l) — includes government-issued IDs, and, for Setnayan, **face vectors / biometric data** and vendor government-ID images.
Notifiable breach	A personal data breach meeting **all** the criteria in § 5.2 (SPI or identity-fraud-enabling data, AND real risk of serious harm).
DBRT	Data Breach Response Team (§ 2).
NPC	National Privacy Commission.

---

2. Data Breach Response Team (DBRT)

Per NPC Circular 16-03 § 5, the PIC constitutes a Data Breach Response Team responsible for the entire incident lifecycle. Setnayan is a sole proprietorship operated by a **2-person founding team**. The breach-response structure is: the **DPO — Indalecio Sacdalan Casasola II (proprietor) — leads**, and **Claire E. Buanhog (VP, co-founder) supports**. There are **no external DBRT members yet**; an **external PH counsel liaison is added when engaged**. Roles may be held by the same individual or by engaged contractors, but each **responsibility** below is assigned and accountable.

2.1 Composition & roles

Role	Held by	Core responsibilities
DBRT Lead / Data Protection Officer	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com	Overall accountability; convenes the DBRT; makes the notifiability determination (§ 5); signs and files NPC and data-subject notifications; primary NPC liaison.

PIC / Business Owner	Indalecio Sacdalan Casasola II (SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	Ultimate PIC accountability under RA 10173; approves external communications and remediation spend; authorizes sub-processor escalation.
DBRT Support / Co-founder	Claire E. Buanhog · VP, co-founder	Supports the DPO across the incident lifecycle; secondary point of contact; assists with triage, breach-register upkeep, and data-subject communications.
Technical / Engineering Lead	**‹OWNER TO SUPPLY: Technical/Engineering Lead holder›**	Detection, containment, eradication, recovery; evidence preservation; forensic timeline; coordination with Vercel/Supabase/Cloudflare support.
Security / Operations Coordinator	**‹OWNER TO SUPPLY: Security/Operations Coordinator holder›**	Monitors Sentry alerts and Vercel / Supabase logs (corrected 2026-10-22 — PostHog removed; Better Stack is not in the code — confirm whether any external uptime monitor is in use); triages user-reported incidents; maintains the breach register; runs the annual drill.
Communications / Legal liaison	**‹OWNER TO SUPPLY: external PH counsel liaison, once engaged›**	Drafts data-subject notifications and the public `setnayan.com/security` disclosure; legal review of NPC filings; media handling if applicable.

DBRT contacts (24/7 escalation): high-severity hotline — **‹OWNER TO SUPPLY: one mobile number›** (a single mobile number suffices to start); escalation email — iscasasolaii@gmail.com.

2.2 Activation & operation

- **Any** Setnayan person or sub-processor notification that suggests a possible breach must be reported to the DPO **and** the Security/Operations Coordinator **immediately** (target: within 1 hour of discovery).
- The DPO convenes the DBRT upon any credible report. The "72-hour clock" begins on **knowledge** of a personal data breach (see § 5.1), not on convening the team — so the DBRT is convened without delay.
- The DBRT operates against the quick-flow in § 10 and documents every step in the breach register (§ 8).

---

3. Prevention & Preparedness

Setnayan reduces breach likelihood and impact through the organizational, physical, and technical measures below — the operative controls are set out in the **Privacy & Security Policy §§ 5 and 7** and summarized here.

3.1 Technical measures (in place)

Control	Implementation
Deny-by-default access (RLS)	All Postgres queries gate through Supabase **Row-Level Security**; no client can read another user's row (Privacy Policy § 5.3). Canonical deny-by-default RLS patterns; RLS enabled at table-creation time.

Encryption in transit	**TLS 1.3** on all external connections and WebSocket channels; HSTS enabled; mixed-content blocked (§ 7.2).
Encryption at rest	**AES-256** on Supabase Postgres and Cloudflare R2; keys managed by Supabase/Cloudflare KMS. Face vectors stored in a per-event **encrypted** vector index (§ 7.1, § 1.4).
Least-privilege access	Production DB access restricted to designated roles; granular admin roles; **two-admin approval** for high-risk actions (role provisioning, refunds/grants > PHP 10K); signed URLs for media are short-lived (5 min for sensitive media) (§ 5.3).
Strong authentication	bcrypt-hashed passwords; OTP/SSO options; **TOTP 2FA mandatory for all admin roles** (§ 5.1).
Append-only audit log	Every admin action logged with timestamp, actor, action, target, before/after state, rationale; **no UPDATE permission**; export restricted (§ 5.4).
Application hardening	Input validation (zod), parameterized queries, React escaping + CSP, CSRF tokens, rate limiting on auth endpoints (§ 7.3).
Encrypted backups	**NONE — no automated database backups exist.** (!) CORRECTED 2026-08-17: this row declared "Daily encrypted Postgres backups retained 30 days (§ 7.1)" and the recovery step below relied on it. The database is on the FREE plan (no scheduled snapshots) and there is no backup job of our own. Owner ruling 2026-08-10 accepts this knowingly, to revisit before launch. **A recovery plan that points at backups we do not hold is worse than no plan** — see the corrected recovery step.

3.2 Monitoring & observability (in place)

- **Sentry** — application error and exception monitoring; anomalous error spikes surface potential incidents.
- **Better Stack** — uptime, heartbeat, and on-call alerting; drives availability-breach detection and the status page.
- ~~**PostHog**~~ — (!) CORRECTED 2026-10-22: **removed** (PR #6774); there is no product-analytics stream. Admin site **Visits** (daily aggregates, ROPA DPS-21) and the admin App Performance page can show unusual traffic.
- Vercel platform logs; Supabase logs and advisors; Cloudflare R2 access is signed-URL-only (no public reads).

3.3 Organizational measures

- This policy plus the Privacy & Security Policy are the standing breach-management framework.
- **Staff awareness:** every person with data access reads this policy on onboarding and at each annual review; the DBRT runs at least one **table-top breach drill per year**.
- **Sub-processor controls:** all sub-processors are bound by DPAs / SCCs; the Anthropic Console workspace runs zero-retention mode where configured. (!) CORRECTED 2026-10-22: **no DPA/SCC is signed with any processor yet** (task `t2-8`), and the Persona/Veriff/Onfido + AMLC line is struck (retired 2026-07-03).
- **Regular review:** this policy, access lists, and the sub-processor register are reviewed at least annually and after any notifiable breach (§ 9).

---

4. Detection & Assessment

4.1 How incidents are detected

1. **Automated monitoring / alerts** — Sentry error spikes, Supabase advisors, auth rate-limit triggers, the admin App Performance / Visits pages. (Corrected 2026-10-22 — PostHog removed; Better Stack not found in code.)
2. **User / data-subject reports** — a customer, vendor, or guest reports suspicious activity or exposure via iscasasolaii@gmail.com or in-app support (0029 Help Center ticket).
3. **Sub-processor notifications** — Vercel, Supabase, Cloudflare, Resend, Sentry, Anthropic, OpenAI, Google or Apple notifies Setnayan of a security event affecting Setnayan data. Setnayan's knowledge for the 72-hour clock arises when it receives such notice with sufficient detail (see § 5.1).
4. **Internal discovery** — a team member or contractor identifies a misconfiguration, leaked credential, RLS gap, or anomalous audit-log entry.

4.2 Initial triage (within 24 hours of discovery)

The Security/Operations Coordinator (or DPO) opens a breach-register entry and records:

- what happened, when discovered, how discovered, systems involved;
- whether **personal data** is involved (if not → security incident only, log and monitor);
- **categories of data** involved (ordinary PII, SPI, face vectors, credentials, financial receipts);
- estimated **number and categories of affected data subjects**; and
- whether the incident is ongoing or contained.

4.3 Severity & notifiability assessment

The DPO assesses severity and applies the notifiability test in § 5.2. If any input is unknown, the DBRT treats the breach as **potentially notifiable** and proceeds toward the 72-hour deadline while facts are confirmed, rather than delaying the clock.

---

5. The 72-Hour Rule

5.1 When the clock starts

The **72-hour** period runs from the time Setnayan has **knowledge of, or a reasonable belief that,** a **notifiable personal data breach** has occurred. Knowledge is presumed once the DPO or DBRT has sufficient information to conclude the § 5.2 criteria are (or are likely) met — including on receipt of a sub-processor's breach notice with adequate detail. Setnayan does **not** wait for full forensic certainty before notifying; it notifies within 72 hours and supplements the report as facts develop.

5.2 Notification criteria (all must be present)

Per RA 10173 § 20(f) and NPC Circular 16-03 § 11, notification of the NPC and affected data subjects is **mandatory** when **all three** of the following are met:

1. **There is a personal data breach** (confidentiality, integrity, or availability); **AND**
2. The personal data involved is either **(a) sensitive personal information** — for Setnayan this includes government-issued IDs, **face vectors / biometric data**, and vendor gov-ID images — **OR (b) any other information that may be used to enable identity fraud** (e.g. full name + email + credentials, payment-reference data, partial financial details); **AND**

3. There is a **real risk of serious harm** to the affected data subjects (e.g. identity theft, financial loss, fraud, reputational harm, discrimination, or unauthorized use of biometric identity).

If **any** criterion is absent, the breach is logged in the register (§ 8) and monitored, but NPC/data-subject notification is not mandatory — though Setnayan may still notify voluntarily where prudent. The DPO documents the reasoning either way.

5.3 What must happen within 72 hours

- **Notify the NPC** (§ 6.1) — file the breach notification with the NPC.
- **Notify affected data subjects** (§ 6.2) — in-app + email, per the required content.

Where notification within 72 hours is not feasible, Setnayan may, in **exceptional cases**, request that the NPC allow a delay or a phased notification, giving reasons; and it may postpone data-subject notification **only** to the extent, and for the period, the NPC directs or law-enforcement necessity requires. Any such deviation is documented and approved by the DPO with counsel.

---

6. Notification Content & Channels

6.1 NPC notification

Channel: filed with the National Privacy Commission via the NPC's prescribed breach-notification means (email / NPC portal as then in force), signed by the DPO.

Contents (NPC Circular 16-03 § 12):

1. **Nature of the breach** — a description of how and when it occurred and the type of breach (availability/integrity/confidentiality).
2. **Personal data possibly involved** — the categories and approximate number of data subjects and records affected (including whether SPI / face vectors).
3. **Measures taken** — actions taken or proposed to address the breach, to secure or recover the data, and to mitigate possible harm; and measures to prevent recurrence.
4. **Name and contact details of the DPO** or other accountable person from whom the NPC can obtain further information.

A **preliminary** notification may be filed within 72 hours with available facts, followed by supplemental submissions as the investigation completes.

6.2 Data-subject notification

Channels: primary — **in-app notice + email (via Resend)** to each affected data subject; a summary disclosure may also be posted on the site where appropriate (a public summary within **7 days** where appropriate). (!) **Updated 2026-10-22:** (1) no `setnayan.com/security` page exists yet — publish the summary on `/privacy` or a new page at the time; (2) **guests receive no e-mail since 2026-09-29** (owner: *"No email. Either use the qr and link only"*) and the RSVP no longer collects one, so for many guests the reachable channels are the in-app notice on their invitation page and the couple. **DPO decision needed:** confirm that a breach notice is an exception to the no-guest-e-mail rule where an e-mail is on file. Where individual notice is not reasonably possible, the DPO will use a substitute means (e.g. prominent public notice) as the NPC allows.

Contents (must be written in clear, plain language):

1. A description of the **nature of the breach** and the **personal data** possibly involved.
2. **Measures taken** by Setnayan to address the breach.

3. **Measures the data subject may take** to reduce risk (e.g. change password, monitor bank/e-wallet activity, revoke face data via the "Delete my face data" link).

4. **DPO contact** — iscasasolaii@gmail.com (and severity-high hotline **‹OWNER TO SUPPLY: one mobile number›**) for questions and assistance.

---

7. Containment, Eradication & Recovery; Evidence Preservation

7.1 Containment (immediate)

- Isolate affected systems / revoke compromised credentials, tokens, and signed URLs; rotate keys and secrets.
- Disable or lock affected accounts; force re-authentication where credentials may be exposed.
- Engage sub-processor support (Vercel / Supabase / Cloudflare / Resend) to halt ongoing exposure.
- Where an RLS/authorization gap is implicated, deploy an emergency policy fix or take the affected surface offline.

7.2 Eradication

- Remove the root cause — patch the vulnerability, correct the misconfiguration, revoke unauthorized access, remove malicious artifacts.
- Verify no persistence (backdoors, residual tokens, altered RLS policies, injected data).

7.3 Recovery

- (!) **THERE ARE NO BACKUPS TO RESTORE FROM (corrected 2026-08-17).** Recovery from a data-loss event is therefore limited to: the couple's own Google Drive copies of their originals (the only customer-held copy), media objects still present in object storage (a separate system, unaffected by a database loss), and manual reconstruction from application logs. **Restoring the database is NOT currently possible.** Re-establishing a backup capability is an owner decision recorded 2026-08-10 and deferred; until it lands, treat database loss as unrecoverable and prioritise prevention. Validate integrity against the audit log before returning to production.
- Monitor closely post-recovery (heightened Sentry/Better Stack watch) for recurrence.

7.4 Evidence preservation

- **Preserve, do not destroy.** Capture and retain logs, timestamps, audit-log excerpts (append-only), Sentry events, access records, sub-processor notices, and system snapshots relevant to the incident **before** remediation alters state where feasible.
- Maintain a chain-of-custody note in the register entry. Evidence supports NPC filings, potential law-enforcement referral, and post-incident review.

---

8. Documentation & Record-Keeping

8.1 Breach register (mandatory)

Setnayan maintains a **breach register** recording **all** security incidents and personal data breaches — notifiable or not — per NPC Circular 16-03 § 14. The register is maintained by the Security/Operations Coordinator under DPO oversight and stored access-restricted. Template in § 10. (!) **Status 2026-10-22: no breach register exists in the product yet** — the only home today is the free-text breach-team / contacts fields on `/admin/compliance`. Starting

the register is NPC task `t3-15` (seeded not started). Until then, keep the § 10.2 template as a dated file.

8.2 Annual report to the NPC

Setnayan submits an **annual report of the summary of security incidents and personal data breaches** to the NPC in the form and period the NPC prescribes. The DPO compiles this from the breach register.

8.3 Retention

Breach-register entries and supporting evidence are retained consistent with the Privacy & Security Policy § 4 audit-log retention (**5 years**) and any longer period required for pending NPC or legal proceedings.

---

9. Post-Incident Review

After every notifiable breach (and periodically for aggregated non-notifiable incidents), the DBRT conducts a documented review covering:

- **Root-cause analysis** — the technical and organizational cause, and why existing controls did not prevent it.
- **Remediation** — permanent fixes, additional controls, and verification that they work.
- **Policy & control update** — amend this policy, the Privacy & Security Policy, RLS patterns, monitoring rules, access lists, or sub-processor terms as needed.
- **Awareness** — brief the team; update onboarding materials; schedule/refresh the annual drill.
- The DPO signs off the review; changes to this policy follow the review cadence in the header.

---

10. Incident Response Quick-Flow & Breach Register Template

10.1 Quick-flow (one page)

```
+-------------------------------------------------------------------------+
|  SETNAYAN INCIDENT RESPONSE — QUICK-FLOW                                |
|  (72-hour clock starts on KNOWLEDGE of a notifiable breach)             |
+-------------------------------------------------------------------------+
|                                                                         |
|  1. DETECT                                                              |
|     Sentry / Better Stack alert · user report (iscasasolaii@gmail.com) ·        |
|     sub-processor notice · internal discovery                           |
|         |  report to DPO + Ops Coordinator ≤ 1 hour                     |
|         v                                                               |
|  2. CONTAIN                                                             |
|     Isolate systems · revoke credentials/tokens/signed URLs · rotate keys ·|
|     lock affected accounts · engage sub-processor support               |
|     >> PRESERVE EVIDENCE (logs, audit trail, snapshots)                 |
|         v                                                               |
|  3. ASSESS  (DPO)                                                       |
|     Personal data involved?  --No--> log as security incident, monitor  |
|         | Yes                                                           |
|         v                                                               |
|     NOTIFIABILITY TEST — ALL three?                                     |
|       (1) personal data breach  AND                                     |
```

```
|       (2) SPI / face vectors OR identity-fraud-enabling data  AND          |
|       (3) real risk of serious harm                                        |
|         | No --> record in register + reasoning, monitor                    |
|         | Yes / Uncertain                                                   |
|         v                                                                  |
|  4. NOTIFY  ≤ 72 HOURS from knowledge                                      |
|     • NPC  — nature · data involved · measures taken · DPO contact         |
|     • Affected data subjects — in-app + email (Resend); what happened,     |
|       what we did, what they should do, DPO contact                        |
|     • (as appropriate) public notice at setnayan.com/security              |
|         v                                                                  |
|  5. REMEDIATE                                                              |
|     Eradicate root cause · recover (NO DB BACKUPS — see § 7.1) · verify            |
|     integrity vs audit log · heightened monitoring                         |
|         v                                                                  |
|  6. REVIEW                                                                 |
|     Root-cause · remediation · update policy/controls · record in register |
|     · feed the annual NPC summary report                                   |
|                                                                            |
+----------------------------------------------------------------------------+
```

10.2 Breach register template

#	Discovered	Occurred	Duration (if known)	Data subjects affected (count + notes)	Data types (incl. SPI?)	Notifiable? (NPC + subjects)	Discovered by / how	Containment actions	DPO sign-off	Status
2026-001	*(example row)*				Compromised signed-URL secret					Open / Closed

Legend — breach type: A = Availability · I = Integrity · C = Confidentiality. **Notifiable?** applies the § 5.2 three-part test; record the reason in either direction.

---

11. Effectivity & Approval

This policy takes effect on **‹OWNER TO SUPPLY: adoption date›** and remains in force until superseded. It is reviewed at least annually and after any notifiable breach (§ 9). Per the adoption posture above, effectivity requires completion of the owner-supplied fields and the DPO's sign-off; external PH counsel review is **recommended and applied by a dated amendment, not a precondition**.

Approver	Name	Signature	Date
Version	**v1.1 — revised 2026-10-22**		
Personal Information Controller (Proprietor)	Indalecio Sacdalan Casasola II · SETNAYAN SOFTWARE DEVELOPMENT SERVICE		

Data Protection Officer	Indalecio Sacdalan Casasola II

Appendix — Cross-references

- **Setnayan Privacy & Security Policy** — § 5 (access control & audit log), § 7 (security practices), § 8 (breach notification), § 10 (sub-processors & cross-border transfers).
- **NPC Circular 16-03** — Personal Data Breach Management (governing circular for this policy).
- **RA 10173** §§ 20, 26–31 and IRR Rules VIII–IX.
- **0028 Email Notifications** — `security_alert` template used for data-subject notification via Resend.
- **0023 Admin Console** — append-only audit log and role-based access supporting detection and evidence.

Compliant baseline; not a substitute for legal review. This policy is adopted by the DPO (Indalecio Sacdalan Casasola II); external PH counsel review is recommended and applied by a dated amendment, not a precondition to effectivity. The "public summary within 7 days where appropriate" (§ 6.2) is a breach public-disclosure timing and is unrelated to the 15-business-day data-subject-request SLA.

Data Privacy Impact Assessment (DPIA) Register + Person Graph DPIA

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted.** · 2026-07-05

> **Revised 2026-10-22** — register re-checked against `origin/main` (`aceb080a0a`): R-01 updated (explicit opt-in, 18+ gate, selfie erased 12 h after the event); R-03 re-scoped (government ID, liveness and AML screening retired 2026-07-03); R-05 corrected (parents' entries about their children ARE processed today); R-06 retired (Contract Intelligence retired 2026-05-18); new rows R-09 → R-12 screened (supplier capture lane, AI receipt reading, site Visits, Pabuya gift records). Processor list corrected.

> Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This register indexes every Setnayan processing system that warrants a DPIA and records its assessment status; Part 2 is the first fully-worked DPIA (the adults-only Person Graph).

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · dpo@setnayan.com · registered on the NPC DPO system 2026-07-07
Register owner	DPO (Indalecio Sacdalan Casasola II)
Key infrastructure / processors	Vercel (hosting) · Supabase (Postgres, Singapore region) · Cloudflare R2 (object storage, Asia-Pacific (APAC)) + relay + bot check · Resend (transactional email) · Sentry (errors) · Anthropic (receipt reading, Deep Search, screening) · OpenAI (moderation) · LanguageTool (grammar) · Google / Apple (sign-in, connections). (!) Corrected 2026-10-22: Persona / Veriff / Onfido and AMLC / ComplyAdvantage struck (retired 2026-07-03); full list in Privacy Manual § 8.2
Governing policy	`01_Contracts/Setnayan_Privacy_and_Security_Policy.md` (v1, locked 2026-05-12; Person-Graph amendment 2026-07-05 in DRAFT)
Register status	DRAFT — pending DPO adoption
Register version / date	2026-07-05 · **revised 2026-10-22**

Part 1 — DPIA Register (index)

Each row is a distinct processing system (or coherent processing activity) assessed for whether it warrants a DPIA, and, if so, the DPIA's current status.

Status legend: Complete = full DPIA finished and DPO-signed · **In-progress** = DPIA drafting/assessment underway · **Pending — counsel-first** = DPIA required before or alongside build; must be reviewed by PH counsel + DPO before the processing goes live (or, where noted, before it is designed).

Risk-level legend: HIGH / MED / LOW = inherent risk to data-subject rights and freedoms before residual-control weighting (biometric, government-ID, financial, minors, and involuntary-inference processing default to HIGH).

#	Processing system	Data-subject(s)	Sensitive-data trigger	Risk level	DPIA status	DPIA owner	Last reviewed
R-01	**Face vectors / biometric auto-tagging** — 128-dim per-event face vectors from RSVP photo + portal upload + check-in kiosk, used to auto-tag gallery photos	Guests	**Biometric = sensitive personal information (RA 10173 § 3(l))**	**HIGH**	**In-progress — counsel-first** — full DPIA now DRAFTED: see **`06_DPIA_Face_Vectors_DRAFT_2026-07-05.md`**. Headline finding: current "implicit consent" via RSVP photo upload is likely insufficient for biometric data — explicit, separate, evidenced face-recognition opt-in required before wider rollout. Pending DPO/counsel sign-off.	DPO	`[TO CONFIRM date]`

R-01a	**Face vectors — status update 2026-10-22**	Guests	Biometric	HIGH → residual Low–Med	[OK] **The consent finding is resolved in code:** a separate, default-off face-recognition tick, an 18+ confirmation, refusal of a guest the host marks as a minor, consent time/source/copy-version stamped; the selfie and vector are erased 12 hours after the event (3-month backstop); withdrawal blurs and keeps the photo. **Still open:** DPO/counsel sign-off of `06_DPIA_Face_Vectors` (revised 2026-10-22) and the owner's 2026-09-30 call that face tagging is ON by default for events with Papic (in code the event default is `papic_face_mode = mode_b`, where live auto-tagging does not run, and christening / debut events are forced to `mode_b`).	DPO	2026-10-22

R-02	**Person Graph** (connections + life-story references + trusted-circle signal), adults-only	Adult account holders + claimed/seeded persons	Relationship data; potential sensitive inference	MED (residual Low)	**Complete** — see Part 2 of this document	DPO	2026-07-05 (this draft)
R-03	**Vendor verification** — business documents (DTI, BIR 2303 with TIN, Mayor's Permit, bank proof), portfolio, client references, 15-minute Google Meet identity call	Vendors (primary representatives)	TIN on BIR 2303 (government identifier); legacy pre-2026-07-03 ID uploads until swept	**MED** (was HIGH)	**Pending** — DPIA still to be written (task `t2-9`). (!) **Re-scoped 2026-10-22:** the government ID, liveness/selfie and AMLC sanctions/PEP screening were **retired 2026-07-03**; no Persona / Veriff / Onfido / ComplyAdvantage relationship exists, so no cross-border transfer to them. Raw uploads deleted 90 days after the decision (sweep built, PR #4735). Automated document checking was proposed and **not started** (owner 2026-09-16).	DPO	2026-10-22

R-04	**Payments & reconciliation** — apply-then-pay orders, BDO/GCash reference matching, partial bank/e-wallet details on receipts, payment-inbox reconciliation	Customers, vendors	Financial data (partial account identifiers; transaction history)	**MED**	**Pending** — DPIA to be written; note no full card/CVV/account numbers stored (§ 1.1 of policy).	DPO	`[TO CONFIRM date]`
R-05	**Minors & Legacy (Phase 3 — stewarded / branch accounts)** — guardian-held child memories to age of majority; post-mortem legacy transfer down the family line	Minors; deceased persons' data; guardians/heirs	Data about minors; post-mortem control; guardianship consent	**HIGH**	**Pending — counsel-first · NOT PROCESSED YET** — adults-only today; **no minor data is processed.** A full DPIA + NPC consultation is required **before any design-to-build**, not merely before launch. **FLAGGED.** Instrument: `Phase3_Minors_and_Legacy_Counsel_Brief_2026-0`	DPO	`[TO CONFIRM date]`

R-05a	**Minors — correction 2026-10-22**	Children (entered by parents)	Data about minors; religion	**HIGH**	(!) **"No minor data is processed" is not accurate for today's product.** Stewarded accounts and legacy transfer are still unbuilt, but parents **do** enter their children's details for christenings and milestones (`dependents`: name, birth date, sex, religion, each consent-stamped; never shown publicly), and guest lists can include children. `/privacy` §"Minors, dependents, and religious information" discloses it. Face enrolment is refused for a known minor. A DPIA covering the live dependents feature is owed (task `t2-9`; control `dependent_minor_profiles`).	DPO	2026-10-22

R-06	~~**Contract Intelligence (0032)**~~	—	—	—	[X] **RETIRED 2026-05-18** (replaced by built-in dual e-signature; SKU `contract_intelligence_per_contract` inactive). No contract text goes to any AI. Row kept for lineage (corrected 2026-10-22).	DPO	2026-10-22
R-07	**Chat / communications (0019)** — customer↔vendor messages, thread file attachments (docs/images/PDF), pasted external meeting links	Customers, vendors, coordinators, guests	Free-text messages may contain incidental sensitive data	LOW–MED	**Pending `[TO CONFIRM]`** — video meetings retired 2026-05-16 (no video data stored); text + files persist to Postgres/R2. Owner to confirm standalone vs. folded.	DPO	`[TO CONFIRM date]`

R-08	**Anti-Fraud & Trust Integrity** — identity clustering (shared device/address/payment), per-cluster de-dup of vendor trust stats, vendor fraud scoring, + two-stage enforcement (reversible auto-suspend + four-eyes wipe/ban)	Couples/guests (identity-clustered) + vendors (scored/enforced)	**Involuntary profiling + automated decision with significant effects** (auto-suspend / ban); repurposed device/address/payment personal data	**HIGH**	**In-progress — counsel-first · LIVE AHEAD OF SIGN-OFF** — full DPIA now DRAFTED: see **`08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.m`** Shipped to prod 2026-07-07 (PRs #2834/#2835/#2836/#2838/#2841) ahead of counsel review (owner-elected). Headline finding: processing is **undisclosed** — a Privacy Policy Anti-Fraud amendment (notice + § 12(f) basis + right to object) + a documented LIA + a formal automated-decision contest path are required. Pending DPO/counsel sign-off.	DPO	`[TO CONFIRM date]`

R-09	**Supplier Papic capture lane + supplier copies + guest takedown** (ROPA DPS-24)	Guests and couples in supplier photos	Likeness captured by a third party (the supplier) and kept as the supplier's own copy / portfolio	**MED**	**Screened 2026-10-22 — DPIA recommended** before the guest-side takedown entry point is built; the migration header still reads "COUNSEL-GATED". Takedown reaches all four capture tables in code; guests cannot yet file one against a supplier-held photo.	DPO	2026-10-22
R-10	**AI reading of payment-proof screenshots** (ROPA DPS-08)	Customers (payers)	Financial information (account name, partial number) sent to Anthropic (US)	**MED**	**Screened 2026-10-22 — no full DPIA needed** if kept as built: the AI never decides a payment, the transcript is not stored, disclosed on `/privacy`. Needs a signed DPA with Anthropic (task `t2-8`).	DPO	2026-10-22

R-11	**First-party site Visits** (ROPA DPS-21)	All site visitors	IP + user-agent hashed for one day only	**LOW**	**Screened 2026-10-22 — no DPIA needed:** no cookie, no stored IP, salt and hashes destroyed daily, aggregates hold no personal data. Disclosure on `/privacy` + `/cookies` still owed.	DPO	2026-10-22
R-12	**Pabuya gift records** (ROPA DPS-28)	Couples, gift-giving guests	Self-disclosed financial details + payment screenshots	**LOW–MED**	**Screened 2026-10-22 — no DPIA needed;** disclosure on `/privacy` still owed (task `t1-5`).	DPO	2026-10-22

Notes on the register.
- Rows R-06 and R-07 are listed for completeness and are candidates for consolidation into adjacent DPIAs at the DPO's discretion; they are **not** the priority items.
- The four priority items for counsel are **R-01 (biometric)**, **R-03 (vendor ID)**, **R-05 (minors/legacy)**, and — for confirmation of two narrow bases only — **R-02 (person graph)**. **R-08 (anti-fraud) is now a fifth priority — and uniquely urgent because it is already LIVE in production ahead of counsel review** (see `08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md` status banner); its transparency/disclosure gap should be closed promptly.
- `[TO CONFIRM date]` in every "Last reviewed" cell must be set by the DPO on adoption; R-02's review date is the date this draft is signed off.

Part 2 — Full DPIA: Person Graph (adults-only)

> Formalizes and expands the self-assessment in `03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md` § 2 into the NPC PIA/DPIA structure. Scope is strictly the **adults-only** Phase-2 person-graph features live behind flags as of 2026-07-05. **Minors and legacy (Phase 3) are expressly out of scope** and carry their own counsel-first DPIA (register R-05).

2.1 Description of the processing

What is processed.
- **Person node** — a durable profile: name, optional photo, and the list of events the person takes part in. Every

account is one person; a person may also be *seeded* by a host (e.g. added as a guest) and later *claimed* by the real person so their own history follows them.
- **Connections** — a relationship edge between two people. Type ∈ {spouse, parent, sibling, child, godparent, friend}; state ∈ {pending → confirmed}. Extended/derived relationships (grandparents, cousins, in-laws) are **computed on read, never stored**.
- **Life-story items** — **references (pointers), not copies**, to a photo/clip/editorial the person appears in, so the item can also surface in that person's own private archive. No image bytes are duplicated; media stays in its single system-of-record (R2).
- **Trusted-circle signal** — a **computed, aggregated** count of how many people in a person's circle explicitly endorsed a given vendor. **Not stored** as a per-person record.

Why (purpose). To let a person's memories and confirmed relationships follow them across events (the product's core "living memories" purpose), and to surface aggregate, consent-based vendor trust signals — without building a browsable social directory or any advertising/data-broker use.

Data subjects. Adult Setnayan account holders and adult persons seeded by a host and not-yet-claimed. No minors.

Data categories.
- Identity: name, optional photo (already collected under policy § 1.1/§ 1.3).
- Relationship: first-degree declared edges only; extended kin derived, not stored.
- Content references: pointers to media the person appears in (governed by the source media's own consent + retention).
- Derived/aggregate: trusted-circle count (computed, not stored).
- **Not collected here:** contact details of connected persons (name-only visibility), face/biometric origin (no face field in the graph schema), booking history as a trust input.

Systems / data flows.
1. Person A initiates a connection request → B receives a just-in-time notice → B confirms or declines.
2. Edge becomes real **only on mutual confirmation**; declined edges are suppressed immediately.
3. Life-story references are assembled from events where photo-sharing consent was given at RSVP; the person can hide any item or opt out of an event's story without touching the host's gallery.
4. Trusted-circle score is computed at read time from **explicit endorsements/reviews only**, gated by min-N ≥ 5, degree ≤ 2, never from bookings, never purchasable.
5. Storage: `person_connections` (edges) + `person_story_items` (references) in Supabase Postgres (Singapore); referenced media in Cloudflare R2 (Asia-Pacific, APAC). Deny-by-default RLS; participant-scoped access only.

2.2 Necessity & proportionality assessment

- **Lawful basis.** Consent (RA 10173 § 12(a)) via mutual confirmation for connections; existing event photo-consent (RSVP) for life-story references; legitimate interest / aggregate-only for the trusted-circle signal, gated so no individual is identifiable. `[TO CONFIRM]` — DPO/counsel to confirm the precise § 12/§ 13 basis mapping per data category.
- **Necessity.** Each element is necessary for the stated purpose: connections require the counterpart's identity to be meaningful; life-story references require a pointer to the source media; the trusted-circle signal requires endorsement counts. No element collects more than the purpose needs.
- **Proportionality / minimization applied.**
- Only **declared first-degree edges** are persisted; extended kin is derived, not stored.
- Cross-person visibility is **name-only** — no contact details cross the edge.
- Life-story items are **references, not copies** — no media duplication.
- Trusted-circle is **computed, not stored**, and **aggregated (min-N ≥ 5)**.
- The graph is **not browsable** — no "people you may know", no directory, no broadcast.

- **Conclusion.** The processing is necessary and proportionate to the purpose, with data minimization enforced structurally (schema + RLS), not merely by policy.

2.3 Consultation

- **DPO:** this DPIA is prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). Two narrow items (cross-event archiving basis; long-lived memory retention basis) are referred to the DPO/counsel for confirmation — see § 2.5.
- **Data subjects:** consulted at the point of processing via just-in-time consent/notice strings (drafted in the Compliance Pack § 1) rather than a formal survey; mutual-confirmation design means no processing occurs without the counterpart's active choice.
- **External counsel / NPC:** not required for the adults-only graph beyond the two confirmation items; **required** before any Phase-3 (minors/legacy) work (register R-05).

2.4 Risk assessment table

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built.

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
PG-1	Exposing a person's data to someone they did not consent to	High	High	**High**	Mutual confirmation required; **name-only, confirmed-only** cross-person visibility (SQL `visible_connection_names`); no contact details cross the edge; deny-by-default RLS	**Low**
PG-2	The graph becoming a browsable social directory	Med	High	**High**	Participant-scoped RLS; no "people you may know"; no browse/search; edges private to the two people only	**Low**

PG-3	A person's photo appearing in another's archive without a basis	Med	High	**Med–High**	Built on event-level photo consent (RSVP); per-person **hide** + per-event **opt-out**; **references not copies**; host gallery untouched	**Low–Med** — cross-event archiving basis to be confirmed with counsel (see § 2.5)
PG-4	Inferring sensitive information from relationship data	Med	Med	**Med**	Extended kin **derived, not stored**; **min-N** ≥ **5** on any aggregate; only declared first-degree edges persisted	**Low**
PG-5	Vendor recommendations exposing who-used-whom	Med	High	**Med–High**	Aggregate-only; **min-N** ≥ **5**; explicit-endorsement-only (**never bookings**); degree ≤ 2; not purchasable	**Low**
PG-6	Cross-event face recognition / biometric creep	High	High	**High**	**Structurally impossible in this schema** — association is tag/QR/confirmed-identity only; no face origin field; face vectors stay **per-event** (policy § 1.4)	**Low**
PG-7	Pending requests leaking a name before consent	Med	Med	**Med**	Names resolve **only for confirmed edges**; pending requests show a neutral label	**Low**

PG-8	Data kept longer than justified (over-retention)	Med	Med	**Med**	Follows event/account retention (policy § 4); hide/opt-out takes effect immediately; a reference dies with its source media	**Low–Med** — long-lived "memory" retention basis to be confirmed with counsel (see § 2.5)

2.5 Residual-risk conclusion

Residual risk across the person graph is **Low overall.** The design applies data minimization and consent structurally — mutual confirmation, name-only + confirmed-only visibility, min-N ≥ 5 aggregation, references-not-copies, per-person hide / per-event opt-out, no cross-event face recognition, and deny-by-default RLS — so the two highest inherent risks (PG-1, PG-6) reduce to Low.

Two items are flagged for counsel confirmation (not redesign):
1. **PG-3 — cross-event photo archiving basis.** Confirm that the event-level RSVP photo consent is an adequate lawful basis for a photo the person appears in to also surface in *their own* private archive across events. (Counsel brief §4.4 reference.)
2. **PG-8 — long-lived "memory" retention basis.** Confirm the lawful basis and disclosure for intentionally long-lived preservation of memories (the product's purpose), so retention is justified-and-disclosed rather than open-ended.

Recommendation. Proceed with the adults-only person graph **once (a) the Privacy Policy Person-Graph amendment (2026-07-05) is approved and (b) the two confirmation items above are answered** by the DPO/counsel. No redesign is indicated.

2.6 Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	___	`[TO CONFIRM date]`
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	___	`[TO CONFIRM date]`

Next review date: `[TO CONFIRM date]` (recommend: at any material change to the person-graph schema/consent, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The Person-Graph Privacy Policy amendment publishes only after sign-off; the biometric (R-01), vendor-verification (R-03), and minors/legacy (R-05) DPIAs remain outstanding and counsel-first.

Data Privacy Impact Assessment (DPIA) — Face Vectors / Biometric Auto-Tagging

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted.** · 2026-07-05

> Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This is the standalone, full DPIA for register row **R-01** (`05_DPIA_Register_DRAFT_2026-07-05.md`) — **HIGH-risk** because it processes **biometric data**, which is **sensitive personal information** under RA 10173 § 3(l). A full, dedicated assessment is warranted precisely because a face vector is not ordinary PII.

(!) CORRECTION — verified against shipped code 2026-07-05 (read first)

> This DPIA's **headline finding (BV-1 / §6) is SUPERSEDED.** It was drafted from the Privacy Policy §6.1's *"implicit consent"* wording — but that wording was **stale**. Verified in production code:
> - `app/[slug]/_components/selfie-capture.tsx` — the face-recognition consent is an **explicit, separate checkbox** (`name="biometric_consent"`, label *"face recognition for this wedding"*), **defaulted OFF** (`useState(false)`); un-checking it drops the selfie.
> - `app/[slug]/actions.ts` (RSVP) **and** `app/papic/face-enroll-actions.ts` (day-of) both **refuse to create a face vector unless `biometric_consent === '1'`**, and stamp `consent_at` + `consent_source` on the enrolment (the evidenced record).

> So the **explicit, separate, evidenced, default-OFF opt-in that §6 recommends is ALREADY SHIPPED** (owner directives 2026-06-05 / 2026-06-28). **BV-1 is substantially RESOLVED in production** → its residual is **Low**, not Med–High. The Privacy Policy §6.1 has been corrected to match (2026-07-05).

> **The genuinely open headline finding is now BV-8 — MINORS:** guests carry no age/birth-date field, so nothing prevents a minor's face from being enrolled (a minor, or a guardian on their behalf, can tick the box). That is the live gap to close, and it is counsel-first. Read §6's recommendation as **"maintain + keep the policy accurate,"** not "implement."

REVISED 2026-10-22 — measured against `origin/main` (`aceb080a0a`) (read after the 2026-07-05 correction above)

> • **BV-1 (consent) — resolved in code, confirmed again.** Separate, default-off tick (*"face recognition for this wedding"*); the server refuses a vector without it and stamps `consent_at`, `consent_source` and `consent_copy_version`.

> • **BV-8 (minors) — resolved in code.** Enrolment now requires an **18+ confirmation** and refuses any guest the host has marked as a minor (`isKnownMinorGuest`, `app/papic/face-enroll-actions.ts`; owner 2026-08-05: *"under 18 will not allow face tagging"*). `/privacy` states *adults 18+ only*. Residual: an adult-looking minor who ticks 18+ is not detectable — Low, counsel to confirm.

> • **BV-3 (engine location) — resolved.** Descriptors are computed in the guest's browser with a self-hosted open model (`@vladmandic/face-api`, models on our own R2 host); matching runs against our own Postgres rows (Singapore). One end-of-event rescan runs the same model inside our own server function and stores no face of anyone not enrolled. **No face data goes to any outside company.**

> • **Retention — enforced, and shorter.** The selfie, enrolment and vector are **erased when the event's Papic closes, 12 hours after the event ends** (owner 2026-09-30, PR #6195, job `face-selfie-papic-close`); backstop deletion at **3 months / 92 days** after the event (job

> `face-data-retention`, PR #4735 merged 2026-08-23). Where the text below says "adopted, not yet automated", read "**automated (cron-free, runs on request traffic)**". That the jobs have run against production data was not verified from this session.
>
> • **Withdrawal blurs and keeps the photo** (PR #4747, 2026-08-24; extended to the shared pool #4766 and the public event page #5530) — owner ruling 2026-08-17.
>
> • **Still open for the DPO:** (1) the owner's 2026-09-30 call that face tagging is **ON by default** for events with Papic — in code the event default is `papic_face_mode = mode_b` (no live auto-tagging) and christening / debut events are forced to `mode_b`, so the ruling and the code should be reconciled and written down; (2) the account-level face profile (`user_face_profiles`) stays **off** (`NEXT_PUBLIC_ACCOUNT_FACE_PROFILE_ENABLED`) pending DPO sign-off; (3) active-vector count could not be re-measured (0 at 2026-08-17).
>
> • DPO contact is now dpo@setnayan.com.

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · dpo@setnayan.com · registered on the NPC DPO system 2026-07-07
DPIA owner	DPO (Indalecio Sacdalan Casasola II)
Processing assessed	Face vectors / biometric auto-tagging (Papic) — register R-01
Governing policy	`01_Contracts/Setnayan_Privacy_and_Security_Policy.md` § 1.4 (Face vectors), § 2.1 (auto-tag purpose), § 3.2 (media/vector storage), § 4 (retention), § 6.1 (photo/likeness consent)
Feature specs	`0012_paparazzi/` (Papic capture → upload → tag) + `10_Papic_Feature_Specification.md`
Risk level (inherent)	**HIGH** — biometric = sensitive personal information
DPIA status	DRAFT — pending DPO adoption + PH counsel review (counsel-first per register)
Version / date	2026-07-05 · **revised 2026-10-22**

---

1. Description of the processing

1.1 What a face vector is

A **face vector** is a **128-dimension** numerical representation ("embedding") computed from a photograph of a person's face. It is not the photo itself — it is a mathematical fingerprint of the face's geometry that lets the system compare two faces for similarity. Under RA 10173 § 3(l), a template derived from a person's face for the purpose of identifying that person is **biometric data**, and biometric data is **sensitive personal information** (§ 3, and see § 12–13 for the heightened processing conditions that follow).

1.2 Why it is processed (purpose)

To **auto-tag guests in a specific event's photo gallery** (the Papic candid-capture service). When a paparazzo or another guest uploads a photo, the system compares faces in that photo against the enrolled guest vectors **for that event only**, and tags matches so each guest's tagged photos surface to them in their gallery and personal-reel builder (policy § 2.1: "Auto-tag photos via face matching (couple-scoped only)").

1.3 Data flow (capture → vector → match → tag → gallery)

1. **Capture / enrolment sources** (policy § 1.4) — a guest's face vector is enrolled from one or more of:
- the guest's **RSVP profile photo**,
- an **optional pre-event portal upload**,
- the **on-the-day check-in kiosk**.

2. **Vector generation** — a 128-dim vector is computed from the enrolment image and written to a **per-event encrypted vector store** (policy § 3.2). The enrolment image itself is governed by the media rules in § 1.3/§ 3.2/§ 4.

3. **Per-event match at upload time** — when a photo/clip lands in the event gallery, detected faces are compared **only against that event's vector store**. Confidence thresholds:
- ≥ **0.85** → **auto-tag** the guest,
- **0.65–0.85** → surface a **suggested tag** for human confirmation,
- **< 0.65** → the photo **uploads untagged** (still delivered — see § 5).

4. **Tag → gallery** — the resulting tag routes the photo into the matched guest's tagged-photos view; untagged photos still land in the couple's gallery (untagged-still-delivered guarantee).

5. **Revocation / expiry** — a guest "Delete my face data" link revokes enrolment within the **next 5-minute refresh cycle**; turning the **Photo Consent** toggle OFF revokes live enrolment and clears any selfie display photo; vectors are otherwise **deleted 3 MONTHS AFTER THE EVENT ENDS** (owner ruling 2026-08-17; same clock as the full-resolution photo floor). (!) **CORRECTED 2026-08-17** — this read "deleted at the 5-year retention boundary with the event data", a rule nothing implemented; and once media moved to indefinite retention on 2026-08-02, "with the event data" silently meant NEVER. **Enforcement is not yet built** — no sweep covers face vectors yet. (!) Corrected same-day: the platform DOES run ~16 cron-free periodic jobs (several delete automatically); none covers this class: today only the revoke link and Photo Consent OFF delete a vector.

1.4 Data subjects

Guests (adults). Minors are excluded from the person-graph today; **whether child guests can be enrolled in face auto-tagging under the current build is `[TO CONFIRM]`** — this must be answered before adoption (see risk BV-8). No vendor, couple, or admin faces are enrolled for auto-tagging.

1.5 Systems, storage, and retention

- **Vector store:** per-event, **encrypted at rest** (policy § 1.4, § 3.2, § 7.1 AES-256). Never reused across events/weddings.
- **Enrolment / gallery media:** Cloudflare **R2 (Asia-Pacific, APAC)**, signed-URL access only (policy § 3.2).
- **Matching engine host / location:** `[TO CONFIRM]` — the compute location and any sub-processor for the face-embedding/matching step is not recorded in the policy and must be confirmed (implicates § 10 cross-border analysis if it runs outside SG/PH).
- **Retention:** face vectors are deleted **3 months after the event ENDS** (owner ruling 2026-08-17). Earlier deletion via the guest "Delete my face data" link or Photo Consent OFF, both of which work today. (!) **Enforcement of the 3-month rule is NOT yet built** — no sweep covers face vectors yet. (Corrected same-day: the platform DOES run ~16 cron-free periodic jobs, several of which delete automatically; none covers this class.) Deleting a vector does **not** remove photo tags (verified in the live schema — no cascade), so guests keep every photo already delivered.

- **Database of record for tags/linkage:** Supabase Postgres (Singapore), RLS-gated (policy § 3.1).

---

2. Necessity & proportionality assessment

2.1 Is biometric auto-tagging *necessary* for the purpose?

The purpose — getting each guest their own photos out of a large shared event gallery — is legitimate and central to Papic. Face auto-tagging makes that **convenient and complete at scale**, but it is **not the only means** of achieving it.

Less-intrusive alternatives already exist in the product:

- **Manual tagging** — the couple / guests tag photos by hand.
- **QR tagging** — the paparazzo scans a guest's personal QR (`setnayan:guest:{id}`) or a table QR (`setnayan:table:{id}`) to tag, with table-tag fan-out to seated guests. (!) **CORRECTED 2026-08-17 — this said "capped at 10 tags/photo". THERE IS NO TAG LIMIT.** The owner retired all per-photo tag caps on 2026-08-06 (*"no tag limit. we can tag as many"*). Production enforces only a 100,000 runaway-write backstop — verified by reading the live function, not a document — which is a loop/retry guard, NOT a product rule and NOT a privacy control. This is a first-class, already-shipped tagging path in the Papic spec that requires **no biometric processing at all**.

Because QR and manual tagging deliver the same core outcome without processing sensitive biometric data, face auto-tagging is best characterized as a **convenience/coverage enhancement layered on top of non-biometric tagging**, not a strict necessity. This framing matters for the consent standard (§ 6): a non-essential, sensitive-data feature should be **separately opt-in**, and a guest who declines it should still get full non-biometric service.

2.2 Proportionality — is biometric justified given the alternatives, and is it minimized?

On balance the biometric layer can be **proportionate**, *conditional on the consent fix in § 6*, because the design already minimizes it structurally:

- **Per-event scoping** — vectors are **never reused across events/weddings**; the store is siloed per wedding, so there is no cross-event identification capability and no growing biometric identity graph.
- **Thresholds tuned to reduce harm** — ≥ 0.85 to auto-tag, a human-in-the-loop **suggested-tag** band (0.65–0.85), and **< 0.65 uploads untagged** rather than guessing.
- **Untagged-still-delivered** — the feature is not load-bearing for photo delivery; a face that never matches still reaches the couple's gallery, so declining biometrics costs the guest nothing structural.
- **Purpose-limited** — vectors are used **only** to tag within the one event; policy § 2.3 forbids sale, cross-vendor sharing, and out-of-platform advertising.
- **Revocable + time-boxed** — "Delete my face data" (≤ 5-min revocation) and Photo Consent OFF both work today; the time-box is deletion 3 months after the event ends (adopted 2026-08-17, **not yet automated**).

Conclusion. The processing can be proportionate **only if** (a) the feature stays a genuine opt-in overlay on non-biometric tagging (which it is), and (b) the **consent standard is upgraded to explicit, separate, evidenced opt-in for face recognition** (§ 6). Absent (b), the sensitive-data processing is **not adequately justified** against the available less-intrusive alternatives.

---

3. Consultation

- **DPO:** this DPIA is prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). The headline consent-standard question (§ 6) and the open `[TO CONFIRM]` items (minor enrolment; matching-engine location) are referred to the DPO and PH counsel for confirmation.
- **Data subjects (guests):** consulted at the point of processing via the RSVP/portal/kiosk consent surfaces and the in-profile **Photo Consent** toggle. **This DPIA finds the current guest-facing consent moment insufficient for biometric data** and recommends a dedicated, separate face-recognition opt-in string (§ 6) — the consultation mechanism exists but its content must be upgraded.
- **External counsel / NPC: required** before wider rollout (register R-01 is "counsel-first"). Counsel to confirm the § 6 consent standard, the minor-enrolment position, and whether an NPC consultation is advisable given the biometric + event-guest population.

---

4. Risk assessment table (biometric-specific)

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built (§ 5). Biometric processing starts HIGH by default.

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
BV-1	**Processing sensitive biometric data without a valid consent standard** — "implicit consent" from an RSVP photo upload may not meet the RA 10173 § 3(b)/§ 12–13 bar of *freely given, specific, informed, and evidenced* consent for sensitive data (see § 6, KEY FINDING)	High	High	**High**	Opt-in framing + Photo Consent OFF toggle + untagged-still-delivered (declining costs nothing)	**Med–High — NOT resolved by current controls.** Reduces to Low only after an explicit, separate, evidenced face-recognition opt-in is added (§ 6). Headline gap.

BV-2	**Function creep / cross-event identification** — vectors reused to identify a person across weddings, building a biometric identity graph	Med	High	**High**	**Per-event scoping — vectors NEVER reused across events (policy § 1.4).** No cross-event vector store; person-graph schema has no face field (DPIA 05 PG-6)	**Low**
BV-3	**Vector breach or theft** — biometric templates exfiltrated; a face **cannot be reset** like a password	Med	High	**High**	Encrypted at rest (AES-256, policy § 1.4/§ 7.1); per-event silo limits blast radius; signed-URL-only media; RLS; 72-hr NPC + user breach notice (§ 8)	**Low–Med** — residual impact stays elevated because biometrics are irrevocable; `[TO CONFIRM]` whether vectors are separately key-scoped per event and whether raw enrolment images are purged post-vectorization

BV-4	**Misidentification / wrong-tag harm** — a guest tagged in a photo that isn't them (or vice-versa), causing embarrassment or mis-delivery	Med	Med	**Med**	Threshold ladder (≥ 0.85 auto · 0.65–0.85 human-confirmed suggestion · < 0.65 untagged); couple review window before public unlock; (!) **NO TAG CAP — corrected 2026-08-17** (caps retired by the owner 2026-08-06; the live 100,000 backstop is a runaway-write guard, not a privacy control, so this risk rating must not rest on it)	**Low**
BV-5	**Inability to withdraw / exercise erasure** — a guest cannot effectively revoke enrolment	Med	High	**Med–High**	"Delete my face data" link (≤ 5-min revocation); Photo Consent OFF revokes live enrolment + clears selfie; account-deletion cascade to face vectors (policy § 4)	**Low**
BV-6	**Covert or non-consensual capture (paparazzi)** — a guest photographed/enrolled without a real choice	Med	High	**Med–High**	Paparazzi opt-out with **face-blur** for opted-out guests (policy § 6.1); NSFW filter always-on	**Low–Med** — depends on the § 6 consent fix and on opt-out being surfaced *before* capture, not only after `[TO CONFIRM]`

BV-7	**Re-identification from vectors** — a stored 128-dim template reverse-engineered or matched against an external face database	Low	High	**Med**	Per-event silo (no cross-event corpus to link against); encryption at rest; no sale/sharing (§ 2.3); no external face DB used	**Low**
BV-8	**Child / minor faces enrolled** — a minor guest's biometric processed without lawful guardian consent	`[TO CONFIRM]`	High	**High**	Minors excluded from person-graph; **whether the auto-tag enrolment path itself blocks minors is `[TO CONFIRM]`**	**`[TO CONFIRM]` — cannot be rated Low until minor-enrolment behavior is confirmed and, if enrolment is possible, blocked or guardian-consent-gated**
BV-9	**Retention beyond necessity** — vectors kept longer than needed for tagging	Low	Med	**Med**	Deletion 3 months after the event ends (adopted 2026-08-17, **enforcement not yet built**); earlier deletion via link/toggle, which does work today	**Low**

---

5. Controls already built

The following controls exist in the shipped design and are load-bearing for the residual ratings above:

- **Opt-in enrolment + Photo Consent OFF toggle** — enrolment originates from a guest-supplied RSVP/portal/kiosk photo; the profile **Photo Consent** toggle turns face detection off at any time (policy § 6.1). *(Note: this DPIA finds the opt-in standard itself insufficient for sensitive data — see § 6.)*
- **Per-event scoping — vectors NEVER reused across events (policy § 1.4)** — the single most important control against function creep and cross-event identification.
- **Confidence thresholds** — ≥ 0.85 auto-tag · 0.65–0.85 human-confirmed suggestion · < 0.65 untagged.
- **"Delete my face data" link +** ≤ **5-minute revocation cycle**, and Photo Consent OFF revokes live enrolment + clears any selfie display photo.
- **Deletion 3 months after the event ends** (owner ruling 2026-08-17) — (!) **ADOPTED, NOT YET AUTOMATED**: no sweep covers face vectors yet, so this is a commitment, not a description of current behaviour. (The platform does run ~16 cron-free periodic jobs; none covers this class.) Account deletion does cascade to face vectors today (§ 4), and the revoke link works.

- **Face-blur for paparazzi opt-outs** — opted-out guests are face-blurred in captures (policy § 6.1).
- **Encryption at rest** — per-event vector store encrypted (AES-256), signed-URL-only media, RLS-gated linkage tables (policy § 1.4/§ 3.1/§ 3.2/§ 7.1).
- **NSFW filter always-on** and **couple review window** before public unlock (per Papic constraints).
- **Untagged-still-delivered guarantee** — declining biometrics never blocks a guest's photos from reaching the gallery.

---

6. KEY FINDING — the consent standard for biometric data (headline)

Finding. RA 10173 treats biometric data as **sensitive personal information**, and its processing requires consent that is **freely given, specific, informed, and EVIDENCED** (§ 3(b) defines consent; § 13 governs sensitive personal information; § 12 governs the general lawful bases). The current design relies on **"implicit consent"** — a guest uploads an RSVP profile photo and that upload is treated as consent to face-recognition auto-tagging (policy § 6.1: *"implicit consent — they uploaded the photo for this purpose"*).

Assessment. For **ordinary** PII, an implied/purpose-bundled consent may be defensible. For **sensitive biometric** data it is **likely insufficient**, for three reasons:

1. **Not specific.** Uploading a photo is a distinct act from consenting to have a **biometric template** computed and matched. Bundling the two means the biometric consent is not *specific* to that processing.
2. **Not clearly informed.** The guest is not necessarily told, at the moment of upload, that a 128-dim face vector will be generated, stored per-event, and used to auto-tag them.
3. **Not clearly evidenced.** "They uploaded a photo" is weak, contestable evidence of consent to biometric processing; RA 10173 expects consent to sensitive processing to be demonstrable as a discrete, recorded choice.

Recommendation (conservative path — the headline recommendation of this DPIA). Introduce an **explicit, separate, granular opt-in for face recognition**, distinct from photo upload:

- A dedicated toggle/consent string — e.g. *"Use face recognition to automatically find and tag me in this event's photos"* — presented **separately** from uploading a profile photo, defaulted **OFF**, and **logged with timestamp** (mirroring the `policy_acceptances` evidence pattern, ideally a purpose-specific `face_recognition_consent` record `[TO CONFIRM]`).
- Uploading a photo (for a display avatar / manual use) must remain possible **without** enabling face recognition — the two choices decoupled.
- Keep the full non-biometric path (QR + manual tagging) as the default so declining face recognition is costless.
- Re-consent, don't grandfather: existing enrolments captured under the implicit-consent model should be re-papered under the explicit opt-in before wider rollout `[TO CONFIRM]` with counsel.

Adopt this **unless PH counsel advises** that a narrower approach satisfies § 12–13 for this population. This is the single change that most reduces the residual risk of the whole feature (BV-1).

---

7. Residual-risk conclusion

With the controls in § 5 — above all **per-event scoping**, the **threshold ladder**, ≤ **5-min revocation**, **selfie erased 12 hours after the event, deletion at 3 months as backstop (both automated since 2026-08-23 / 2026-09-30 — updated 2026-10-22)**, **face-blur opt-out**, and **encryption at rest** — most biometric risks reduce to **Low** (BV-2, BV-4, BV-5, BV-7, BV-9) or **Low–Med** (BV-3, BV-6).

However, overall residual risk is CONDITIONAL and cannot be declared Low–Medium until the consent-standard fix lands. Specifically, before or at wider rollout / scale:

1. **MUST — upgrade the consent standard (BV-1 / § 6):** ship an **explicit, separate, evidenced face-recognition opt-in**, decoupled from photo upload, defaulted OFF, and logged. Re-consent existing enrolments. *This is the gating item.*
2. **MUST — resolve minor enrolment (BV-8):** confirm whether the auto-tag path can enrol a minor guest today; if so, block it or gate it behind verified guardian consent. `[TO CONFIRM]`
3. **SHOULD — confirm engine location + key/image hygiene (BV-3):** record the matching-engine host/location (and any sub-processor / cross-border transfer per policy § 10), confirm per-event key scoping, and confirm raw enrolment images are purged after the vector is derived. `[TO CONFIRM]`
4. **SHOULD — ensure paparazzi opt-out is offered before capture (BV-6)**, not only remediated after.

> [OK] **Status 2026-10-22: items 1, 2 and 3 are done in code** (see the revision block at the top); item 4 (opt-out before capture) is covered by FaceBlock and withdrawal-blurs. **Residual risk: Low–Medium, pending DPO/counsel sign-off.**

With items 1–2 done, residual risk across the feature is Low–Medium. Until then, the biometric processing should be treated as **counsel-first / not-cleared-for-wider-rollout**, consistent with the register R-01 status.

---

8. Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	___	`[TO CONFIRM date]`
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	___	`[TO CONFIRM date]`

Next review date: `[TO CONFIRM date]` (recommend: on adoption of the explicit face-recognition consent flow, at any material change to the vector schema / thresholds / retention, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The biometric processing remains counsel-first (register R-01): the explicit-consent upgrade (§ 6) and the minor-enrolment question (BV-8) must be resolved before wider rollout.

Compliance Facts Register — Setnayan

Date: 2026-07-05 · **Revised 2026-10-22** (DPO contact, scale caveat, sub-processors rebuilt from the code, payment rail, remaining unknowns)
Purpose: The single source for every `[TO CONFIRM]` value across the NPC pack. Owner-supplied facts + values I could derive (live DB / code / known infra). Finalize with the DPO (the owner/proprietor) + PH counsel, then thread into the pack (or maintain via the admin Compliance page — see note at end).

> [OK] **The BIR TIN has been REDACTED from this file** (2026-07-05) — the sensitive government ID now lives only in the access-controlled **admin → Compliance** page (PR #2848), never in a repo. This file remains a working reference for the non-sensitive facts; still keep it out of any public repository.

---

1. Business identity — [OK] supplied

Field	Value
PIC (legal)	**SETNAYAN SOFTWARE DEVELOPMENT SERVICE** (sole proprietorship)
Proprietor	Indalecio Sacdalan Casasola II
DTI Business Name No.	8297508 (national · valid 25 Jun 2026 – 25 Jun 2031)
BIR TIN	**[redacted — held by owner; entered in admin → Compliance]** *(sensitive government ID; deliberately not stored in this file / any repo)*
Registered / principal address	**76 Sampaguita Avenue, Quezon City** *(barangay + ZIP — add if NPC form requires)*
NPC registration no.	*(blank until filed)*

2. DPO & team — [OK] supplied

Field	Value
DPO	**Indalecio Sacdalan Casasola II** (the proprietor/PIC also serves as DPO) · published contact **dpo@setnayan.com** (owner ruling 2026-09-22; verified reachable 2026-09-13; routes to the owner's iCloud) · **registered on the NPC DPO system 2026-07-07** under iscasasolaii@gmail.com — update to dpo@ at filing
DPO employment basis	Internal — the proprietor/PIC also acts as DPO (2-person founding team). (!) **PIC = DPO:** NPC generally prefers a DPO with autonomy from the controller; for a 2-person sole proprietorship this is commonly accepted — counsel to confirm and, if kept, note a short independence rationale in the designation sheet (doc 03).
DPO phone / designation date	*(to set — recommend stamping the date the manual is adopted)*

Total headcount	**2** — Indalecio S. Casasola II (proprietor + DPO) + Claire E. Buanhog (VP, co-founder)
Staff with personal-data access	Both (2 of 2)

3. Scale — (!) RE-READ FROM LIVE DB 2026-07-31 · the 2026-07-05 figures below are STALE AND HIGH

> (!) **2026-10-22: not re-measured.** The latest production reading in the pack is 2026-08-17 (9 accounts · 39 guests · 2 shops · 6 events · 0 face vectors). This session has no production access, so no newer count is given — read `/admin/compliance/data-sheet` on filing day.

Data subjects	2026-07-05 (stale)	2026-07-31 (live)
Customer accounts (`users`)	19	**6**
Vendors (`vendor_profiles`)	50	**2**
Guests (`guests`)	332	**39**
Events	61	**3**
Active biometric face vectors (sensitive)	**0**	**0** — `guest_face_enrollments` is empty (0 rows), `user_face_profiles` 0

> **(!) The counts went DOWN by roughly 10×, which means test data was purged at some point between 2026-07-05 and 2026-07-31.** Total data subjects today = **45** (6 accounts + 39 guests), **not the "~401" quoted in `00_ADOPTION_COVER_SHEET`** and echoed through docs 01/03. Those prose figures are labelled as a *2026-07-05 pre-launch snapshot*, which keeps them defensible as history — but **do not type them into an NPC form.**

> [OK] **The filing itself is safe:** `/admin/compliance/data-sheet` computes every scale count **live** at render time (`data-sheet/page.tsx` → `countOf()`), so the exported sheet reports whatever is true on the day it is generated. The risk is only that a human reads the prose instead of the export. **Re-read the counts on the day you file** — do not trust any number written in this pack.

> The registration-threshold analysis is **unaffected**: 45 subjects and 0 biometric vectors are further below the ≥1,000-SPI trigger than the stale figures were, and the recommendation to register still rests on the **risk-to-rights + not-occasional** grounds, which are volume-independent (doc 03 § B.4).

- **Sensitive-data holders today:** 0 biometric at the last reading; suppliers submit the TIN on BIR 2303 (government IDs retired 2026-07-03); guest `dietary_restrictions` may reveal health/religion (special category). Counts are small + pre-launch — but per the RoPA, **NPC registration is still advised** on the *risk-to-rights + not-occasional* grounds, independent of volume.

4. Breach response team — (!) currently the 2-person team

- No external DBRT members yet. Document the 2-person structure: **DPO = the proprietor (owner)** leads; **VP (Claire E. Buanhog)** supports. Add an external PH counsel liaison when engaged.
- 24/7 escalation contacts + DPO breach hotline: *(to set — even a single mobile + the DPO email suffices to start).*

5. Sub-processors — rebuilt 2026-10-22 from the hosts the code calls (`origin/main aceb080a0a`)

Sub-processor	Role	Jurisdiction / hosting	Personal data?	DPA on file
Supabase	Database, sign-in, realtime	**Singapore** (ap-southeast-1)	Yes — incl. face vectors	**No**
Vercel	App hosting	US company; functions in **Singapore** (`sin1`)	Yes (in transit)	**No**
Cloudflare	R2 storage (APAC) · TURN relay · Turnstile bot check · STUN	APAC / global	Yes (media, selfies, proofs, documents; IP in transit)	**No**
Resend	E-mail (no guest e-mail since 2026-09-29)	United States	Yes (addresses + content)	**No**
Sentry	Error monitoring, masked replay on error	United States	Minimal (scrubbed)	**No**
Anthropic	Receipt reading · Deep Search · gallery screening · theme sentence	United States	Yes (payment screenshots)	**No**
OpenAI	Moderation of published text	United States	Yes (text)	**No**
LanguageTool	Grammar check, free public API	Germany (EU)	Yes (text)	**No — not possible on free endpoint**
Google	Sign-in · YouTube · Drive · Gemini · STUN	United States	Yes, per connection	Google API terms
Apple	Sign in with Apple · in-app purchase (off) · iTunes search	United States	Yes (ID token; purchases)	Apple terms
Meta	Own posts · supplier Instagram sync	United States	Supplier posts	Meta terms
TikTok	Patiktok posting	SG / US	Yes, per connection	TikTok terms
OpenStreetMap · Vimeo · browser push services · public CDNs	Maps · poster image · web push · library downloads	UK / US / various	Address text, links, notification content, IP	n/a
~~PostHog~~	~~Product analytics~~	—	[X] **Removed 2026-10-22 (PR #6774)**	—
~~Persona / Veriff / Onfido~~	~~Vendor ID verification~~	—	[X] **Retired 2026-07-03**	—

Suno	Music, used by hand	—	**No** — not called by code	n/a
Face matching	Embedding + match	**In the browser + our own server function** (self-hosted open model); vectors in Supabase (Singapore). **No third-party face service.**	Yes (biometric, stored)	n/a (in-house)

6. Processing specifics — [OK] derived

Question	Answer
Sensitive RSVP fields collected	`dietary_restrictions` + `meal_preference` (may reveal health / religious belief — special category). **No standalone religion or health field.**
Solely-automated decisions w/ legal/significant effect	**YES — one, as of 2026-07-07:** the Anti-Fraud engine (DPIA **R-08** / ROPA **DPS-12**) can **automatically suspend** a vendor's public listing at a high fraud score (**reversible**). The **irreversible** wipe/ban is NOT automated (routed through the four-eyes admin gate). AI planning features remain assistive only. See `08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md` §6 (RA 10173 §16(c)/§34) — a formal contest/appeal path is a flagged follow-up.
Payment rail	**No gateway is called.** Manual apply-then-pay to Setnayan's own BDO / GCash accounts with a proof upload. Maya (dormant) was superseded by PayMongo as the chosen future rail (owner 2026-07-23) — **neither is called by the code**. Apple in-app purchase is built and switched off. (Updated 2026-10-22.)
Staff NDAs / privacy training / device policy	*(to set — for a 2-person team, a short signed confidentiality + basic-hygiene note suffices; recommend adopting.)*
DPIA / designation adoption dates	*(to set on adoption.)*

7. Remaining true unknowns (short list for owner/DPO + Claire/VP) — updated 2026-10-22

1. Barangay + ZIP for the address
2. The DPO contact phone + the adoption/signature date
3. Which sub-processors have a signed DPA (today: none) — task `t2-8`
4. Whether to adopt the light NDA / training / device-hygiene notes (recommended) — task `t2-11`
5. Production state that a session cannot read: data-subject counts, each `/admin/data-privacy` control, the `npc_filing_tasks` statuses, and which keys/switches are set (Google/Apple sign-in, Turnstile, TURN, push, Anthropic, device fingerprint)
6. ~~PostHog instance region~~ — retired: PostHog removed 2026-10-22

This register resolves the large majority of the pack's `[TO CONFIRM]` items. Recommended next step: move these facts into an access-controlled admin Compliance page (editable, admin-only, can export the NPC data sheet) — the correct secure home for the TIN + DPO details, rather than a plaintext file.

Data Privacy Impact Assessment (DPIA) — Anti-Fraud & Trust Integrity (identity clustering · fraud detection · enforcement)

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted.** · 2026-07-07

> Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This is the standalone, full DPIA for register row **R-08** (`05_DPIA_Register_DRAFT_2026-07-05.md`). It is **HIGH-risk** because it (a) **repurposes** already-collected personal data (device fingerprint, normalized home address, payment-sender identity) for a **new purpose** without the data subject's active choice, and (b) performs **automated decision-making with significant effects** — it can automatically hide a vendor's livelihood-bearing listing and, on human confirmation, permanently ban it.

(!) STATUS — this processing is LIVE IN PRODUCTION as of 2026-07-07, ahead of counsel sign-off (read first)

> The anti-fraud stack (repo PRs #2834/#2835/#2836/#2838/#2841 · migrations `20270516600000`, `20270517644717`, `20270518682623`) was **shipped to production on 2026-07-07**. The engineering PRs each flagged **counsel review PENDING** for this RA 10173 processing; the **owner (PIC) elected to ship ahead of that review** to unblock the feature. **This DPIA is therefore a retroactive assessment** — it documents processing that is already occurring and identifies what must still be done (chiefly the **transparency/disclosure gap in §6**) to bring it fully into compliance. **Counsel review remains outstanding and is the gating adoption item.** Nothing in this DPIA should be read as confirming the processing was cleared before launch.

REVISED 2026-10-22 — measured against `origin/main` (`aceb080a0a`)

> • **AF-1 disclosure — PUBLISHED.** The live `/privacy` page now carries §"Anti-fraud & trust integrity": it names the signals (device and browser signals, the account address, the payment-sender identity), the purpose, legitimate interest as the basis, that a high-risk listing may be hidden reversibly, that a permanent action needs two team members, and that a vendor can object. The §6 "MUST — publish" item is done; AF-1 residual falls to **Low–Med**.
>
> • **LIA + formal appeal path — still owed** (NPC task `t1-4`, seeded *not started*; current status lives in production and was not read). The help-center appeal stub remains the route.
>
> • **Reversal returns a shop to *hidden*,** and an admin re-publishes it — an owner lock (2026-07-27), not a defect; "reversible" in this DPIA means that.
>
> • **Device signal:** in code the browser capture is behind `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` and the `device_fingerprint` control (both default off), but it was **measured collecting in production on 2026-08-17** — a code default is not the production value; check the board. The server hashes with a fixed salt (`DEVICE_HASH_SALT`), not a rotating one — acceptable for clustering (it must be stable), worth stating in the LIA. Owner as DPO (2026-09-16): device hashes are deleted on account close, excluded from the export and pruned on a schedule — (!) no pruning job was found in code.
>
> • The anti-fraud control (`antifraud_trust_signals`) was approved and recorded on 2026-08-18 (DECISION_LOG).
>
> • DPO contact is now dpo@setnayan.com.

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · dpo@setnayan.com · registered on the NPC DPO system 2026-07-07
DPIA owner	DPO (Indalecio Sacdalan Casasola II)
Processing assessed	Anti-Fraud & Trust Integrity — identity clustering + vendor fraud detection/scoring + two-stage enforcement — register R-08
Governing policy	`01_Contracts/Setnayan_Privacy_and_Security_Policy.md` § 1.1 (identity/device/payment data collected), § 2 (purposes), § 3 (storage/RLS), § 4 (retention), § 10 (sub-processors/cross-border) — **an Anti-Fraud amendment is REQUIRED and not yet drafted (see §6)**
Feature specs	`03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md` §§ 3–6
Shipped code	migrations `20270516600000_identity_clusters_phase2`, `20270517644717_fraud_signals_detection_engine`, `20270518682623_fraud_enforcement_state_and_audit`; `apps/web/lib/fraud-detection*.ts`; admin surface `/admin/fraud`
Risk level (inherent)	**HIGH** — repurposed personal data + involuntary profiling + automated decisions with significant effects
DPIA status	DRAFT — pending DPO adoption + PH counsel review; **processing is already live** (see status banner)
Version / date	2026-07-07 · **revised 2026-10-22**

---

1. Description of the processing

1.1 What the processing is

Three layered, service-internal mechanisms that protect marketplace trust signals (reviews, booking counts, badges) from manipulation:

1. **Identity clustering** — links multiple user accounts that are probably the *same person or household* by **shared strong signals**: the same **device fingerprint**, the same **normalized home address**, or the same **payment-sender identity**. Each connected group is assigned an opaque `cluster_id`.
2. **Trust-stat de-duplication** — vendor review counts, ratings, and completed-booking counts are counted **per cluster, not per account**, and **arm's-length-excluded** (a review/booking from someone in the vendor owner's or team's own cluster does not count). This is what makes fake-account rings ineffective.
3. **Fraud detection + two-stage enforcement** — per-vendor anomaly **signals** (score 0–100) are computed and stored; a high aggregate score can **auto-suspend** a vendor (reversible), and — only on a second admin's

confirmation via the four-eyes gate — a vendor can be **wiped + permanently banned** (irreversible).

1.2 Why it is processed (purpose)

Fraud prevention and marketplace integrity — to stop vendors from inflating their reviews, ratings, badges, and booking counts with sockpuppet accounts (fake couples on shared devices/addresses/payment sources), and to detect and act on anomalous trust-manipulation patterns. The purpose protects **couples** (who rely on honest trust signals to choose vendors) and **honest vendors** (who are otherwise out-competed by fabricated reputations).

1.3 Lawful basis (preliminary — to be confirmed by counsel)

Legitimate interest — RA 10173 § 12(f): fraud prevention is a recognized legitimate interest of the PIC and of honest data subjects. This basis requires a documented **legitimate-interest balancing** (necessity ↔ data-subject impact) and **transparency** (the processing must be disclosed). **Neither the balancing test nor the disclosure yet exists — this is the headline finding (§6).** `[TO CONFIRM]` — DPO/counsel to confirm § 12(f) as the basis for each data category and the automated-decision provisions of § 16(c) / § 34.

1.4 A secondary use of already-collected data — NO new collection

Critically, this processing **collects no new personal data.** It **repurposes** data already collected and recorded for other purposes:

- **Device fingerprint** — `user_devices.device_hash` (already collected for session/security).
- **Normalized home address** — `users.address_normalized` (already collected at account/profile).
- **Payment-sender identity** — `payments.reference_number` joined to the paying user (already collected for apply-then-pay reconciliation, DPS-08).

Because it is a **new purpose over old data**, the compliance question is one of **purpose-compatibility + disclosure**, not new consent for collection. Under RA 10173 a further, compatible processing purpose is permissible on a lawful basis, **but it must be disclosed** — which it currently is not (§6).

1.5 Data subjects

- **Couples / customers / guests** — whose device/address/payment signals are clustered to detect review/booking rings. **They never see cluster membership** (service-role only). This is the more novel, involuntary population.
- **Vendors** — whose trust stats are de-duplicated and who are **scored, and potentially auto-suspended or banned**. This is the population subject to **automated decisions with significant effects**.

1.6 Data categories processed

- **Identity-link signals (input):** device fingerprint hash, normalized home address, payment-sender reference. (Personal information; **not** SPI under § 3(l).)
- **Derived — identity cluster membership:** an **inference** that two or more accounts are the same person/household. (A new derived personal datum about the linked individuals.)
- **Derived — vendor fraud signals/scores:** per-vendor anomaly signals (`ring`, `velocity`, `graph_isolation`, `import_spike`, `rating_shape`), each with a 0–100 score and a **non-PII** `evidence` JSONB (counts, ratios, opaque cluster labels, booleans — **no names, no addresses, no raw identifiers**).
- **Enforcement state:** `fraud_suspended_at` / `fraud_banned_at` / `fraud_tombstoned` on the vendor; `voided_by_fraud` flags on the vendor's reviews/events; an append-only `fraud_enforcement_audit` row per action.

- **Intentionally NOT processed: IP address** — no core identity table captures an IP, and IP-capture infrastructure was **deliberately not built** (deferred to a future "Phase 2.1"). This is a data-minimization choice.

1.7 Systems, storage, and retention

- **Database of record:** Supabase Postgres (**Singapore**). `identity_clusters` + `user_identity_signals` (views/matviews), `fraud_signals` + `vendor_fraud_scores`, enforcement columns + `fraud_enforcement_audit`.
- **Access control: service-role / admin ONLY.** Every object carries `REVOKE ALL FROM anon, authenticated` and/or `is_admin()` RLS at `CREATE TABLE` time — **couples and vendors can never read cluster membership, fraud signals, or scores.**
- **Cross-border:** SG (Supabase) only for this processing. No US/third-party AI sub-processor is involved (the clustering + scoring are plain SQL/TypeScript in-house).
- **Retention:** `identity_clusters` / `vendor_fraud_scores` are **recomputed matviews** (no independent history). `fraud_signals` + `fraud_enforcement_audit` **persist** — **a specific retention rule for these is not yet defined `[TO CONFIRM]`** (see AF-8). Underlying signal inputs follow their source systems' retention (device/address = account retention; payment = 5-year tax retention, DPS-08).

---

2. Necessity & proportionality assessment

2.1 Is the processing *necessary* for the purpose?

Marketplace trust is the product's core promise; fabricated reviews/bookings directly harm couples and honest vendors. **Non-identity-based** anti-fraud (e.g. manual moderation) does not scale and cannot see cross-account rings. Identity clustering is the mechanism that actually neutralizes sockpuppet rings, and per-cluster de-duplication is the minimal way to make fake accounts ineffective without deleting anyone. So the clustering + de-duplication layer is **necessary and well-targeted**.

Automated **scoring** is necessary to triage at scale; automated **suspension** is a proportionality choice (see §2.2) — justified only because it is **reversible** and set at a **high-confidence threshold**.

2.2 Proportionality — is it minimized, and are the effects proportionate?

The design minimizes structurally:

- **No new data collected** — secondary use of existing signals only (§1.4).
- **IP deliberately excluded** — the most privacy-invasive identity signal was not built (§1.6).
- **Service-role-only** — the inferences are never exposed to any data subject or other user; they exist solely to correct trust math and feed the admin queue.
- **Non-PII evidence** — the stored fraud evidence carries counts/ratios/opaque labels, not identities.
- **The irreversible action is NOT automated** — only the **reversible** auto-suspend is automated, and only at a **high aggregate score (≥ 90)**, strictly above the advisory band. The **wipe + permanent ban** requires a **second admin's confirmation** through the existing four-eyes gate — a human, accountable, logged decision, never the machine's.
- **Appeal path** — an enforcement action opens a help-center appeal ticket stub, giving the vendor a route to contest.

Conclusion. The processing can be proportionate **conditional on §6** — i.e. once (a) it is **disclosed** to data subjects and (b) a **legitimate-interest balancing** is documented and counsel-reviewed. The automated-suspension effect is proportionate **because** it is reversible and human-reversible in one action; the irreversible effect is proportionate

because it is never automated.

---

3. Consultation

- **DPO:** prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). The transparency finding (§6), the lawful-basis mapping (§1.3), the retention gap (AF-8), and the automated-decision rights (§6 / AF-5) are referred to the DPO and PH counsel.
- **Data subjects: not yet consulted or notified** for this specific processing — there is currently **no notice** that device/address/payment data is used to cluster identities for fraud prevention, and no notice to vendors that they may be automatically scored/suspended. Closing that is the §6 recommendation.
- **External counsel / NPC: required** — register R-08 is counsel-first, and the processing shipped ahead of that review (status banner). Counsel to confirm the § 12(f) basis, the § 16(c)/§ 34 automated-decision provisions, the retention rule, and whether an NPC consultation is advisable given the automated-enforcement effect.

---

4. Risk assessment table

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built (§5).

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
AF-1	**Undisclosed repurposing** — device/address/payment data collected for other purposes is used to cluster identities for fraud prevention **without notice** to the data subject (transparency failure under § 12(f) + the § 16 right to be informed)	High	High	**High**	Service-role-only (never surfaced); no new collection; purpose-limited to fraud prevention	**Med–High — NOT resolved by current controls.** Reduces to Low only after the Privacy Policy discloses the processing + the right to object (§6). **Headline gap.**
AF-2	**Wrongful automated suspension** of a legitimate vendor (false positive hides their livelihood-bearing listing)	Med	High	**High**	**Reversible** auto-suspend; high threshold (score ≥ 90, above the advisory 60); admin Dismiss / Un-suspend in one action; fail-soft scoring	**Low–Med**

AF-3	**Wrongful irreversible ban** — a vendor is wiped/banned and reviews/events voided in error	Low	High	**High**	**Never automated** — routed through the **two-admin (four-eyes) gate**; typed business-name confirmation; append-only `fraud_enforcement_audit`; help-center appeal ticket opened	**Low–Med**
AF-4	**Cluster mis-linkage** — unrelated people linked as one identity (shared family PC, shared address, one person paying for another) → a false "same identity" inference	Med	Med	**Med**	Used only to **de-dup trust stats** + as one fraud-signal input, **never surfaced** to users; enforcement needs corroborating anomaly signals, not cluster membership alone; bounded (≤ 64-hop) cycle-guarded closure	**Low–Med**
AF-5	**Data-subject rights over automated processing** — a vendor cannot access/understand/contest an automated decision (RA 10173 § 16(c) right to object; § 34 rights re automated processing)	Med	High	**Med–High**	Appeal-ticket stub on enforcement; irreversible step is human-decided; audit trail records rationale	**Med** — a **formal** access/object/contest path for automated scoring is not yet documented (see §6)

AF-6	**Breach of the identity-cluster / fraud store** — exfiltration of who-is-linked-to-whom or who-is-flagged	Low	Med–High	**Med**	**Service-role/admin ONLY** (`REVOKE ALL FROM anon, authenticated`, `is_admin()` RLS at CREATE); non-PII `evidence`; SG-only (no third-party processor); AES-256; TLS 1.3	**Low**
AF-7	**Function creep** — cluster/fraud data reused for marketing, ranking, or sold/shared	Low	High	**Med**	Purpose-limited by design + policy § 2.3 (no sale/cross-vendor sharing/advertising); service-role-only	**Low** — pending an explicit policy lock naming this processing
AF-8	**Over-retention of fraud signals** — `fraud_signals` / `fraud_enforcement_audit` kept longer than necessary	Med	Med	**Med**	Matviews (`identity_clusters`, `vendor_fraud_scores`) recomputed, no history; enforcement audit is intentionally durable	**Med** — no explicit retention/aging rule for `fraud_signals` yet `[TO CONFIRM]` (audit trail retention should be justified against BIR/dispute needs)

5. Controls already built

Load-bearing for the residual ratings above; all verified against the shipped migrations/code:

- **Service-role / admin ONLY** — `identity_clusters`, `user_identity_signals`, `fraud_signals`, `vendor_fraud_scores`, and the enforcement/audit objects carry `REVOKE ALL FROM anon, authenticated` and/or `is_admin()` RLS **at `CREATE` time**. No data subject can read them.
- **No new data collection** — secondary use of `user_devices.device_hash`, `users.address_normalized`, `payments.reference_number` only.
- **IP deliberately not captured** — the most invasive identity signal was left unbuilt (data minimization).
- **Non-PII evidence** — `fraud_signals.evidence` holds counts/ratios/opaque cluster labels/booleans, not identities.
- **Automated action is the *reversible* one only** — auto-suspend at aggregate score ≥ 90 (above the advisory 60); it hides the listing + freezes badges but **destroys nothing** and reverses in one admin action.

- **Irreversible action is human + four-eyes** — wipe + permanent ban routes through the existing **two-admin approval gate** (`admin_approval_requests`, new `approve_fraud_wipe_ban` action type); a *different* admin confirms; never automated.
- **Append-only audit** — every enforcement action writes a `fraud_enforcement_audit` row (actor, rationale, evidence snapshot).
- **Appeal route** — enforcement opens a help-center appeal ticket stub.
- **Defense-in-depth freeze** — a fraud-frozen vendor is excluded from the marketplace query, `/v/[slug]`, `api/v1/vendors`, and the Spotlight-Award candidate pool.
- **Bounded computation** — the cluster closure is a cycle-guarded, ≤ 64-hop recursive CTE (to be promoted to a nightly union-find job at scale).

---

6. KEY FINDING — the transparency & automated-decision gap (headline)

Finding. The processing is lawful in principle on a **legitimate-interest (§ 12(f))** basis, but two accountability requirements of that basis are **not yet met**, and the processing is **already live** (status banner):

1. **No disclosure / notice.** Neither couples nor vendors are told that (a) their **device fingerprint, home address, and payment-sender identity** are used to **cluster identities for fraud prevention**, nor that (b) vendors may be **automatically scored and suspended**. RA 10173's § 16 right-to-be-informed and the transparency limb of § 12(f) require this to be disclosed. **This is the single most important gap.**
2. **No documented legitimate-interest balancing (LIA)** and **no formal automated-decision rights path.** § 12(f) requires the PIC's interest to be weighed against data-subject rights and freedoms, recorded. And because auto-suspension is a decision producing a **significant effect** on a vendor, the § 16(c) right to object and § 34 provisions on automated processing should be reflected in a documented **contest/appeal** path (the ticket stub exists; the formal process does not).

Recommendation (the headline recommendation of this DPIA).

- **MUST — publish an Anti-Fraud disclosure** in the Privacy Policy (a new amendment, mirroring the Person-Graph amendment pattern): state plainly that device/address/payment data may be used to detect and prevent fraudulent trust manipulation, that vendors may be subject to automated integrity checks and (reversible) suspension with a human-reviewed, appealable path to any permanent action, and the legitimate-interest basis + how to object. Present it to couples and vendors.
- **MUST — record a legitimate-interest balancing test (LIA)** for the clustering + scoring, and a **formal vendor contest/appeal procedure** for automated suspensions (elevate the ticket stub to a documented § 16(c)/§ 34 path).
- **MUST — obtain the outstanding counsel review** (register R-08 is counsel-first; the processing shipped ahead of it — status banner). Counsel to confirm § 12(f) mapping, the automated-decision provisions, and whether an NPC consultation is advisable.
- **SHOULD — define a retention rule** for `fraud_signals` and justify `fraud_enforcement_audit` retention (AF-8).

Until the disclosure (item 1) lands, the residual risk of AF-1 stays **Med–High** and the processing, while operational, is **not fully compliant** on the transparency limb.

---

7. Residual-risk conclusion

With the controls in §5 — above all **service-role-only access**, **no new collection**, **non-PII evidence**, **reversible-only automation at a high threshold**, and the **four-eyes gate on the one irreversible action** — most

risks reduce to **Low** (AF-6, AF-7) or **Low–Med** (AF-2, AF-3, AF-4).

However, overall residual risk is CONDITIONAL and cannot be declared Low–Medium until the §6 transparency items land, and the processing is currently **live ahead of counsel review**. Before this can be treated as adopted/cleared:

1. **MUST — publish the Anti-Fraud Privacy Policy disclosure + notice** (AF-1 / §6). *Gating item.*
2. **MUST — record the legitimate-interest balancing (LIA) + a formal automated-decision contest path** (AF-5 / §6).
3. **MUST — complete the outstanding PH counsel review** (R-08 counsel-first).
4. **SHOULD — set a retention rule for `fraud_signals` + justify audit retention** (AF-8).

With items 1–3 done, residual risk across the processing is Low–Medium. Until then it should be treated as **operational-but-not-yet-cleared / counsel-first**, consistent with register R-08. The design itself is sound; the gap is **paperwork + disclosure**, not architecture.

---

8. Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	___	`[TO CONFIRM date]`
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	___	`[TO CONFIRM date]`

Next review date: `[TO CONFIRM date]` (recommend: on publication of the Anti-Fraud Privacy Policy disclosure, at any material change to the clustering signals / scoring thresholds / enforcement model, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The processing is live in production as of 2026-07-07 ahead of counsel sign-off (owner-elected); the transparency/disclosure upgrade (§6) and the outstanding counsel review are the gating items to bring it fully into compliance.

Setnayan — Data Retention Schedule

> **Revised 2026-10-22** — current enforcement, measured in code (`origin/main` `aceb080a0a`): chat 5 years after the event (`retention-sweep`); **face selfie + vector erased when Papic closes, 12 hours after the event**, backstop 92 days (`face-selfie-papic-close`, `face-data-retention`); supplier identity uploads 90 days after the decision, DTI / BIR 2303 / Mayor's Permit 7 years (`vendor-identity-retention`); Deep Search dossiers 180 days; full-resolution originals replaced by the web copy at 6 months from first capture (≥ 3 months after the event) — **the compressed gallery is kept for life**; unanswered connection requests 30 days; anonymous drafts 30 days; group stories 24 hours; site-visit hashes 1 day. Payments / receipts / contracts: **10 years** per the live `/privacy`. **Promised on `/privacy` but no purge found in code:** support tickets 2 years, our error/usage logs 90 days, stale device records 24 months. **Account deletion has no tail** — request → 24-hour admin review → anonymise-and-retain. Class 9 (observability): PostHog removed 2026-10-22; Sentry only. All jobs are cron-free (run on request traffic). Where the body below differs, this line governs.

> **Status: DRAFT — `[PENDING COUNSEL]`.** Retention periods below are reasoned from the standard PH statutes (RA 10173, NIRC/BIR, Civil Code). They are **not legal advice** and must be ratified by external counsel before launch. **DPO = the owner** (Indalecio S. Casasola II) per `[[dpo-designation-owner]]`; external counsel = TBD.

> Created 2026-07-11. This is the canonical answer to "how long do we keep user data, and until when *can* we keep it?" — supersedes scattered "5-year" mentions in individual iteration specs.

---

1. Governing principles

Retention is bounded on **both** ends, and the two bounds come from different laws pulling in opposite directions:

Bound	Source	Effect
Maximum (delete *by*)	RA 10173 (Data Privacy Act) — **storage-limitation principle**	Personal data may be kept **only as long as necessary** for its purpose, then must be securely disposed of. Indefinite retention of personal data is itself a violation and a breach-surface liability. "Keep everything forever" is **not** an option for personal data.
Minimum (cannot delete *before*)	NIRC / BIR **RR 17-2013**; Civil Code **Art. 1144**	Financial/tax records must be kept **10 years**; a written contract is actionable for **10 years**, so contract records must survive that dispute window. These **override** an earlier RA 10173 erasure for the specific records they cover.

Design consequence: a chat thread and the payment attached to it are **different retention classes**. You cannot anchor everything to one "delete at N years" switch — you would either illegally delete a tax record or needlessly hoard chat. Retention is **per data class**, below.

---

2. Retention schedule (by data class)

#	Data class	Iteration(s)	Retention anchor	Keep for	Legal basis	Disposal

1	**Vendor↔couple chat** (`chat_threads`, `chat_messages`)	0019	`event_date`	**5 years**	RA 10173 necessity + normal dispute window	Hard-delete thread + messages

2	**Media** — Papic photos/video, gallery, reels (R2)	0012, 0009, 0024	**first capture** (NOT `event_date`), floored at `event_date` + 3 months	**Full-res 6 months from the event's FIRST capture and never less than 3 months after the event date, then ONE compression to the ~8% web copy — free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** (owner-locked 2026-07-10 "free forever, never deleted"; window 3 mo → 6 mo owner 2026-08-02; post-event floor 30 d → 3 mo and capture opening 5 mo → 6 mo owner 2026-08-07). (!) **CORRECTED 2026-08-02** — this row previously read *"5 years (hot 90 d → cold → purge)"*, which described a deletion the product does not perform. (!) **ANCHOR CORRECTED 2026-08-07** — it said `event_date`; the clock actually starts at the **first capture**, which can be six months earlier, so an `event_date` anchor overstates how long we hold an engagement-shoot original. A schedule promising a purge that never happens is the more dangerous direction of drift: it is a commitment to the regulator broken every day. The couple's own Google Drive full-res is separate and permanent (2026-07-11 invariant) — we never downgrade or delete THEIR copy.	RA 10173 — see (!) below; PH photographer norm	R2 lifecycle: compression at 6 mo; **no expiry rule on the web copy**

> (!) **INDEFINITE RETENTION IS A LAWFUL-BASIS QUESTION, NOT A STORAGE SETTING (flagged 2026-08-02).**
> Row 2 now states that the compressed web copy is kept forever. That is the shipped product and the owner's lock — but RA 10173 asks that personal data be kept no longer than the purpose requires, and these are photographs of identifiable people, including guests who are not our customers. The basis is the couple's own request to preserve their memories, plus guest consent captured at RSVP/tag time, plus the standing opt-out and face-blur path. **That reasoning must be written down and reviewed by counsel before this schedule is lodged** — 'the owner decided' is not a lawful basis. Until then this row is accurate about what we DO, and unproven about whether we MAY.
> | 3 | **Payments / receipts / Official Receipts** | 0026, 0034 | payment date | **10 years** — *legal floor, cannot delete early* | BIR RR 17-2013 | Purge at 10 y |
> | 4 | **Contracts + e-signatures** | 0032 | contract execution date | **10 years** | Civil Code Art. 1144 prescription | Purge at 10 y |
> | 5 | **Account / profile PII** (`users`, settings) | 0025 | account close / deletion request | **Life of account + 30–90 day tail**, then purge | RA 10173 storage limitation | Soft-delete → hard-delete after tail |
> | 6 | **Face-recognition vectors** (`face_enrollments`) | 0012 | `event_date` | **Per-event only; revocable on request. (!) CORRECTED 2026-08-07 — this read "purge with media (≤5 y)". The media row was corrected 2026-08-02 to retain the compressed copy INDEFINITELY, so "purge with media" silently became "never purged" and this row was not re-read. Nothing in the codebase deletes a face vector on a schedule — only erasure-on-request does. There is currently NO automatic end date. Whether one is required under the storage-limitation principle is an OPEN DPO question, not a settled rule.** | RA 10173 sensitive data; per-event-scoped lock | Delete on revoke or at media purge |
> | 7 | **Marketing consent / comms prefs** | 0025, 0028 | last consent change | Life of account + audit tail | RA 10173 / CAN-SPAM proof-of-consent | Purge with account |
> | 8 | **Support tickets / help-center** | 0029 | ticket close | **2 years** | Operational necessity | Purge at 2 y |
> | 9 | **Observability / logs** (Sentry, PostHog) | 0035 | event timestamp | Provider default (≤**90 days**); **no PII in logs** | RA 10173 data-minimization | Provider TTL |
> | 10 | **Device-fingerprint hashes** (`user_devices.device_hash`) — fraud prevention | Fake-Inquiry Protection (Phase E) | `last_seen_at` | **Life of account**; rolling-prune device rows unused **> 24 mo** (proposed) | RA 10173 §12(f) legitimate interest (fraud prevention); pseudonymous, non-sensitive | Purge with account (class 5 tail) or on rolling prune |

The clocks, stated plainly

- **Chat = 5 years**, anchored to `event_date`.
- **Media has its OWN clock and it is not five years** (see row 2, and § "Papic media" below). (!) **CORRECTED 2026-08-07** — this line previously read *"Default = 5 years for the experience data (chat + media)"*, which **contradicted row 2 of this same document** and restated the very claim row 2 exists to retract. *A schedule that records the decision in one row and contradicts it three lines later will be read from whichever line the reader hits first* — and this is the summary, so it is the line most people hit.
- **Legal-hold floor = 10 years** for anything touching **money or a contract** — flagged and **exempt** from the sweep.

Papic media — the three numbers, and how they interlock (owner-locked 2026-08-07)

	value	where it is enforced

Cameras may start shooting	**6 months** before the event	`PAPIC_CAPTURE_MONTHS_BEFORE`
Full-res ORIGINAL held at full resolution	**6 months** from the event's **first capture**	`DEFAULT_FULL_RES_RETENTION_DAYS = 183`
…but never less than	**3 months after the event date**	`FULL_RES_POST_EVENT_GRACE_DAYS = 92`
The phrase itself (compressed copy)	**free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.**	no expiry rule in code

The eligibility rule is `GREATEST(first_capture + 183d, event_date + 92d)` in migration `20271102113000` — the **later** of the two, so the floor can only ever hold the original at full resolution for longer.

NO PHOTO IS EVER DELETED — SAY "COMPRESSED", NOT "DELETED"

Owner-corrected twice, most recently 2026-08-07: *"again. not delete. just compress."* This is the single most-repeated wording error on this product, so it is stated here rather than assumed.

Nothing disappears from a customer's gallery, ever. A compressed copy of every photo is derived at capture time and kept **free, for life** (owner 2026-08-18, *"we keep it for life"*, superseding the 2026-08-07 five-year window — and **nothing is deleted at 5 years**). What the window above governs is **resolution**: at the end of it, the full-resolution *original file* is replaced by that compressed copy.

[OK] **The code enforces this and cannot do otherwise.** `isEligibleForDrop` (`lib/papic-fullres-drop-core.ts`) returns `false` when no compressed copy exists — its own comment reads *"dropping would LOSE the photo"* — and the clip path additionally requires the web copy to be a **distinct object** from the poster still. There is no code path that removes an original before its replacement exists.

House wording, lifted verbatim from the warning email (copy this, do not invent new phrasing):

> *"Your gallery stays online forever, free. We'll switch the full-resolution copies we host to a lighter, compressed version — that compressed gallery stays online for you forever. Your gallery keeps every photo; we just won't be holding the*

> *full-resolution originals after that."*

[X] Never write, in any customer-facing surface: *deleted · we delete your photos · purged · removed · gone · lost · expires · auto-delete*. [OK] Write: *compressed · replaced by a compressed copy · we keep a compressed copy forever*.

(!) This carve-out does **not** apply to features that genuinely delete — a host removing a photo, an RA 10173 erasure request, account deletion, the 5-year chat sweep. Those really do delete and must keep saying so.

The third number is the promise, not the second. Because shooting may open six months before the event, a photo taken at the earliest permitted moment has its own six-month clock expire **on the wedding day itself**. Every day a couple keeps their originals *after* their own wedding is bought by the 3-month floor. The 5-month capture cap and 30-day floor that appear in older documents were superseded on 2026-08-07 — **do not reason from that pair.**

(!) **Never state this as a flat "we compress everything at 6 months"** either — even about the original file, that over-commits four ways: clips/video are not compressed or replaced at all today (`PAPIC_CLIP_DROP_ENABLED` is opt-in and off); events with no Google Drive connected **hold the originals indefinitely** until a warning is provably sent plus a 7-day grace; Drive-connected events **defer** until the copy is confirmed; and the window is env-overridable. Honest phrasing: originals become **eligible for replacement** at that point, and a weekly sweep swaps them for the compressed copy unless one of those holds applies.

---

3. Right-to-erasure interaction (RA 10173 §16)

A user's erasure/account-deletion request (iteration 0025) deletes their personal data **now**, **except** records under a legal-hold floor (classes 3 & 4 — payments, contracts), which are **retained under the legal-obligation basis** and disclosed as such in the privacy policy.

This carve-out is standard and defensible: *"We honor deletion requests except where law requires us to retain financial and contractual records, which we keep for the statutory period and then dispose of."*

---

4. Implementation reality (as of 2026-07-11)

Audited against shipped code — **the retention plumbing is greenfield**; almost none of this is enforced yet:

- **Chat** (`chat_threads` / `chat_messages`): text-only, append-only, no attachments. **[OK] UPDATED 2026-07-24 (PR #3634, migration `20270926679942`):** `chat_threads.archived_at` NOW EXISTS. Remove-vendor / withdraw now **archives** (stamps `archived_at`, thread + messages preserved, re-add resumes the same thread) instead of hard-deleting; the `chat_threads` **DELETE RLS policy was REMOVED** → no authenticated user can hard-delete a thread (chat is now an immutable evidence layer). Only service-role paths (retention sweep + RA 10173 erasure) delete. `chat_messages` stays append-only (SELECT+INSERT only). `chat_threads.updated_at` tracks last activity. *(This resolves the old "chat is user-deletable" assumption in the class-1 row above.)*
- **R2 lifecycle: NOT configured** — hot→cold tiering + expiry exist only as prose in `OWNER_ACTIONS.md` and marketing copy. No `wrangler.toml`/Terraform in the repo. **This is the real space program** (media = gigabytes; chat = megabytes).
- **No cleanup cron** touches chat/media. House style deliberately avoids `pg_cron` (uses Vercel cron + on-access sweeps).

- **(!) Compliance gap:** account hard-delete (`admin/users/actions.ts` → `deleteUser`) sets chat user-FKs to NULL but **leaves message bodies (the couple's PII) in `chat_messages` indefinitely** — threads only cascade on *event* delete, and events are never deleted. Fixing this is part of enforcing class 1 & 5.

Build order to enforce this schedule

1. **Archive (UX, zero deletion)** — add `archived_at` to `chat_thread_reads` (per-user); inbox filter `archived_at IS NULL OR chat_threads.updated_at > archived_at` (Viber-style: a new message un-archives). Ships safely on its own.
2. **R2 lifecycle** — actually configure bucket rules for class 2 (the gigabyte win).
3. **Retention sweep** — weekly Vercel cron `/api/cron/retention-sweep`: hard-delete **class 1 (chat) only** at anchor + 5 y; **skip** any thread/record tied to an active legal hold (class 3/4). Fix the account-deletion residue in the same job.
(!) **CLASS 2 (MEDIA) IS NOT ON THIS SWEEP AND MUST NOT BE ADDED TO IT** (corrected 2026-08-07). Media is handled by `lib/papic-fullres-drop.ts`, which **replaces a file** — it swaps the full-resolution original for its compressed copy and refuses to act when that copy is missing. It does not delete a record, and no photo is ever deleted on a schedule. Wiring class 2 into a hard-delete sweep would destroy galleries we promise to keep for good.

---

5. Open items for counsel `[PENDING COUNSEL]`

1. Confirm **BIR retention = 10 years** for in-app SKU payments + Official Receipts (RR 17-2013) and the exact record scope.
2. Confirm **contract retention** period + whether e-signature audit trails (RA 8792) extend it beyond 10 years.
3. Ratify the **5-year period for CHAT** as "necessary" under RA 10173 §11(e).
(!) **Media is NOT on the 5-year clock** — see the Papic media table above. This item said "chat + media" until 2026-08-07, which would have put the wrong number in front of the DPO.
4. Approve the **erasure carve-out** wording (§3) for the privacy policy.
5. Confirm **face-vector** treatment as sensitive personal information and the per-event purge rule.
6. Sign off on **device-fingerprint hashes** (class 10) — legal basis (legitimate interest vs consent), notice wording, and the 24-month rolling-prune period. See the dedicated one-pager `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md`.

Related: `[[dpo-designation-owner]]` · `0025_profile_settings/` · `0026_bir_tax_compliance/` · `0032_contract_intelligence/` · `0019_communications/` · `Pricing.md § 2.1` (media storage/longevity ladder).

Privacy Reconciliation — Updated Home & New Data Flows vs. the Privacy Corpus

> **Revised 2026-10-22 — historical gap register.** Many SEV-1 gaps below were closed after 2026-07-13: `/privacy` now discloses faith / minors / dependents, the device identifier, anti-fraud, Pabuya details (but not yet the new gift records), the payment-receipt read and most processors (Apple, Cloudflare Turnstile, Meta/Instagram sync and browser push services are still not named); face enrolment is adults-only. Vendor ID verification (Persona etc.) was retired 2026-07-03. For the current state read `NPC_Compliance/00_WHAT_CHANGED_2026-10-22.md` and the ROPA (DPS-01 → DPS-28).

Date: 2026-07-13 · **Type:** compliance deep-dive + gap register · **Status:** findings for owner/DPO/counsel — nothing silently changed
Trigger: owner — *"do a deep dive and track. most specially we updated our home."*
Method: 4-front audit — (1) redesigned couple **Home/Event Overview** data flows (worktree `feat/overview-council-redesign` @ `4eb39a329`, PR #3188), (2) new 2026-07-12 capture features + SPI/minor + build-state (grounded in `origin/main` migrations), (3) the live `setnayan.com/privacy` notice content, (4) the 9-doc privacy corpus for canonicity + conflicts. Load-bearing facts re-verified directly against `origin/main` before writing.

> **Headline.** Setnayan is **collecting sensitive personal information and minors' data in production, live, with disclosure gaps.** Profile **religion + civil status + gender** capture is live with no flag; the **dependents** table (minors' birth-date + religion + sex + godparent third-party emails) is recorded as flag-ON in prod (DECISION_LOG 2026-07-13); the onboarding **`events.signature_details`** path collects a child's DOB/gender and a pregnancy due-date with **no flag and no consent stamp**; and the couple **Home** now renders explicit religious-rite data. Meanwhile the **live privacy notice (last updated 2026-07-04)** mentions **none** of faith, minors, device-fingerprint, or e-gift handles — and **affirmatively denies collecting biometrics** while a biometric-enrollment feature is built. The freshest master dossier (2026-07-12) is the **narrowest** SPI declaration in the corpus and is **uncommitted**.

A. LIVE-NOW gaps — SPI / minors / financial PI collected in prod, undisclosed (SEV-1)

Ranked by exposure. "Live" = shipped on `origin/main` with capture reachable in production.

#	Data collected	Where	RA 10173 class	Build state (verified)	Disclosed anywhere?
1	**Religion + civil status + gender** (self)	`users.religion` / `civil_status` / `sex` (+ `*_consent_at`)	(!) SPI §3(l) — religion & marital status; sex sensitive-adjacent	**LIVE, no flag**, consent-stamped. `profile/actions.ts` writes directly (verified `origin/main`). Gender added today (PR #3209).	[X] Notice/dossier §5 list only biometrics as SPI

2	**Dependents** — minor's `birth_date` + `sex` + `religion`; **godparent name + email** (3rd party); godchild-birthday emails to that 3rd party	`dependents`, `godparents`	(!)(!) Minor + SPI + third-party PII	**Shipped; flag `NEXT_PUBLIC_DEPENDENT_PEOPLE` default OFF in code, but DECISION_LOG 2026-07-13 records owner set it `=1` in prod ("long done").** If so → **collecting now**; godchild emails go live next deploy. Household RLS shares a child's record with the spouse and **persists after annulment/separation** (owner rule B6).	[X] Zero coverage. Privacy amendment (07-05) still says person-graph is *"adults-only… minors not processed"* — now contradicted
3	**Onboarding specialty fields** — christening `child_birth_date` + `child_gender`; gender-reveal **pregnancy `due_date`**; `ceremony_rite/rite_type` (religion); birthday `celebrant_age`	`events.signature_details` JSONB	(!) Minor + minor's sex + health-adjacent (pregnancy) + religion	**LIVE, NO flag, NO consent stamp.** With all 14 event types enabled (#3127), a christening/gender-reveal create-flow accepts these today. Gender-reveal `due_date` **contradicts the council's own Q3 "defer due-date capture until counsel clears."**	[X] Not disclosed; **collectable outside the counsel gate that governs the parallel `dependents` table**
4	**Explicit religious-rite data on the couple HOME** — Muslim nikah overlay (`mahr_description` free-text dower, `gender_separation`, `wali/witness/imam` guest roles), Chinese/Tsinoy tea-ceremony tile	`events.*`, `guests.role`, surfaced by Overview overlays	(!) SPI §3(l) religion	**LIVE** — rendered on `/dashboard/[eventId]` Home	[X] Notice never mentions religious ceremony as a data category

5	**Biometric face enrollment** — selfie + mandatory biometric-consent flow; `face_vector` column exists	`guest_face_enrollments`	(!) SPI §13 biometric	**Built.** Code comment: vector is **DORMANT** (image-only enrollment until an embedder/model is live) → selfies + consent captured now, vectors not yet stored.	(!) **Notice affirmatively DENIES it** — lists *"Face biometrics or any other biometric data"* under **"What we do not collect."** Denial is currently technically-true-for-vectors but false the moment the model ships, and the consent/table already exist
6	**Pabuya e-gift handles** — couple's own `gcash/maya/bank/paypal` handle + `account_name` + receiving-QR image	`event_egift_methods`	(!) Financial PI (not §13 SPI); display-only by design (no amount/ledger column)	**Table LIVE**; public guest route `PABUYA_PUBLIC_ROUTE_ENABLED=1` in prod per DECISION_LOG 2026-07-13	[X] **Zero mentions in all 9 privacy docs** — largest fully-undocumented processing activity

Data-minimization note (home): the Overview server component loads **full guest rows** — email, mobile, `dietary_restrictions`/`meal_preference` (health-adjacent), and `photo_consent`/`faceblock_enabled`/`face_recognition_excluded` (biometric-adjacent) — into memory even though only aggregate counts render. Co-host/invitee **email addresses are displayed** in the Hosts card, read via the RLS-bypassing admin client. Not a disclosure gap, but a minimization item worth a pass.

What bounds the exposure (good news): on the *home surface specifically*, dependents/minors' Year-view data is **flag-off and its commits are not in the redesign branch** (year-view code asserts "zero PII, no birthdates"), and **no e-gift handle is surfaced on any home surface**. So gaps #2 and #6 are live in their own routes, not additionally leaked onto Home.

B. Doc-corpus conflicts & staleness to reconcile (SEV-2/3)

The corpus is **four layers, no single canonical doc**. Deepest/most complete = the **tracked `NPC_Compliance/` pack** (11-system RoPA + DPIAs). The shiny **`NPC_Privacy_Compliance_Dossier_2026-07-12.md`** is the freshest executive summary but the **narrowest** SPI declaration — treat it as a summary annex, not the filing backbone.

- **Device-fingerprint "is it live?" — direct conflict.** New dossier §4 + `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12` say flag-OFF / collects nothing. But `01_Contracts/Anti_Fraud_Privacy_Policy_Amendment_DRAFT_2026-07-08` B.1 says *"we analyse signals we already hold: your device fingerprint… already active (shipped 2026-07-07)"* and DPO Designation B.5 lists it "live 2026-07-07." **Reconcile before either publishes.**
- **Dossier's PIA claims the fingerprint disclosure was "published in the public privacy notice 2026-07-12."** The live notice is dated **2026-07-04** and contains **no** device-fingerprint language. The claim is unsupported by the page.
- **SPI under-count in the new dossier.** §5 names only biometric vectors. The NPC pack treats **vendor gov-ID + liveness + AMLC/PEP sanctions** as the SPI categories that *trigger NPC registration* — the new dossier drops the entire vendor-verification surface. Filing the dossier as-is would under-declare.

- **DPO contact split.** New dossier → `dpo@setnayan.com`; every other doc → `iscasasolaii@gmail.com`. Two published DPO addresses. (DPO **identity** is consistent everywhere: the proprietor, Indalecio S. Casasola II — no doc names "Claire.")
- **Response-SLA split.** Dossier says **15 business days**; Privacy Policy §9 + DPO Designation say **7 business days**.
- **Retention — binding policy is stale.** `Setnayan_Privacy_and_Security_Policy.md` §4 has **no 10-year floor** (5y/7y model) and contradicts the newer `Data_Retention_Schedule_2026-07-11` (10-yr floor on payments/OR + contracts). The schedule's own §4 flags a **live gap**: account hard-delete **leaves chat PII behind**. Vendor-verification retention (90d hot → 7y cold) exists in the policy but is **absent from both the new schedule and the dossier ROPA**.
- **Subprocessor list omissions.** `/privacy` names **Persona** + **Anthropic** as cross-border recipients but leaves them **out of the Subprocessors table**; **Suno** (music generation) is missing from policy §10.
- **Cookie consent is `localStorage`-only** (`setnayan-cookie-consent-v1`) — no server-side consent-events log, which weakens RA 10173 proof-of-consent retention.
- **Stale one-pager.** `Setnayan_AI_Data_Use_DPO_Review_2026-06-29` frames the AI as a *paid* assistant learning from *browsing behavior*; current direction is **deterministic + free** — the behavioral-personalization framing reads stale.
- **Durability risk.** The three newest/most-relied-on docs — **dossier (07-12), retention schedule (07-11), fingerprint one-pager (07-12)** — are **UNTRACKED (uncommitted)**, i.e. the current "canonical" master + retention authority are the least-durable files in the set.

C. Owner / DPO / counsel decision queue (NOT actioned here — surfaced per corpus rules)

These are load-bearing and/or legal; I did not change the notice, the dossier, or any flag.

1. **Confirm the prod flag reality.** DECISION_LOG asserts `NEXT_PUBLIC_DEPENDENT_PEOPLE=1` and `PABUYA_PUBLIC_ROUTE_ENABLED=1` are ON in Vercel prod (unverifiable from the repo). If ON, the dossier must add a **live SPI+minors** processing activity (dependents) and a **financial-PI** activity (e-gift), incl. the household RLS spread + post-dissolution retention.
2. **Close the `signature_details` SPI hole.** Either gate the christening `child_birth_date`/`child_gender`, gender-reveal `due_date`, and `ceremony_rite` fields the same way the `dependents` table is gated, or attach equivalent consent copy + retention. The un-flagged due-date field directly contradicts the council's own defer recommendation.
3. **Fix the biometric denial.** The notice's "we do not collect biometrics" is a landmine given `guest_face_enrollments` + consent flow exist and vectors go live when the embedder ships. Rewrite to "optional, opt-in, per-event, currently image-only" rather than a flat denial.
4. **Publish the faith / minors / e-gift / device-fingerprint disclosures** in the public notice + add ROPA rows. These are the four categories the notice omits.
5. **Reconcile the corpus conflicts** in §B: pick one DPO email + one SLA; add the 10-yr floor + vendor-verification class to the binding policy; add Persona/Anthropic/Suno to the subprocessor list; resolve the device-fingerprint live/off contradiction; decide on a server-side consent log.
6. **External counsel sign-off** for the §3(l)/minors/third-party-notify cluster and the BSP-OPS e-gift question — the specs flagged *external* review as required; the owner-is-DPO marking resolves the internal step only.

D. What was tracked in this pass

- This document (the gap register).
- `DECISION_LOG.md` row (2026-07-13).
- Memory: `project_setnayan_privacy_reconciliation.md` + index pointer.
- The three previously-untracked privacy docs (dossier 07-12, retention schedule 07-11, device-fingerprint one-pager 07-12) committed into git history alongside this, so the canonical set is durable.

Not done (needs owner/DPO/counsel): editing the live `setnayan.com/privacy` notice (code-repo change + legal disclosure), or flipping any feature flag.

Correction — 2026-07-13: "dependents" is generic, not a minors registry

Owner: *a dependent "can be a dog, a cat, or anyone — there is no specification that it needs to be a child."* This audit (§A row 2, §C, and the "minors' data" framing throughout) over-characterized the `dependents` table as a minors registry. It is now a generic **"someone (or something) you care for"** list with a `dependent_kind` (person / pet / other) — app PR #3219. Only `kind=person` may carry a birth date / religion / sex under the age fence, and only there does minors' SPI arise (as a **conditional sub-case**, when the adult enters a child). Pets/other carry no sensitive data. Treat every "dependents = minors' data" statement in §A/§C as reframed by this note; the dossier §3/§5 and binding policy were updated to match.

Correction — 2026-07-13: the live notice was better than first reported

When the `/privacy` notice was edited (PR #3215), reading `origin/main` directly revealed the earlier extraction (agent, §A row 5 + §B) was from a **stale local checkout**: the deployed notice **already** carried a proper opt-in **Biometric** section (no "denies biometrics" line) **and** a **Device identifier (fraud prevention)** section. So gaps #5 (biometric denial) and the "notice omits device fingerprint" claim were **not real on the live site**. The genuine notice gaps were narrower — faith/family/honoree/e-gift + Anthropic/Suno — and those are what PR #3215 added. The dossier §5/§4/§11 were corrected to match. Treat §A row 5 and the §B "device-fingerprint disclosure" bullet as superseded by this note.

Update — 2026-07-13: dossier upgraded to a submittable v2.0

Owner: *"edit it and update so that will be the document we can submit NPC."* `NPC_Privacy_Compliance_Dossier_2026-07-12.md` was rewritten to **v2.0** and the `.docx` mirror regenerated. It now closes the **document-side** gaps from §A/§B: the ROPA (§3) covers all 18 processing activities incl. self-profile religion/civil/gender, the dependents/godparents family graph, event honoree/`signature_details` data, e-gift handles, and vendor-verification identity; the SPI declaration (§5) enumerates every sensitive category (was biometric-only); the subprocessor list (§7) adds Persona/TikTok/Suno; retention aligns to the 07-11 schedule's statutory floors. Owner decisions applied: **device fingerprint = OFF/dormant**; **minors' `signature_details` SPI = documented as-is**; DPO contact `dpo@setnayan.com` + 15-day SLA (matching the live surfaces). A consolidated **§11 "Open items before filing"** carries the residue: external counsel review (the final gate — this is a DPO draft, not legal advice), the **public `/privacy` notice** reconciliation (add faith/minors/e-gift/fingerprint disclosures + fix the biometric denial), and the older-corpus alignment (gmail→dpo@, 7→15-day SLA, 10-yr floor + vendor class + Persona/TikTok/Suno into the binding policy). **Still not done — needs owner/counsel:** the notice edit and external legal sign-off.

Device-Fingerprint Capture — One-Pager for DPO Review

> **Revised 2026-10-22.** The capture was measured collecting in production on 2026-08-17 (9 rows / 4 accounts; disclosed on `/privacy` §"Device identifier"). In code it is behind `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` and the `device_fingerprint` control — a code default is not the production value; check `/admin/data-privacy`. The server salt is fixed (`DEVICE_HASH_SALT`), which clustering needs. Owner as DPO (2026-09-16): hashes deleted on account close, excluded from export, pruned on a schedule — the 24-month prune promised on `/privacy` has **no job in code yet**. The "vendors are charged per lead" premise below is outdated (answering is free); the basis is review/rating integrity (finding #19 of 2026-08-24). LIA + DPO sign-off: task `t2-10`. DPO contact: dpo@setnayan.com.

> **For:** the Setnayan DPO (the owner, Indalecio S. Casasola II — per `[[dpo-designation-owner]]`), NPC-registered.
> **Ask:** review + sign off on the legal basis, notice wording, and retention below before the **device-fingerprint capture** (fake-inquiry protection · Phase E) is switched on. The design is deliberately minimal and privacy-preserving — this should be a **sign-off, not a redesign**.
> **Date:** 2026-07-12. **Law:** RA 10173 (Data Privacy Act) + NPC issuances.
> **Companion:** `Vendor_Fake_Inquiry_Protection_Build_Plan_2026-07-11.md` (Phase E), `Data_Retention_Schedule_2026-07-11.md` (new class 10).

What we want to do

To catch **sock-puppet fraud** — one bad actor (often a competing vendor) spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer — we need to tell when several "different" accounts are really **the same browser/device**. So, on a **secured (logged-in) account**, we record a **coarse, first-party device identifier**:

- A **random id** generated once in the browser's `localStorage` (like a cookie). It is **NOT** a behavioral/biometric fingerprint — no canvas/font/WebGL probing, no third-party fingerprinting SDK, no cross-site tracking.
- Sent to our own server, where it is **hashed** (`SHA-256` with a server-side salt) and stored as `user_devices.device_hash` against the account. **The raw id is never stored** — only the one-way hash.
- Two accounts that share a device produce the **same hash**, which lets our existing fraud-clustering flag them for **human review** (it never auto-bans anyone).

Nothing here is shared with any third party, used for advertising, or used to profile a couple's planning behavior.

The legal basis we're relying on

- **Legitimate interests (RA 10173 §12(f))** — preventing fraud and protecting the integrity of the marketplace (and the vendors who pay us) is a textbook legitimate-interest processing purpose. The data is a **pseudonymous hash**, the least-intrusive signal that achieves the purpose, and it is **not sensitive personal information**.
- Balancing test: the intrusion is minimal (a hashed random id, fraud-only, no tracking), the interest is substantial (vendors are charged per lead; fakes are a direct financial harm), and it is disclosed. We assess legitimate interest as the correct basis rather than consent — **but this is the DPO's call** (see item 1 below).

The seven safeguards built into the design

1. **Coarse by design.** A random localStorage id — explicitly **not** a canvas/font behavioral fingerprint and **no external SDK**. It identifies a *browser*, not a *person's* behavior.

2. **Hashed, raw value never stored.** `SHA-256(salt + id)` server-side; the DB holds only the hash. The salt is a server secret.

3. **Purpose limitation.** Used **only** for fraud detection (identity-cluster review). Never for ads, marketing, personalization, or sold.

4. **Secured accounts only.** Anonymous/draft sessions are not captured — no fraud-subject identity, no capture.

5. **Data minimization + first-party only.** One hash per (account, device) + a `last_seen_at`. No IPs stored for this (IP is explicitly out of scope of the cluster signals). No third-party recipients.

6. **Retention clock.** New **class 10** in the retention schedule: kept for fraud-prevention while the account is active, **purged with the account** (class 5 tail); `last_seen_at` enables a rolling prune of stale device rows. Confirm the period (item 3).

7. **Rights honored.** The device hash is account-linked personal data → included in the existing **"download my data"** export and **deleted on account deletion** (iteration 0025). An opt-out is available if the DPO decides consent (not legitimate interest) is required.

What we'd like the DPO to confirm

1. **Legal basis** — that **legitimate interest (fraud prevention)** is the correct basis, so this can be **on-by-default when enabled** with notice; OR direct us to make it **consent-based** (a Privacy-settings toggle, defaulting off).

2. **Notice wording** — proposed privacy-policy line: *"To keep our marketplace safe, we record a hashed identifier for the device you sign in from and use it only to detect fraud and fake accounts. We don't use it for advertising or tracking you across other sites."* Confirm this is adequate.

3. **Retention period** — confirm class 10 (life-of-account + purge-with-account, with a rolling prune of device rows unused for a set period — propose 24 months).

4. Whether a **Privacy-settings entry** (disclosure + optional opt-out) is required in addition to the policy notice.

Engineering state (so the DPO knows the stakes)

LIVE — collecting in production since 2026-07-12. (!) CORRECTED 2026-08-17: this was described as built-but-switched-off. Measured in production on 2026-08-17: 9 device rows across 4 accounts, first written 2026-07-12, most recent the same day as this correction. The 2026-07-23 instruction to hold it off was SUPERSEDED on 2026-07-24 by the owner-locked Interim Payments & Privacy Deferral Policy, which deliberately activated it; the live public /privacy notice discloses device-fingerprint processing accordingly. Basis relied on: RA 10173 §12(f) legitimate interest (fraud prevention). STILL OWED: the documented legitimate-interest assessment (NPC task t2-10). Collection is coarse and first-party — a random id in localStorage, hashed server-side, raw never stored; no canvas/behavioural fingerprint and no external SDK; secured accounts only.

_(The original text read: "Built but switched OFF behind a flag (`NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED`, default OFF) — it cannot collect anything" until the flag is flipped, which we will not do until this sign-off. Fully reversible (flag off → capture stops; existing `user_devices` rows are purgeable). The capture only writes `user_devices`; the fraud-cluster detection it feeds runs in **shadow mode** (admin review only, never auto-action).

Related: `[[dpo-designation-owner]]` · `Data_Retention_Schedule_2026-07-11.md` (class 10) · `Vendor_Fake_Inquiry_Protection_Build_Plan_2026-07-11.md` (Phase E) · `0025_profile_settings/` (export + deletion + Privacy tab) · `Setnayan_AI_Data_Use_DPO_Review_2026-06-29.md` (sibling DPO one-pager).